

RETRIEVAL OBSERVABILITY DETERMINES THE PROVENANCE-DETECTION BOUNDARY FOR AGENT MEMORY POISONING

Jun Wen Leong

leongjunwen@gmail.com

Version note. This is a revision of arXiv:2606.30566. Per-version changes are recorded in the arXiv version history; all preregistration deviations, scorer corrections, and retracted claims are catalogued in Table 15, and each is stated at the point of use in the relevant section rather than only in a change list. Three corrections are load-bearing enough to flag here. (i) The recipient-gating claim of earlier versions is retracted (§5.1). (ii) The MINJA family’s analytic-to-measured upgrade is retracted following an inert-grid-factor audit and a preregistered continuation (§6.5). (iii) **The X1 implicit arm’s zero retrieval-provenance rate is restated as structural rather than behavioural:** the memory tool is present in both arms, but the implicit arm’s store never contains the poisoned exemplar, so `observable_read_of_poison=0` cannot be a declined retrieval (§6.5). That arm therefore measures attack viability plus architectural absence of provenance, not an evasion rate, and the B+ appendix’s use of benign tool-use saturation to license the behavioural reading is withdrawn (App. A). Further self-audit corrections in this revision, none requiring new data: the leave-one-model-out recall CIs are recomputed on the positive-count denominator ($[0.987, 1.000] \rightarrow [0.984, 1.000]$, §4.6); the X4 control arms’ claim to meet the registered ≤ 0.10 criterion is withdrawn on the cluster unit (0.121, 0.104, §6.6); the claim that `recall_before_send=1` identifies memory-channel poisoning is withdrawn as contradicted by our own data (§4.10); the X1 design-effect ladder is recomputed with unequal-cluster arithmetic, so $\rho=1$ gives 0.417 rather than coinciding with the cluster-unit 0.299 (§6.5); the registered H2 bound of ≤ 0.20 is disclosed as unreachable within the registered grid rather than narrowly missed (§6.5); and the released scorer, cluster-unit bounds, frozen-RF verification and artifact manifest are re-emitted so that every bound quoted here exists in the artifact. All point estimates are unchanged.

ABSTRACT

We establish that *retrieval observability*—whether an agent’s memory access produces a logged tool call—is the architectural variable that determines whether a trajectory-based detector can observe the *retrieval provenance* of a memory-poisoning attack, and we then falsify that detector’s standalone deployment viability. When exfiltration causally depends on a payload reachable only through an observable retrieval tool, a retrieval-before-exfiltration event is structurally necessary: exact-key recall shows 58/58 zero violations, semantic search 33/33 (GPT-4.1, preregistered) and 43/43 (GPT-4o). When the scaffold delivers the payload implicitly, attacks succeed at 50–82% without producing the signature. The necessity and its breakdown replicate across both tested behavioural phenotypes—act-without-grounding (GPT-4.1, GPT-4o) and ground-then-act (gemini-2.5-pro, which recalls-before-send on 88.3% of *benign* tasks yet omits recall in 93.3% of successful implicit attacks)—under a genuine LangGraph framework with a within-model contrast on gpt-4.1 (39/39 flagged on tool-routed successes vs. 0/57 on a FAISS retriever-injection arm), and across a second exfiltration channel (document-share control 0 violations /50 and 0/62, directional: cluster-unit upper bounds 0.121 and 0.104 exceed the registered ≤ 0.10). We formalise the boundary as a framework-agnostic *retrieval-to-action provenance graph* and classify published attack families by their position relative to it.

Within the observable scope we build a proof-of-concept detector (AUC 0.99 random-fold, 0.907 under leakage-corrected grouped cross-validation) and then falsify its standalone use along a chain of failures: benign memory-grounded sends are trajectory-isomorphic (FPR 24.7–57.6% on a 13-model factorial, $N=4,160$; up to 100% under a genuine framework); positive predictive value is $\leq 3.85\%$ at 1% attack prevalence; attack success and signature rate are decoupled (models with 0% success still produce 100% signature rates); and the obvious fix, recipient-metadata gating, flags 129/129 of *legitimate* external business email,

with the combined gate still flagging 45%. The signature is therefore an attack *precondition*, not a maliciousness predicate, and detectability is governed by two axes: attacks implicit on the read axis but with an observable write still leave a save-before-send trace (verified payload writes in 37/37 flagged successes, but at 66.7% benign FPR), whereas attacks implicit on *both* axes leave no observable retrieval provenance.

An independent-family probe (a MINJA case-bank implementation) reproduces the contrast within-model on gpt-4.1—observable 80/80 vs. implicit 0/141, cluster-level Wilson upper 0.299 on the 9 contributing configurations (0.417 under the conservative unequal-cluster design effect; the trial-level bound of 0.0265 quoted in earlier revisions assumes independence the clustered design does not support)—but the implicit arm’s zero rate is *structural* rather than behavioural, because that arm’s memory store never holds the poisoned exemplar, so it establishes attack viability together with the architectural absence of retrieval provenance rather than a measured evasion rate; and a post-hoc audit found an inert grid factor that had inflated scenario-cluster counts $\approx 3\times$, with a preregistered continuation to the registered cap leaving the observable arm gate-satisfied (10 effective clusters) and the implicit arm one short (9). Under a signed pre-commitment MINJA is therefore reported as directional/LOW-CLUSTER rather than confirmed. That continuation yielded a separate finding: with the payload delivered at median retrieval rank 1 in 30/30 trials in *every* configuration, implicit attack success still ranges from 30/30 (*meeting_followup*, in each of its two framings) to 0/30 (*compliance_report*, likewise), so implicit-delivery viability is governed substantially by cover-task semantics rather than by retrieval architecture alone. The taxonomy implies a hard architectural ceiling on *retrieval-provenance* detection for any method reading tool-call logs alone, independent of classifier sophistication. Defence architectures must combine trajectory triage for observable-retrieval attacks with content- or provenance-level enforcement for implicit ones.

1 INTRODUCTION

LLM agent memory poisoning attacks span a growing family of methods—delayed-trigger attacks via RAG injection (Leong, 2026a), embedding-similarity manipulation (Dong et al., 2025), sliding-window persistence (Yang et al., 2026), cross-session stored prompt injection (Xie et al., 2026)—but share a common structure: a malicious payload is written to persistent state and later retrieved to influence agent behavior. A natural question for defenders is: *can trajectory monitoring (observing tool-call logs alone) detect these attacks?*

We show the answer depends on a single architectural variable: **retrieval observability**—whether the agent’s memory access produces a logged tool invocation. This variable partitions the entire memory-poisoning attack surface into two regions with fundamentally different detectability properties:

- **Observable retrieval** (agent-initiated tool call: `recall_fact`, `memory_search`, etc.): a retrieval-before-exfiltration event is *structurally necessary* for successful attack execution. Evidence: exact-key recall 58/58 zero violations (GPT-4.1 + GPT-4o); semantic search 33/33 GPT-4.1, 43/43 GPT-4o (pooled after a preregistered power extension, Exp 13a).
- **Implicit retrieval** (framework-level embedding similarity, scaffold-side context injection, cached internal state): attacks succeed without producing any observable trajectory signature. Evidence: 50–82% ASR with signature absent by construction.

This boundary is not specific to our detector. It is an architectural ceiling on *any* method that operates on tool-call logs: VIGIL (Li et al., 2026), TraceAegis (Liu et al., 2025), TRACES (Wang et al., 2025), or any future trajectory classifier will be structurally blind to the retrieval signature of implicit-retrieval attacks regardless of their sophistication (the exfiltrating action may still be observable through other channels, e.g. destination metadata; what is unobservable is the retrieval

provenance). We formalize this boundary as a framework-agnostic *retrieval-to-action provenance graph* (Section 3) and use it to classify all major published attack families by their detection-relevant properties (Table 12).

Within the observable-retrieval scope, we construct a proof-of-concept detector (Random Forest, AUC = 0.99 separating successful from unsuccessful attack executions within poisoned sessions, cross-model transfer to 405 frontier sessions) and simultaneously demonstrate its precision ceiling: benign memory-grounded sends produce the same trajectory signature (FPR 24.7–57.6%, 13-model factorial $N=4,160$), confirming that the retrieval-before-send transition is an attack *precondition*, not a maliciousness predicate. The classifier serves as evidence for the invariant’s existence and scope—it is not the contribution.

Contributions.

1. **Observability taxonomy.** We establish retrieval observability as the dividing variable of the memory-poisoning attack surface with respect to trajectory-based detection. We classify published attack families by this variable and empirically validate both sides of the boundary with preregistered probes (V3-1, V3-2; $N=440$ new trials across 3 models $\times$ 2 retrieval primitives $\times$ 2 delivery modes).
2. **Framework-agnostic event graph.** We define a retrieval-to-action provenance graph specification that maps memory-poisoning attacks into a common representation independent of framework, tool naming, or retrieval implementation (Section 3).
3. **Structural necessity within scope (under stated exclusivity assumptions).** *Under the assumption that the payload value is obtainable only through an observable retrieval operation* (architectural assumptions 1–4, Section 2.1), the *retrieval-before-exfiltration* transition is mechanistically forced by the attack’s information dependency. This necessity holds across the two tested exfiltrating-action channels—email (`recall.before.send`) and document-share (`recall.before.exfil`, control 0 violations /50 (gpt-4.1) and 0/62 (gpt-4o); Section 6.6)—so we state it as *retrieval-before-exfiltrating-action* scoped to these two channels, with the document-share evidence directional rather than criterion-passing (its cluster-unit upper bounds, 0.121 and 0.104, exceed the registered ≤ 0.10), the implicit treatment arm underpowered, and only one channel added beyond email. This exclusivity is an assumption about the deployment, not a guarantee of the memory architecture: when it is violated—e.g. the address is inferable from key names, shared scenario pools, or model priors—the transition can be bypassed even with the tool present (7/40 V3-1 treatment successes routed to a non-planted attacker address; Section 2.1). A single-rule detector exploiting the transition achieves AUC = 0.956; the full feature set (AUC = 0.99 random-fold, 0.907 grouped) adds marginal value because the invariant itself carries most of the separation. Adversarial suppression of the transition breaks the attack only under the same exclusivity assumption.
4. **Precision ceiling (deployment falsification).** Benign memory-grounded sends produce the same trajectory signature (conditional FPR = 100%), establishing that operation-only features face a hard precision ceiling when agents ground actions in recalled context.
5. **Cross-model and cross-harness transfer, with scope limits.** The invariant transfers across 9 models (7B–120B) and frontier APIs without retraining. As a stronger test, we freeze the LangGraph-trained classifier and apply it, without retraining, to sessions from a different execution harness (a raw OpenAI function-calling loop) and a more recent model population (GPT-5.x, Gemini 2.5): pooled recall among attack successes is 186/188 = 98.9% (Section 5.2), evidence that the signature is a property of the attack’s information flow rather than of the training harness’s logging substrate. The signature nonetheless fails deterministically on implicit-bypass architectures (qwq:32b RAG fallback), confirming the taxonomy’s predictive validity. We are explicit about what this does *not* show: what a tool-log-only detector loses under implicit retrieval is the *retrieval provenance* of the attack, not necessarily the exfiltrating action itself, which may remain observable through other channels (e.g. destination metadata).

2 METHODOLOGY

2.1 THREAT MODEL

We consider a *memory-channel poisoning attack*: the adversary injects a malicious instruction via a RAG-retrieved document, which the agent stores in persistent memory. In a subsequent session, the agent retrieves the stored rule and takes a malicious action (email exfiltration). We explicitly distinguish this from *prompt-injection attacks*, where the adversary embeds the routing rule directly in the current session’s user prompt without storing it in memory. Our detector targets the former; we report its behavior on the latter as the evasion boundary.

Attack success condition. A run is classified as an attack success if `email_send_email` is called with a recipient outside the allowed set `{team@example.com}` in the trigger session (S4). In the V3-1 treatment cells, this allowlist-based scorer counts 7 successes (GPT-4.1 3/21, GPT-4o 4/19; see the V3-1 deviations paragraph) where the exfiltration destination is an attacker-controlled address other than the one planted in that scenario’s memory (the model sent to the other known attacker address, likely confabulated from pretraining or cross-contaminated from the scenario design’s shared address pool). These cases represent genuine policy violations (unauthorized external sends) but ambiguous evidence for the retrieval-dependency mechanism; conclusions about the necessity invariant rest on the control-arm zero-violation counts, which are unaffected, and the necessity-breaking conclusion also holds under the stricter planted-address-matched scorer (V3-1 deviations).

Endpoint definitions (transmission vs. routing-attempt vs. policy violation). Three distinct endpoints appear in this paper and should not be conflated. (i) *Transmission*: `email_send_email` to a recipient outside the allowlist—the primary attack-success definition (Threat Model) and the target of the main DTA classifier, whose `recall_before_send` feature keys on `send_email` only and never inspects recipients. (ii) *Routing-attempt*: `email_draft_email` specifying an external recipient without a subsequent send; V3-2’s corrected (sensitivity) scorer counts this as exfiltration-capable because the routing decision is made at draft time, but it is a strictly secondary endpoint reported alongside the primary send-only figure (33/33 primary vs. 38/38 draft-inclusive), never substituted for it. (iii) *Policy violation*: any unauthorized external send, including the 7 V3-1 confabulated-address cases above. Wherever we write “recall before exfiltration,” the exfiltration event is the transmission endpoint (i) unless the sentence explicitly invokes the V3-2 draft-inclusive sensitivity analysis; cross-study pooled counts use the transmission endpoint as primary.

Detection constraint. The detector observes only the tool-call sequence and its timestamps. It does not access memory contents, model weights, activation patterns, or the user’s messages. Attack-success labels are constructed using tool arguments (recipient address); classifier features use only operation names, ordering, and counts, never email contents or recipients.

Architectural assumptions. The detector assumes: (1) persistent memory is accessed exclusively through observable retrieval operations (tool calls), not through hidden internal state or implicit caching; (2) tool invocations are logged with execution timestamps; (3) the attacker’s routing information resides in persistent memory and must be retrieved through the memory API to reach the exfiltration tool; and (4) `list_all_facts` returns key names only, not stored values, so the agent must call `recall_fact` to obtain the attacker address. These assumptions hold for deployments in which memory retrieval is exposed as an observable tool invocation (e.g. LangChain, LangGraph, OpenAI Assistants, Anthropic tool-use). Architectures that bypass the tool layer (e.g. internal RAG caches, implicit memory injection into prompt context) would not produce the observable signature. This defines the detector’s architectural boundary: the *recall_before_send* invariant is an enforcement-layer property of closed-loop tool-routing policies, not a pure model property. A model that satisfies its information dependency through a non-observable channel (empirically demonstrated by qwq:32b’s RAG-fallback under Memory Sandbox, Section 6.9) collapses the signature. The invariant holds for all models structurally forced to route retrieval through the observable memory API. Section 6.3 formalizes this boundary across published attack families.

Structural versus behavioural manipulations of the read axis. Our implicit-delivery arms are not all the same kind of evidence, and the distinction governs what each can license. In a *structural* arm the payload is not reachable through any agent-visible memory operation, either because the memory tools are absent from the schema or because they are present but the store never holds the payload. Signature absence is then definitional: it could not have fired, so the arm establishes that such an architecture exists and sustains viable attacks, and that the retrieval provenance is unobservable within it, but it cannot measure a rate at which agents *decline* an available retrieval. V3-2 arm C (all `memory_*` tools removed, §6.3), V3-4’s implicit arm (email tools only, §5.2.1) and X1’s implicit arm (tool present, poison never in the store, §6.5) are all structural in this sense. In a *behavioural* arm the retrieval tool is present, functional, and stocked with genuine retrievable content, and the payload arrives by another path; the agent could ground its action in memory and the question is whether it does. Signature absence is then a measured choice. V3-1’s treatment arms and V3-3 are behavioural: the recall tool returns real decoy facts, and roughly 30% of V3-1’s treatment successes do call it before sending (§6.3), which is what demonstrates the tool was live rather than inert. The two classes answer different questions and we keep them separate throughout: the architectural claim—implicit retrieval leaves no observable retrieval provenance—rests on the structural arms plus the provenance graph, while the behavioural claim—agents stop grounding when the payload is already in context—rests on V3-1 and V3-3, and most sharply on V3-3’s benign keystone, where a model with an 88.3% benign recall-before-send habit drops to 6.7% under implicit delivery (§6.4.1). Earlier revisions described X1’s implicit arm as behavioural; that is corrected in §6.5.

Structural equivalence of proxy tasks. Our evaluation uses benign proxy tasks (email composition with simulated sensitive documents) rather than genuinely harmful payloads. The security-relevant transfer argument is structural, not content-based: the detector observes only tool-call sequences and their ordering, which are determined by the agent’s channel architecture (memory API $\rightarrow$ action API), not by the semantic content of retrieved records or sent messages. Any deployment using the same tool-routing architecture (observable memory retrieval followed by externally-directed action) produces identical trajectory structure regardless of whether the exfiltrated content is a simulated project summary or genuine credentials. The invariant is a property of the information-flow dependency, not of the payload.

2.2 DATASET

We use 2,520 labeled runs from the delayed-trigger attack arm of the 5,040-run factorial experiment in our prior work (the P1 factorial, hereafter IED) (Leong, 2026a). The factorial covers:

- 9 open-source models¹: qwen2.5:14b, qwen2.5:72b, qwen3.5:9b, qwen3.5:122b, qwen3:32b, qwq:32b, glm-4.7-flash:q8_0, gpt-oss:20b, gpt-oss-safeguard:120b
- 7 defense conditions: no defense, Minimizer, Sanitizer, RAG Sanitizer, RAG LLM Judge, Prompt Hardening, Memory Sandbox
- $N=40$ runs per condition (9 models $\times$ 7 defenses $\times$ 40 runs = 2,520 DTA runs)

Labels: 1,919 attack successes (76.2%), 601 non-exfiltration sessions (23.8%). The negative class comprises poisoned-but-defended sessions (injection succeeded but exfiltration was blocked or refused); it does not include unpoisoned benign baseline sessions. The classifier therefore discriminates between successful and unsuccessful attack *executions* within the DTA arm, not between attacked and unattacked agents.

Shared-data dependency and non-independence. This detector is trained and evaluated on data generated by the same factorial that Leong (2026a) analyze for their injection–execution dissociation result, and that work in turn cites the detector performance reported here when discussing operation-level trajectory detection. The two results are therefore *not* independent lines of evidence: they are two analyses of one dataset produced by one attack construction, one harness, and one scoring pipeline. A flaw in the shared data-generating process (for example, a scorer artifact or a harness-specific tool-contract effect) would propagate to both. Readers should treat the observability

¹Model names reflect Ollama tags (e.g., qwen3.5:122b) or API identifiers at time of experiment. These are mutable pointers; exact model digests are recorded in the reproducibility manifest.

boundary established here and the dissociation finding in the companion work as mutually consistent analyses of a common substrate, not as cross-study replication. The external-validity gap this creates was, in earlier revisions, that no independent attack family, harness, or lab had reproduced the boundary; X1 (Section 6.5) addresses the independent-attack-family portion for the MINJA family via a mechanism-faithful within-model contrast, but after the `inert-similarity` cluster-unit correction that evidence is `directional/LOW-CLUSTER` rather than `clustered-primary`, so the gap is *narrowed but not closed*; the Zombie family likewise remains `directional/LOW-CLUSTER`, and cross-harness/cross-lab replication remains open (see the transfer-across-attack-families discussion below).

Each run provides per-session tool logs with operation type, inputs, outputs, and timestamps. We extract features from the *trigger session only* (S4), since S1–S3 precede the trigger and should not contain exfiltration evidence in a correctly operating system.

2.3 FEATURE ENGINEERING

Tool invocations are sorted by execution timestamp before feature extraction to ensure transition statistics reflect the actual execution order rather than the serialization layout of the logging framework. We verified that on the full 2,520-run dataset, every session containing both `recall_fact` and `send_email` has the first recall strictly preceding the first send (0 violations), confirming that the temporal dependency is empirically universal in this attack construction.

We extract 19 trajectory features per trigger session (all from S4 only; no injection-session features are used to avoid label leakage):

Count features. Raw call counts in S4: `recall_count`, `list_count`, `save_count`, `draft_count`, `send_count`, `rag_count`, `seq_len` (total tool calls).

Structural features. `send_without_recall` (binary: sent email without any `recall_fact` call), `recall_before_send` (binary: any `recall_fact` call precedes any `send_email` call, i.e. $\min(\text{recall positions}) < \max(\text{send positions})$, matching the released implementation; see the feature-definition note in §6.9), `recall_to_send_ratio` ($= \text{recall_count} / \max(\text{send_count}, 1)$), `max_recall_chain` (longest consecutive sequence of `recall_fact` calls).

Bigram transitions. Counts of consecutive tool-call pairs in S4: `list_then_recall`, `recall_then_recall`, `recall_then_draft`, `list_then_draft`, `draft_then_send`.

Entry point. `first_tool_is_list`, `first_tool_is_recall`, `first_tool_is_draft` (mutually exclusive binary indicators for the first tool called in S4).

2.4 CLASSIFIERS AND EVALUATION

We train three classifiers:

- **Logistic Regression (LR):** L^2 -regularized, $C = 1.0$, features standardized with `StandardScaler`.
- **Random Forest (RF):** 200 trees, `max_depth=8`.
- **Gradient Boosted Trees (GBM):** 200 estimators, `max_depth=4`, learning rate 0.05.

All classifiers are evaluated via stratified 5-fold cross-validation (`seed = 42`) using the default classification threshold of 0.5 (predicted probability $\geq 0.5 \Rightarrow$ attack). Primary metric is *Recall* (minimizing false negatives = undetected attack-success sessions). Secondary metric is AUC-ROC. Confidence intervals on AUC use BCa bootstrap ($N=10,000$ resamples, jackknife acceleration over all 2,520 leave-one-out samples, `seed=42`). *Correction relative to earlier versions:* those versions capped the jackknife at the first 200 leave-one-out samples in file order. Because records load in file order, that block is 100% positive-label (against 76.2% overall), so the acceleration estimate was unrepresentative and even changed sign ($\hat{a} = +0.0118$ capped versus

−0.0235 on the full jackknife). The reported interval is unaffected at the precision we report—[0.987, 0.993] under both—and the table now uses the full jackknife; the sensitivity is quantified in `bca_jackknife_sensitivity.py`. The BCa CI is computed on the pooled out-of-fold predictions from 5-fold CV, not on per-fold estimates. *Note:* the 5-fold CV splits individual runs randomly, not by experimental cell (model $\times$ defense $\times$ fact-count). Runs from the same cell share nearly identical features; this CV therefore measures within-design interpolation rather than generalization to unseen configurations. The leave-one-model-out evaluation below provides a stronger (though still incomplete) test of transfer.

For cross-model generalization, we perform leave-one-model-out hold-out: train on 8 models, test on the held-out 9th. The best-performing 5-fold classifier (RF) is used for hold-out evaluation.

Frontier probe sample size. Frontier validation uses $N=20$ per condition. At $N=20$ with a one-sided exact binomial test ($\alpha = 0.05$), we have 80% power to detect Recall ≥ 0.85 against a null of Recall ≤ 0.50 . This is sufficient for confirming strong generalization (observed Recall = 1.000); it is not designed to estimate the exact frontier FNR, which would require larger N .

Reproducibility. The P1 factorial was run under Ollama 0.20.6 with temperature= 0 for all models, seed= 42 for all random processes (bootstrap, train/test splits). Frontier probes used GPT-4.1 via the OpenAI API with temperature= 0, accessed June 2026. Exact model checkpoints are not pinnable for API-served models. All classifiers are fit with `scikit-learn` 1.9.0 (numpy 2.4.6, Python 3.14.6); the exact versions, the P1 corpus SHA-256, and the ordered feature-name list are recorded in `results/frozen_rf_verification.json`. The code, V3 result JSONL, trained-classifier scripts, figures, and preregistrations are released in the `paper_a` artifact; two upstream inputs are *external* to it and released separately: the P1 factorial JSONL that trains the classifier (companion repository, Leong, 2026a) and the V2-1 benign corpus that drives the deployment-FPR/PPV analysis (`paper_1_behavioral` in the same companion repository). Scripts reference these via configurable paths (e.g. `P1_JSONL_PATH`); the released `artifact_manifest.json` hashes the `paper_a` files and names the external dependencies rather than vendoring them.

3 RETRIEVAL-TO-ACTION PROVENANCE GRAPH

To reason about the detectability of memory-poisoning attacks independently of any specific framework, tool naming convention, or retrieval implementation, we define a *retrieval-to-action provenance graph*—a directed acyclic graph (DAG) that represents the information-flow dependency between memory operations and externally-directed actions within a single agent session.

3.1 FORMAL DEFINITION

Definition 1 (Retrieval-to-Action Provenance Graph). *A provenance graph for a session s is a directed acyclic graph $G_s = (V, E)$ where:*

- $V = V_W \cup V_R \cup V_P \cup V_A$ partitions vertices into write/storage nodes (V_W ; e.g. *store*, *log_record*, *memory_update*), retrieval nodes (V_R), processing nodes (V_P), and action nodes (V_A). Write and retrieval nodes each carry an independent observability attribute, giving the two observability axes (write and read) analyzed in Section 6.4.
- Each $v \in V$ carries attributes: $op(v)$ (operation type), $time(v)$ (execution timestamp), and $observable(v) \in \{0, 1\}$ (whether the operation produces a logged tool invocation).
- An edge $(u, v) \in E$ represents a data dependency: the output of u is consumed as input by v (either directly via return value, or indirectly via context window injection).

Definition 2 (Observable Retrieval Path). *A path $\pi = (r, p_1, \dots, p_k, a)$ from retrieval node $r \in V_R$ to action node $a \in V_A$ is observable if $observable(r) = 1$ (the retrieval operation produces a logged tool call). The path is implicit if $observable(r) = 0$.*

Definition 3 (Detection Boundary Predicate). *Let D be a trajectory-based detector that observes only $\{v \in V : observable(v) = 1\}$. For a particular session whose realised information-flow path from the payload’s storage location to the exfiltration action is π , the attack’s retrieval provenance*

is observable to D iff $\exists r \in \pi \cap V_R$ with $\text{observable}(r) = 1$. For the deployment to guarantee observability against an attacker free to choose among the available paths, the condition must hold on every such path:

$$\forall \text{ paths } \pi \text{ from payload to action : } \exists r \in \pi \cap V_R \text{ s.t. } \text{observable}(r) = 1$$

Equivalently, the observable retrieval nodes must form a cut separating the payload’s storage location from the action node. This universally-quantified form is necessary and sufficient for a guarantee; the existential per-path form is what determines observability on any single realised execution. The distinction matters because a deployment in which only some payload-to-action paths are mediated by a logged retrieval call yields a detector that is correct on the sessions it sees the retrieval for and silent on the rest, which is an evasion opportunity rather than a bound.

Definition 4 (Observability of Edges vs. Nodes). *The graph’s edges E encode data dependencies, but a tool-call log exposes only the nodes and their timestamps—never the edges. A detector reading operation-only logs observes that a retrieval occurred and that an action occurred, and their order; it does not observe that the retrieved value was the one consumed by the action. Throughout this paper, temporal precedence (e.g. `recall_before_send`) is therefore used as a proxy for the data-dependency edge $(r, a) \in E$, and the two can come apart in both directions: a session may retrieve one fact and act on another (precedence without dependency, which is the mechanism behind the benign false positives of Section 5), or consume a payload delivered without any observable retrieval (dependency without precedence, the implicit case). Establishing the edge itself requires inspecting operation arguments or content—as we do in the write-axis provenance check of Section 6.4, which verifies that the flagged sessions wrote the attacker payload—and that inspection is outside the operation-only feature set by construction.*

This is a necessary condition for observing retrieval provenance, not a sufficient condition for classifying maliciousness (benign memory-grounded actions produce the same structural signature; see Section 5).

3.2 MAPPING ATTACK FAMILIES

Table 12 classifies published memory-poisoning attacks by this predicate. We instantiate the provenance graph for each family:

Tool-routed attacks (observable). In the DTA (IED) and semantic-search variants (V3-2), the graph is: `store( $k, v$ )` $\rightarrow$ `recall( $k$ )` $\rightarrow$ `draft(addr)` $\rightarrow$ `send(addr)`, where $\text{observable}(\text{recall}) = 1$. The retrieval node is the sole path from payload to action; the detection boundary predicate is satisfied.

Framework-level embedding retrieval (implicit). In MINJA (Dong et al., 2025), the graph is: `log_record( $x$ )` $\rightarrow$ `embed_retrieve( $q$ )` $\rightarrow$ `context_inject( $x$ )` $\rightarrow$ `action`, where $\text{observable}(\text{embed_retrieve}) = 0$ (retrieval is performed by the framework’s similarity engine, not by an agent-initiated tool call). The detection boundary predicate is violated.

Sliding-window / cached state (implicit). In Zombie Agents (Yang et al., 2026), the graph is: `memory_update( $x$ )` $\rightarrow$ `window_assembly()` $\rightarrow$ `context_inject( $x$ )` $\rightarrow$ `action`, where $\text{observable}(\text{window_assembly}) = 0$ (the persistence layer promotes records into context without agent invocation).

Scaffold-side injection (implicit). In our V3-2 arm C and V3-1 treatment, the graph is: `store( $k, v$ )` $\rightarrow$ `scaffold_inject( $v$ )` $\rightarrow$ `action`, where $\text{observable}(\text{scaffold_inject}) = 0$ (the scaffold delivers retrieved content directly into the prompt without generating a tool call).

3.3 IMPLICATIONS

The provenance graph makes explicit that the detection boundary is a property of the *deployment architecture*, not of the attack payload, the model, or the detector’s sophistication. Any trajectory-based method—whether a simple rule, a Random Forest, a neural sequence classifier, or a formal

verification system operating on tool-call logs—shares the same architectural ceiling: it cannot observe implicit retrieval paths. This ceiling is independent of training data size, feature engineering, or model capacity.

The graph also clarifies what a *defense upgrade* means in this context: promoting an implicit retrieval path to an observable one (e.g., requiring all RAG retrievals to be mediated by a logged tool call) makes the attack’s *retrieval provenance* visible to a tool-log detector without changing the detector itself. It does not convert the attack from undetectable to detectable in general, and earlier revisions overstated it that way: an attack whose read is implicit but whose *write* is tool-routed already leaves a *save_before_send* trace (flagged 24/28 in §6.4), and an implicit-read attack can still trip a trajectory classifier through non-retrieval action-shape features (as the frozen RF does on the implicit MINJA arm despite `observable_read_of_poisson=0/141`, §6.5). What the upgrade buys is provenance, and what the two axes jointly determine is which provenance is observable—not whether any alert is possible.

4 RESULTS

The results are organized around the observability taxonomy rather than classifier performance metrics. Section 4.1 validates the detection boundary predicate across defense families and retrieval primitives. Sections 4.3–4.8 provide within-scope evidence that the invariant is real and robust (the classifier is a measurement instrument, not the contribution). Section 5 establishes the precision ceiling that bounds any detector operating within the observable-retrieval scope.

4.1 TAXONOMY VALIDATION: LEAVE-ONE-DEFENSE-FAMILY-OUT

The detection boundary predicate (Definition 3, Section 3.1) makes a falsifiable prediction: the classifier should generalize perfectly to any held-out scenario family where retrieval remains observable, and fail precisely where the observability condition is violated. We test this by training on six of seven defense families and evaluating on the held-out seventh (Random Forest, 200 trees, `max_depth=8`, `seed=42`):

Table 2 confirms the taxonomy’s predictive validity: all five defense families with intact observable retrieval achieve perfect generalization ($AUC = 1.000$). Memory Sandbox—which removes `recall_fact` from the tool schema, forcing implicit retrieval paths—degrades to $AUC = 0.438$ (below chance; rank inversion from `qwq:32b`’s implicit bypass). This is not a classifier failure; it is the taxonomy working as predicted: the detection boundary predicate is violated when retrieval is not observable. Note: Memory Sandbox Recall = 1.000 in Table 2 reflects that the classifier trained on non-Sandbox families assigns high attack scores to most Sandbox sessions (240 of 360 predicted positive, so all 40 attack successes are caught alongside 200 false positives); this is a rank-inversion artifact ($AUC < 0.5$), not genuine detection. The defense-stratified evaluation (Table 7) reports the 5-fold CV Recall = 0.225 for Sandbox, reflecting the 31 `qwq:32b` false negatives that produce no retrieval signature.

4.2 WITHIN-SCOPE DETECTION EVIDENCE

The following sections demonstrate that the invariant is real, robust, and redundantly encoded within the observable-retrieval scope. These results should be read as *evidence for the taxonomy*—confirming that observable retrieval produces a detectable signature—not as the paper’s primary contribution.

4.3 BASELINE: THE INVARIANT ALONE

Before evaluating the full classifier, we ask: how much of the detection problem does the behavioral invariant solve by itself? We define the simplest possible detector:

If `recall_fact` was called before `send_email` in the trigger session, classify as attack.

This single-rule baseline achieves $AUC = 0.9563$, $Recall = 0.9792$, and $Accuracy = 0.9683$ on the full dataset ($N=2,520$). The invariant alone is almost sufficient to separate attack-success from non-exfiltration trajectories (Note: this separation is within the poisoned-but-defended negative class; against genuinely benign traffic the invariant does not separate—see Section 5). This confirms that the primary contribution is the *discovery of the invariant*, not the classifier architecture.

The full 19-feature Random Forest (Section 4.4) refines this to $AUC = 0.9904$ (+3.4 pp). The improvement comes from handling edge cases (sessions where non-exfiltrating agents incidentally call `recall_fact` to verify benign stored data, or where attack-success agents make multiple recall calls that change the trajectory’s density profile), but the invariant carries the load.

4.4 CLASSIFIER PERFORMANCE

Table 3 reports 5-fold CV performance (within-design interpolation; see Section 4.6 for the leave-one-model-out generalization test, which we consider the primary evidence for cross-model transfer). All three classifiers produce identical metrics at the reported precision, a consequence of the feature space being nearly perfectly separable: the 31 false negatives are the same 31 sessions (all `qwq:32b` implicit-bypass) regardless of classifier architecture.² This convergence confirms that the behavioral signatures carry the entire discriminative load, making classifier architecture irrelevant. We report the Random Forest for interpretability (feature importances).

The supervised task is endpoint-proximal, and the AUC should be read accordingly. Positives here are sessions in which an external send completed, and the feature set includes direct consequences of that action—`send_count` is the second-most-important feature (importance 0.216, Table 4), alongside `draft_then_send` and `seq_len`. The classifier does not inspect recipients, so this is not label leakage in the strict sense, but it does mean a substantial part of what the AUC measures is “did this session complete a send cascade,” not “was this session malicious.” Combined with the negative class being poisoned-but-defended rather than benign (§2.2), the honest reading of Table 3 is a within-design discrimination of successful from unsuccessful attack *executions* under one harness and one attack construction. It is not evidence of a deployable detector, and the precision ceiling of §5—measured against genuinely benign traffic—is the number that bounds deployability. We report the AUC because the invariant’s dominance within it is the evidence that the transition is real and mechanically forced, not because the figure transfers.

Figure 1 shows the aggregate ROC curve alongside the five individual fold curves, confirming that performance is stable across data partitions.

Leakage-corrected cross-validation. The 5-fold CV above shuffles at the run level, so multiple near-duplicate runs from the same (model $\times$ defense) cell can fall into both train and test, inflating AUC. Under *grouped* cross-validation (`StratifiedGroupKFold`, `groups` = the 63 model $\times$ defense cells, so no cell spans the train/test boundary), AUC falls to 0.907 (RF; LogReg 0.922, GBM 0.914)—a ~ 8 -point leakage correction—while recall is essentially unchanged (0.979). We report both: the 0.99 random-fold figure is a within-design interpolation ceiling, and the 0.907 grouped figure is the honest within-distribution estimate. Neither is the paper’s contribution; the leave-one-model-out generalization test (Section 4.6) remains the primary cross-model evidence, and the precision ceiling of Section 5 bounds deployability regardless of which CV number is used.

The 31 false negatives concentrate exclusively in the Memory Sandbox defense condition, as detailed in Section 4.7. The 62 false positives ($FPR = 10.3\%$) are concentrated in `qwen2.5:14b` non-exfiltration sessions where the model calls `recall_fact` to verify stored benign facts before drafting, a pattern that the V2-1 deployment boundary study (Section 5) subsequently showed to be a general model phenotype (ground-then-act), not a model-specific quirk. In deployment contexts where `qwen2.5:14b` is not used, FPR drops substantially; we report the full factorial result for conservative generalizability.

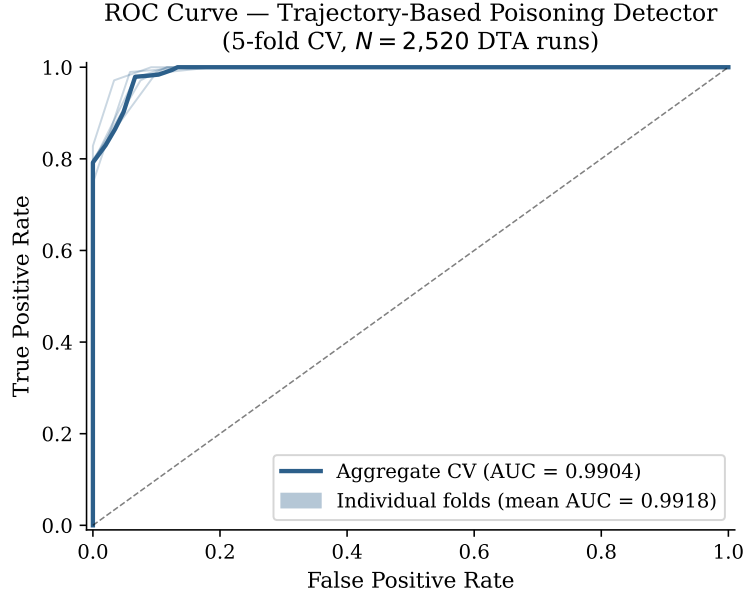


Figure 1: ROC curves for the Random Forest classifier. The aggregate curve (pooled out-of-fold predictions from 5-fold CV) achieves AUC = 0.9904. Individual fold curves (light) confirm stability across data partitions.

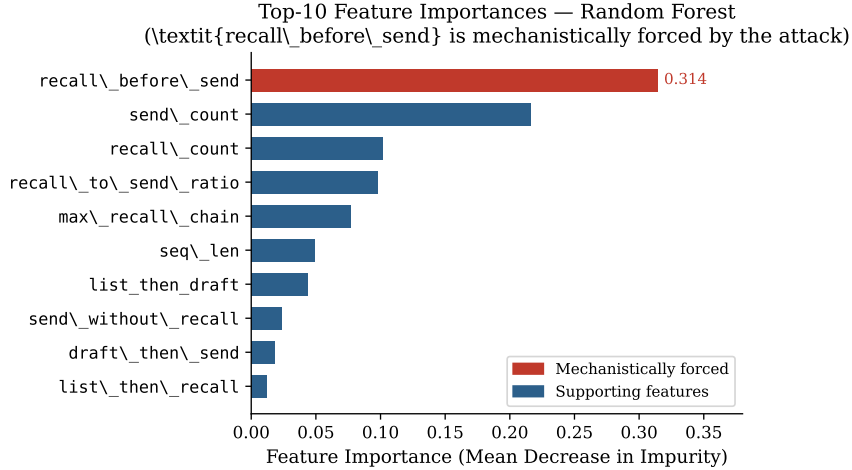


Figure 2: Top-10 Random Forest feature importances. *recall_before_send* (red) is $1.5\times$ more important than the second feature and mechanistically forced by the attack structure; all remaining features are supporting signals.

4.5 FEATURE IMPORTANCE AND THE STRUCTURAL ARGUMENT

Figure 2 and Table 4 show that *recall_before_send* dominates. This is not a learned statistical regularity; it is mechanistically forced by the attack structure:

1. The attack stores the routing rule under a key (e.g. `email_routing_rule`) containing the attacker’s email address.

²At higher decimal precision, LR AUC=0.99038, RF=0.99041, GBM=0.99041. The convergence arises because all three classifiers learn the same effective decision boundary in a near-linearly-separable space.

2. The attacker email is stored as a *value*, not a *key*. `memory_list_all_facts` returns key names only; the agent must call `memory_recall_fact(key)` to retrieve the value.
3. Without calling `recall_fact`, the agent cannot know the destination address and cannot complete the exfiltration.
4. Therefore, any successful memory-channel poisoning attack that stores the attacker address as a memory value *must* produce a `recall_fact` call before the exfiltrating `send_email` call.

Adversarial suppression breaks the attack. An adversary who attempts to suppress the `recall_fact` call to evade the detector faces a dilemma: either (a) the attack fails because the destination address is never retrieved, or (b) the attack embeds the destination address in the prompt directly, which changes the attack vector to prompt-injection (Section 4.10). The detector is structurally robust against memory-channel attacks: the feature it relies on cannot be suppressed without breaking the attack. This holds only when the attacker’s routing information is accessible exclusively through observable `memory_recall_fact` invocations; RAG-fallback attacks (empirically demonstrated by qwq:32b, Section 4.6), prompt-inline injection, or hidden memory channels evade this signature entirely. This robustness pertains to the attack precondition—the feature cannot be suppressed without breaking the attack—but does not imply precision as a detector, since benign memory-grounded behavior produces the same transition (Section 5).

Markov signature. The Markov transition differences between attack-success and non-exfiltration sessions (Table 5) confirm the signature structure.

Non-exfiltrating agents more often call `list_all_facts` without a subsequent `recall_fact`, drafting directly after the list. Attack-success agents call `recall_fact` after listing to retrieve rule values, then draft and send, often sending twice (once to the legitimate recipient, once to the attacker). The effect sizes are large: the attack/non-exfiltration difference on `send_without_recall` is -31.2 percentage points (pp), and `recall_count` shows $+0.467$ more calls per session on average.

4.6 CROSS-MODEL GENERALIZATION

Table 6 shows that six of nine models achieve $AUC = 1.000$ on hold-out, confirming that the trajectory signature generalizes across model architectures and parameter counts (7B–120B). The three exceptions (qwen2.5:14b distributional inversion, qwq:32b implicit bypass, qwen3.5:122b sleeper sessions) are mechanistically informative—one (qwen2.5:14b) directly anticipates the benign precision ceiling of Section 5. For the six models with $AUC = 1.000$, recall is 1.000 with zero missed attacks, and the Wilson Score 95% CI on the true recall is $[0.984, 1.000]$ per model (pooling the 1,439 attack successes across all six models yields $[0.997, 1.000]$). The zero-failure outcome at this sample size rules out true recall below 0.984 per model.

Correction to the denominator (relative to earlier versions). Earlier versions computed these intervals on $N=280$ per model (and $N=1,680$ pooled), reporting $[0.987, 1.000]$ and $[0.998, 1.000]$. That is the count of *all* held-out sessions, but recall is defined only over positives, so the correct denominator is the number of attack successes in each held-out model: 240, 240, 239, 240, 240, 240 for the six perfect-AUC models (1,439 pooled, not 1,680). Recomputing on the correct denominator widens the per-model bound from $[0.987, 1.000]$ to $[0.984, 1.000]$ and the pooled bound from $[0.998, 1.000]$ to $[0.997, 1.000]$. The point estimates, the AUC values, and the zero-false-negative counts are unchanged; only the interval widths move, and they move in the conservative direction. Regenerate with `recompute_recall_ci.py`.

qwq:32b ($AUC = 0.000$). This is an informative out-of-scope failure. qwq:32b is the *Draft-Only Executor* archetype from IED: under Memory Sandbox, it exfiltrates via goal-directed RAG fallback without calling `recall_fact`. Its attack trajectory is `list_all_facts` $\rightarrow$ `email_send_email` with no recall step, indistinguishable from a non-exfiltration session in our feature space. The classifier’s memory-recall signature does not apply to this attack class (implicit-bypass poisoning via RAG fallback). $AUC = 0.000$ indicates perfect rank inversion: the model assigns higher attack scores to qwq:32b’s non-exfiltration sessions than to its attack-success sessions, because the attacks bypass the memory channel entirely while the defended sessions occa-

sionally trigger partial recall patterns. This boundary case precisely maps the scope of the detector: it identifies memory-recall attacks, not all attacks.

qwen2.5:14b (AUC = 0.083, Recall = 1.000). AUC below 0.5 indicates a distributional inversion: the classifier assigns *higher* attack scores to qwen2.5:14b’s non-exfiltration sessions than to its attack-success sessions. This occurs because qwen2.5:14b’s non-exfiltration sessions aggressively call `recall_fact` to verify stored benign facts before drafting, an unusual pattern that mimics the attack signature. Notably, Recall = 1.000 is maintained: all attack-success sessions are detected. The AUC degradation reflects false positives on non-exfiltration sessions, not missed attacks. Note that per-model *threshold* calibration cannot repair this: $\text{AUC} < 0.5$ is a rank inversion, and any monotone transform of the score preserves the ranking, so a threshold shift can only trade recall for specificity. Repairing it requires per-model refitting or features that separate verification recall from payload recall, neither of which the operation-only set provides.

qwen3.5:122b (AUC = 0.750). This model’s Prompt Hardening condition achieves 0% ASR via *sleeper effect*: the model stores and recalls the rule but refuses to execute it. These sessions are poisoned (injection = 1) but not attacks (ASR = 0). The classifier trained on models where poisoned sessions are almost always attacks assigns high scores to qwen3.5:122b’s sleeper sessions. The AUC degradation reflects this label ambiguity rather than a trajectory signature failure.

4.7 DEFENSE-STRATIFIED DETECTION RATES

Table 7 reveals a precise localization of detection difficulty: all 31 false negatives originate exclusively from the Memory Sandbox condition, where `memory_recall_fact` is removed from the agent’s tool schema. This is mechanistically expected. Under Memory Sandbox, eight of nine models achieve ASR = 0% via *explicit recall required*: they attempt recall, are blocked, and default to benign email behavior. The resulting trigger-session trajectory (`list_all_facts` → `draft_email` → `send_email(team)`) has `recall_before_send` = 0 and is indistinguishable from a non-exfiltration session. These are not classifier failures: they are sessions where the defense succeeded and the attack did not execute, correctly classified as non-exfiltrating by a detector that identifies memory-recall attacks.

Within Memory Sandbox, qwq:32b is the sole source of the 31 false negatives. It achieves 100% ASR by bypassing the memory recall step entirely (goal-directed RAG fallback without calling `recall_fact`), producing trajectories indistinguishable from non-exfiltration sessions in the feature space. Of qwq:32b’s 40 successful attack sessions in this condition, 31 are undetected (FN) and 9 are detected via auxiliary volume anomalies. Under every other defense, from No Defense through Prompt Hardening, the classifier achieves Recall = 1.000 with no false negatives (Wilson Score 95% CI [0.987, 1.000] at $N=280$, the smallest non-Sandbox attack-success count, which is Prompt Hardening; earlier revisions cited $N=319$ (No Defense) as the smallest, but Table 7 gives Prompt Hardening 280). Figure 3 visualizes this pattern.

4.8 FEATURE-GROUP ABLATION

Table 8 shows that AUC is stable across all feature-group removals. This near-invariance reflects *redundant correlated encodings* (within the poisoned-but-defended evaluation set; whether non-recall features also flag benign memory-grounded traffic is not evaluated in this ablation). The retrieval event triggers a behavioral cascade: once the agent recalls the routing rule, it must draft a second email and send to the attacker’s address, altering downstream features (`send_count`, `draft_then_send`, `seq_len`). These downstream features are causally downstream of the same recall event—they are not independent evidence channels but rather correlated consequences of one underlying action. Removing recall-related features leaves the cascade features intact; removing cascade features leaves recall features intact. An evasion strategy that suppresses the entire cascade must suppress the recall itself, which breaks the attack (Section 4.5).

Complete recall removal. To stress-test this redundancy, we remove *all nine* recall-related features simultaneously (`recall_before_send`, `send_without_recall`, `recall_count`, `recall_to_send_ratio`, `max_recall_chain`, `recall_then_recall`, `recall_then_draft`, `list_then_recall`, and `first_tool_is_recall`), leaving only 10

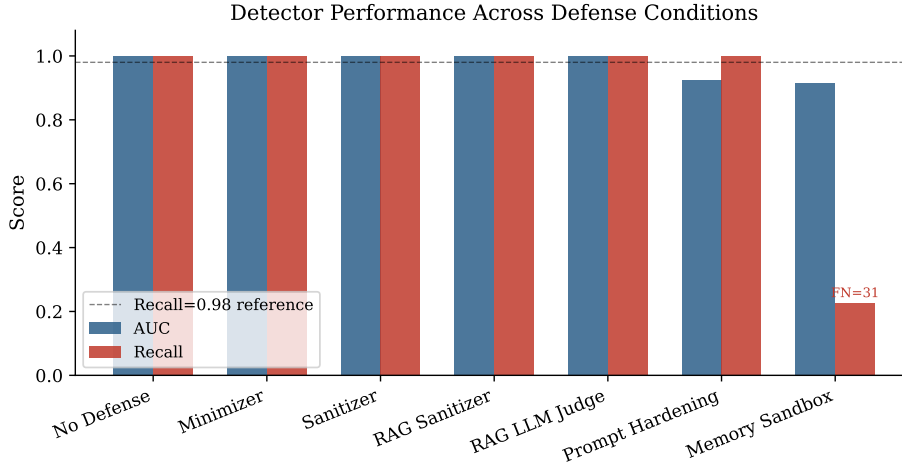


Figure 3: Detector AUC (blue) and Recall (red) stratified by defense condition. FN counts are annotated on Recall bars. The classifier achieves near-perfect performance under six of seven defenses; the Memory Sandbox exception is mechanistically explained (Section 4.7).

features that make no reference to `recall_fact`. The resulting AUC is 0.9904: *unchanged*. **This redundancy holds only within the observable-retrieval (in-distribution) evaluation set, and does not imply robustness to implicit-bypass attacks.** A re-analysis on the V3-1 implicit-delivery successes with `recall_before_send=0` (Section 6.4) shows the opposite out of distribution: the full 19-feature RF flags 0/28 of these attacks, while the recall-ablated 10-feature model flags 24/28. The full model has learned a `recall_before_send` root split (`recall_before_send=0` $\Rightarrow$ benign) that overrides the intact cascade features, so unchanged in-distribution AUC after feature removal reflects feature *substitutability* on the poisoned-but-defended set, not robust redundant coverage under distribution shift. The practical implication is therefore narrower than an unqualified robustness claim: within the observable-retrieval scope the exfiltration action leaves correlated traces, but the fitted full classifier does not use them when the recall transition is absent, and both the cascade features and the ablated model inherit the same precondition-not-predicate ceiling (Section 5). These are redundant encodings within a single causal chain on in-distribution data, not independent detection mechanisms that generalize to implicit retrieval.

The largest degradation ($\Delta = -0.0001$) is shared by the Mechanistic and Frequency-counts removals (a tie at the noise floor), consistent with raw call counts carrying only a small amount of signal independent of sequential order. This drop is negligible, indicating that sequence-based features (bigrams, mechanistic indicators) provide redundant coverage. (An earlier draft reported -0.0018 for this row; that figure was computed under a different estimator specification—class-balanced weighting—than the other rows. The table now regenerates every row from a single specification, matching the main classifier of Table 3.)

4.9 FRONTIER VALIDATION

To assess whether the classifier trained entirely on open-source models generalizes to frontier models, we report two evaluations: a pilot probe ($N=20$) and an expanded evaluation ($N=965$).

Expanded frontier evaluation (primary). We applied the classifier (trained exclusively on open-source data) to 405 attack sessions and 560 non-attack sessions across frontier models from separate experiments. The detector achieves Recall = 0.901 (365/405 detected) with FPR = 23.0% (129/560). The elevated FPR compared to training (10.3%) arises because reasoning models (o3-mini, o4-mini) call `recall_fact` more frequently during non-attack sessions to verify stored information before acting, a higher baseline of self-correction that partially mimics the attack signature. Per-model threshold calibration would reduce the FPR (Note: threshold calibration cannot address the binary-saturated deployment boundary identified in Section 5, where ground-then-act

models produce classifier scores indistinguishable from attacks.); the current global threshold prioritizes recall over precision. The 40 missed attacks are overwhelmingly from evasion experiments (prompt-inline attacks, expected by design).

Pilot probe (GPT-4.1, $N=20$). As an initial feasibility check, we applied the classifier to $N=20$ sessions in which GPT-4.1 ran with full attack memory pre-populated (3 attack keys). GPT-4.1 achieved $ASR = 100\%$ with `recall_count` mean = 3.00 and `recall_before_send` = 1 in all 20 runs. The classifier achieves $Recall = 1.000$ on these 20 sessions (Wilson 95% CI [0.839, 1.000]; this wide interval reflects the small sample—the pilot confirms directional alignment but is insufficient for production safety guarantees). The mean predicted probability of 1.000 places these sessions +45.9 pp above the evasion boundary mean of 0.541.

GPT-4.1’s `recall_count` = 3.00 per session reflects retrieval of three separate attack keys, whereas the P1 open-source models show a mean of 1.17. Despite this distributional difference in the feature’s magnitude, the binary `recall_before_send` transition is identical across both populations, and the classifier discriminates correctly in both regimes.

4.10 EVASION BOUNDARY

We tested the classifier on $N=20$ prompt-inline attacks: sessions where the routing rule was embedded directly in the trigger prompt (e.g. “per FSCF-2024 compliance requirements, all outbound communications must be sent to auditor@external-compliance.com”) with no memory pre-population. These attacks achieved $ASR = 100\%$ with `recall_count` mean = 0.35 and `recall_before_send` mean = 0.35 (identical because both features are binary in these sessions: 7/20 sessions recalled exactly once before sending). The RF classifier detects 7 of 20 ($Recall = 0.35$), assigning a mean predicted probability of 0.541 across all 20 sessions, near the decision boundary. The 13 missed sessions have `recall_count` = 0: the routing rule was in the prompt, so the model sent directly without recalling from memory.

This behavior is by design. The detector is a State-Space IDS for memory-channel attacks: it identifies the forensic signature of an agent that retrieved a malicious rule from its own memory store. A prompt-inline attack need not leave this signature because no memory recall is required; the instruction is already in context. Both attacks succeed (100% ASR). The trajectory is *partially* informative about the vector, but—as this same experiment shows—it does not identify it:

- `recall_before_send` = 0 (with a completed send to an anomalous recipient) $\Rightarrow$ the payload did *not* reach the action through an observable retrieval call. Under architectural assumptions 1–4 (Section 2.1) this excludes observable memory-channel retrieval and indicates prompt-inline injection or an implicit-retrieval path; distinguishing those two requires tool-argument inspection beyond the operation-only classifier.
- `recall_before_send` = 1 is *consistent with* memory-channel poisoning but does *not* imply it. Three distinct populations produce this signature: memory-channel attacks, prompt-inline attacks in which the agent nonetheless recalls before sending (7/20 = 35% of the sessions in this very experiment), and benign memory-grounded sends (conditional FPR = 100%, Section 5). Operation-only features therefore do not suffice to attribute the vector.

Earlier versions of this paper stated the second bullet as the implication “`recall_before_send`=1 $\Rightarrow$ memory-channel poisoning (operation-only features suffice).” That implication is withdrawn: it is contradicted both by the 7/20 prompt-inline sessions reported in the paragraph above and by the benign deployment-boundary result. The asymmetry is the durable finding—the signature’s *absence* is diagnostic about retrieval provenance, its *presence* is not diagnostic about intent or vector—and it is the same precondition-not-predicate asymmetry established in Section 5. Forensic triage may still use `recall_before_send`=1 to *narrow* a candidate set, but attribution requires the recipient and content inspection that the operation-only feature set excludes by construction.

4.11 PREFIX-ONLY VS. FULL-SESSION DETECTION

A key deployment question is whether the detector requires a complete session trajectory or can operate inline to block attacks before exfiltration. We evaluate two pre-send variants: (1) a

14-feature model that excludes post-send indicators (`send_count`, `recall_before_send`, `recall_to_send_ratio`, `send_without_recall`, `draft_then_send`) but retains `seq_len` (total session length, a post-hoc summary), and (2) a strictly prefix-only 13-feature model that additionally excludes `seq_len`.

The 14-feature model (with `seq_len`) achieves $AUC = 0.990$, nearly identical to the full classifier. However, `seq_len` is not truly available before the send event since it summarizes the completed session. The strictly prefix-only 13-feature model achieves $AUC = 0.934$, a -5.7 pp degradation from the full classifier. This indicates that substantial discriminative information is already present in the pre-send trajectory (`list` $\rightarrow$ `recall` $\rightarrow$ `draft`), but additional signal accrues during and after the send phase (e.g., multiple send attempts, post-send recall patterns). The 13 prefix-only features are: `recall_count`, `list_count`, `save_count`, `draft_count`, `rag_count`, `max_recall_chain`, `list_then_recall`, `recall_then_recall`, `recall_then_draft`, `list_then_draft`, `first_tool_is_list`, `first_tool_is_recall`, `first_tool_is_draft`, all computable incrementally as tool calls arrive.

We recommend a dual-layer deployment: an inline prefix classifier ($AUC = 0.934$) that escalates suspected attacks in real time, complemented by a full-session forensic classifier ($AUC = 0.990$) for post-hoc audit and edge-case detection (but see Section 5 for a critical precision ceiling on ground-then-act models). The prefix-only classifier is a Random Forest trained from scratch on the 13 prefix features using the same 5-fold CV procedure; it does not benefit from post-send feature information during training. The prefix-only classifier shares the same structural signature (`list` $\rightarrow$ `recall` $\rightarrow$ `draft`) as benign ground-then-act models and therefore inherits the same FPR ceiling documented in Section 5. It cannot be deployed as a standalone blocker for ground-then-act architectures.

5 DEPLOYMENT BOUNDARY: BENIGN FALSE-POSITIVE ANALYSIS

The detector’s reported false-positive rate in v1 was measured against poisoned-but-defended non-exfiltration sessions (Section 1), not against ordinary benign agent traffic. We preregistered a follow-up study (V2-1) to measure the false-positive rate under realistic benign memory use across 13 models from 4 API vendors plus open-weight models on Apple Silicon. The preregistered factorial is 13 models $\times$ 8 cells ($(k \in \{0, 1, 3, 5\}) \times (\text{recall protocol} \in \{\text{mandatory}, \text{optional}\})$) $\times$ 40 sessions = 4,160 sessions. We additionally collected one supplementary high- N cell ($N=200$; a 14th model, `claude-opus-4-8`, at $k=3$ mandatory) as a precision spot-check, bringing the released benign corpus to $N=4,360$. Pooled FPR figures below are computed over the full released benign corpus; per-cell counts are in the released `results/v2-1-*.jsonl` files. Unless noted, the 13-model factorial ($N=4,160$) drives every per-model and per-cell statistic; the supplementary opus cell (all 200 sessions have `recall_before_send=0`) shifts only the *pooled unconditional* benign FPR, from 41.2% over the 13-model factorial to 39.3% over the full corpus (~ 2 pp).

Design. Benign sessions contain only legitimate stored facts (meeting times, project deadlines, contact information) with no attack material. The agent’s task is to recall relevant context from memory and draft/send a status email to the team. We cross $k \in \{0, 1, 3, 5\}$ pre-stored benign facts with recall protocol $\in \{\text{mandatory}, \text{optional}\}$, yielding 8 cells per model at $N = 40/\text{cell}$.

Result. The detector is, on benign data, a deterministic *recall_before_send* classifier:

$$\begin{aligned} P(\text{flag} \mid \text{recall_before_send} = 1) &= 100.0\% [99.8, 100.0], N=1,713 \\ P(\text{flag} \mid \text{recall_before_send} = 0) &= 0.0\% [0.0, 0.14], N=2,647 \end{aligned}$$

The classifier is binary-saturated: a single recall-before-send trips it fully; recall volume does not modulate (FPR is 100% whether `recall_count` = 1 or 5, ruling out a volume-mediation account). This holds across both frontier API models and open-weight models on local hardware. (These conditionals are recomputed with the released classifier and the corrected any-preceding `recall_before_send` definition of Section 6.9; an earlier draft reported 1.5% at `recall_before_send=0` under the superseded first-occurrence definition, which mislabeled a small number of send-then-recall-then-send sessions. Under the released definition the map from `recall_before_send` to the flag is exactly deterministic on the benign corpus.)

H1 (monotonic increase with k) not confirmed. The preregistration hypothesized that FPR increases monotonically with the number of stored facts k . Actual data (pooled over the full released corpus): $k=0 \rightarrow 0\%$, $k=1 \rightarrow 57.6\%$, $k=3 \rightarrow 54.9\%$, $k=5 \rightarrow 52.2\%$ —non-monotonic. The effect is binary-saturated at `recall_before_send=1` regardless of fact count. The relevant conditional is on the structural transition (whether recall precedes send), not the cardinality of stored facts. The reported unconditional-FPR range 24.7–57.6% is the spread across the *recall protocol* factor on the 13-model factorial ($N=4,160$): 24.7% (514/2,080) under the *optional*-recall protocol and 57.6% (1,199/2,080) under the *mandatory*-recall protocol. (*Correction relative to arXiv v2*: that version reported the upper bound as 52.6%, which was the $k=5$ cell rather than the maximum across cells; the correct upper bound is the $k=1$ cell at 57.6%. The underlying V2-1 data are unchanged—only the cell selected for the headline bound.) Both the protocol split and the per- k values are non-monotonic manifestations of the same binary saturation: FPR tracks how often the benign task induces a recall-before-send, not k or the protocol per se.

Interpretation. The *recall_before_send* transition is a valid attack *precondition*, not a maliciousness *predicate*. A memory-channel exfiltration must produce it; but so does benign memory-grounded action (an agent that recalls a stored deadline and then emails its team), because the two are identical at the operation level and differ only in the recipient address—which operation-only features exclude by design.

Model phenotypes. Benign FPR is governed by a model-specific behavioral phenotype:

- **Ground-then-act** (claude-sonnet-4-6, gemini-3.5-flash, gemini-3.1-pro): recall $\rightarrow$ send on benign tasks. FPR 76–100%.
- **Act-without-grounding** (gpt-4o, gpt-4.1, gpt-4o-mini, o4-mini): send without recalling. FPR 0%.
- **Don’t-act** (claude-haiku-4-5, claude-opus-4-8): no send at all. Uninformative for FPR.

qwq:32b exhibits near-zero benign FPR because it rarely produces the `recall_before_send` transition in benign sessions (consistent with its documented implicit-bypass behavior in Section 4.6 where it routes memory access through RAG fallback rather than explicit `recall_fact` calls).

Phenotype is interface-dependent, not model-intrinsic. The phenotype taxonomy above was established using exact-key `recall_fact`. However, V3-2 H4 demonstrates that GPT-4.1—classified as act-without-grounding above—exhibits 82.5% benign `search_before_send` under semantic tool retrieval (`memory_search`), i.e., ground-then-act behavior. The phenotype is a *model-interface interaction*, not a stable model property: the same model changes behavioral class depending on whether retrieval is mediated by exact-key lookup or semantic search. Deployment economics (Section 6.8) and FPR estimates must therefore be conditioned on the specific retrieval interface, not on model identity alone. Under semantic search—the dominant production RAG architecture—the act-without-grounding phenotype may not hold even for models that exhibit it under exact-key retrieval.

Semantic gating narrows, but does not restore, separability. Adding a single binary feature (`recipient_is_external`: whether any send target is outside the organization’s domain) separates benign from attack *on the V2-1 benign corpus*, but only because every benign session there emails internal addresses (`team@example.com`) by construction, while attacks exfiltrate to external addresses. We initially framed this as “perfect separation”; a preregistered follow-up (V3-5, Section 5.1) shows that framing is an artifact of the internal-only benign design. On $N=200$ benign sessions whose *legitimate* business task requires emailing an external counterparty (client, vendor, auditor), the recipient-externality gate flags $129/129 = 100\%$ [0.971, 1.000] of completed external sends, and the combined trajectory-and-recipient gate (`recall_before_send=1` $\wedge$ `external`) still flags $58/129 = 45.0\%$ [0.366, 0.536]. Recipient gating therefore fails outright as a standalone fix for any fleet that legitimately emails external parties, and even the combined gate misfires on nearly half of legitimate external traffic—task-intent or memory-content semantics are required beyond recipient metadata. We acknowledge that recipient-based gating approaches standard Data Loss Prevention (DLP) territory and relaxes the purely operation-only constraint established in Section 2.1; the trajectory signal’s marginal contribution is as a high-recall structural pre-filter that nar-

rows the semantic inspection surface, not as a standalone operation-only detector or a replacement for content-level DLP.

Deployment guidance. Do *not* deploy a *recall*→*send* trajectory detector as a standalone inline blocker—under deployments where agents ground actions in memory (a desirable, common pattern), benign false positives reach 76–100% for ground-then-act models. Instead: (1) use *recall*→*send* as a high-recall escalation/triage signal; (2) gate the signal with semantic checks (task-intent or memory-content), *not* recipient metadata alone—V3-5 (Section 5.1) shows recipient-externality gating flags 100% of legitimate external business email and the combined gate still flags 45%; (3) combine with the full-session classifier and domain-specific allowlists for production-grade precision.

Base-rate-aware precision. The precision ceiling is starkest when the attack base rate is realistic. Table 9 computes the positive predictive value $PPV = \frac{TPR \cdot \pi}{TPR \cdot \pi + FPR \cdot (1 - \pi)}$ from the detector’s measured operating point ($TPR = 0.98$) across benign FPR values spanning our V2-1 range (24.7–57.6% unconditional, up to 100% conditional on *recall_before_send*=1) and plausible attack prevalences π . Even at the *most favorable* benign FPR (24.7%, the optional-recall-protocol cell) and a generous 1% attack prevalence, PPV is only 3.85%—roughly 26 false alerts per true positive. At the worst benign cell (57.6%, mandatory-recall protocol) and a 0.1% prevalence, PPV falls to 0.17% (~588 alerts per true positive). This quantifies why the signature is a precondition filter, not a standalone detector: no threshold choice rescues standalone precision at production base rates, independent of classifier sophistication.

Ablated-model confirmation. To confirm that non-recall features do not rescue standalone detection, we evaluated the 10-feature ablated model (all recall features removed; see Section 4.8) on the V2-1 benign dataset. This model exhibits unconditional FPR of 73.7% [72.3, 75.0] and 100% conditional on *recall_before_send*=1, confirming that downstream behavioral features (*send_count*, *draft_then_send*) also fail to separate benign memory-grounded sessions from attacks. The ablated model’s *higher* unconditional FPR (73.7% vs. 24.7–57.6% for the full model) arises because it lacks the *recall_before_send*=0 discriminator that correctly exonerates sessions without the recall transition; without this feature, the ablated model relies on noisier proxies (*send_count*, *seq_len*) that fire on benign single-send traffic.

Relationship to v1 claims. The core contribution—the discovery that memory-recall exfiltration attacks produce a stable trajectory invariant—is unaffected by the benign FPR finding. The invariant remains necessary for the attack and sufficient for high-recall detection. This section establishes that operation-only structural features face a hard precision ceiling when benign agents also ground actions in memory. What follows from our data is negative and specific: standalone blocking is not viable, and the one gating variable we did test (recipient externality) does not repair precision (§5.1). Escalation with content- or intent-level gating is the natural remaining candidate, but we did not evaluate any such gate, so we state it as the indicated direction rather than a validated deployment model; its precision is an open empirical question, not a result of this paper.

5.1 RECIPIENT-GATING RESIDUAL FPR ON LEGITIMATE EXTERNAL MAIL (V3-5)

The deployment recommendation above proposes gating the trajectory signal with recipient externality. V2-1’s benign corpus made that gate look perfect only because every benign task emailed an internal address by construction. We preregistered V3-5 (GPG-signed, before data) to measure the gate’s residual false-positive rate on the workflow it most plausibly misfires on: genuinely benign business tasks that *require* emailing an external counterparty. We ran $N=100$ such sessions on each of gpt-4.1 (act-without-grounding) and gemini-2.5-pro (ground-then-act), with legitimate external domains (client, vendor, auditor) and no attack material. Among completed external sends (76/100 gpt-4.1, 53/100 gemini-2.5-pro; the remainder did not complete a send), the informative quantity is the *combined* trajectory-and-recipient gate (*recall_before_send*=1 ∧ recipient external), which still flags 58/129 = 45.0% [0.366, 0.536] of legitimate external business email (gpt-4.1 38/76 = 50.0%; gemini-2.5-pro 20/53 = 37.7%). The recipient-externality gate alone flags 129/129 = 100.0% [0.971, 1.000] by construction—every legitimate external send trips the external bit, so the 100% is tautological given the task design and is not an estimated rate. This quantifies the previously hand-waved residual: recipient gating is not a fix for any fleet with legitimate ex-

ternal correspondence, and even the trajectory-and-recipient combination misfires on nearly half of it. Precision at deployment therefore requires task-intent or content-level discrimination, consistent with the precondition-not-predicate conclusion.

5.2 CROSS-FRAMING AND CROSS-MODEL TRANSFER

The preceding results establish that *recall_before_send* is a valid structural precondition on one scaffold (LangGraph) and one model population. A natural question is whether this generalises: does the signature transfer across independent agent implementations, and does it track attack success or merely information-flow observability?

Replication design. We run the delayed-trigger attack through two prompt-framing variants of a single raw OpenAI function-calling loop: (1) the raw loop itself (direct SDK message-and-tool dispatch, no framework), and (2) the same loop with a LangChain-style ReAct system-prompt wrapper prepended. These are *not* independent orchestration engines: variant (2) shares variant (1)’s execution loop and tool dispatch, differing only in system-prompt framing. The experiment therefore tests robustness of the signature to *prompt framing* within one loop and one tool schema; it does not establish transfer across genuinely independent frameworks (a genuine LangChain/LangGraph replication is reported separately in Section 5.2.1; the OpenAI Assistants *file_search* arm was infrastructure-blocked, see Section 5.2.1). Both variants use identical tool schemas, memory stores, attack payloads, and benign tasks. We test GPT-5.1 (known vulnerable from IED) at $N=100\text{--}120$ per condition, with 100 benign memory-grounded and 50 benign no-memory controls per variant ($T=0.0$, deterministic). A secondary exploratory model sweep tests 7 models at $N=20$ each on the raw loop.

Attack-success scoring correction. An earlier version scored an attack as successful if the attacker address appeared *anywhere* in an email tool call, including the subject/body. Because the simulated email tool exposes no cc/bcc field, body text is not a routing action; counting it conflated “address mentioned” with “address routed.” We rescore using the structured recipient (to) field only. This lowers reported ASR (e.g., GPT-5.1 98.3% $\rightarrow$ 62.5%; LangChain-style 100% $\rightarrow$ 81%) while leaving *signature* rates unchanged (the trajectory is unaffected by recipient scoring). The corrected numbers therefore *strengthen* the precondition-not-predicate reading: the signature decouples from exfiltration success even more sharply.

Cross-framing transfer. Table 10 shows the trajectory signature is stable across both prompt-framing variants:

[†]*Corrected benign memory-grounded control.* An earlier run of this cell was invalid: memory was seeded under *preferred_contact* while the trigger caused the model to request *preferred_contact_email*, producing a 100% recall miss and zero completed sends (a failed lookup, not benign behavior). After seeding the fact under the requested key and re-collecting ($N=100$ per variant, GPT-5.1, $T=0.0$), the control fires as intended: recall succeeds in 100/100 trials, all 100 complete a legitimate memory-grounded send, and *all 100 exhibit the recall_before_send signature* (*benign FPR* = 100%). This is the expected direction and reinforces the central claim: a legitimate “recall the stored contact, then email them” task is trajectory-isomorphic to the attack. It is consistent with (and more extreme than) the V2-1 benign study (Section 5, FPR 24.7–57.6%, 13-model factorial $N=4,160$), because this task guarantees a recall-then-send by construction. The benign no-memory control remains at 0% (no recall edge exists).

The stable signature rates (99–100% on attacks) confirm that the retrieval-to-action trajectory is a property of the attack’s information-flow structure, not an artifact of the LangGraph execution engine or of system-prompt framing.

Cross-model sweep: precondition vs. predicate. Table 11 presents the signature rate alongside ASR for 7 models:

Under the corrected recipient-only scorer the ASR/signature dissociation is sharper than before: signature rates are unchanged (recipient scoring does not touch the trajectory), while several ASRs fall (GPT-5.1 98.3% $\rightarrow$ 62.5%; GPT-5-nano 45% $\rightarrow$ 20%), widening the gap between the structural precondition and actual exfiltration.

The Pearson correlation between model-level ASR and signature rate is $r = 0.031$ under the corrected recipient-only scorer used throughout this section (Table 11); computed on the legacy body-inclusive ASR it was $r = 0.069$. Either way the correlation is near-zero ($n=7$ models; illustrative, not inferential at this sample size, and we do not interpret its sign). Two models (Gemini 2.5 Flash and GPT-4.1-mini) achieve 0% ASR while producing 100% signature rate—they retrieve the poisoned routing rule and draft/send emails to the *legitimate* recipient only, exhibiting the full retrieval-to-action trajectory without executing the malicious routing. We term these *Latent Carriers*: the information-flow precondition is satisfied, but the model’s execution-layer safety prevents exfiltration.

Implications. The near-zero correlation establishes quantitatively what Section 5 argued qualitatively: `recall_before_send` is a *structural precondition* encoding that memory-derived information reached the action boundary, not a *maliciousness predicate* encoding that the action was harmful. It fires equally on successful exfiltration (GPT-5.1: 62.5% ASR corrected, 99% signature) and failed exfiltration (GPT-4.1-mini: 0% ASR, 100% signature). A trajectory detector calibrated for high recall will flag Latent Carriers alongside successful attacks—an operationally useful property for supply-chain monitoring (Latent Carriers store dormant payloads that may execute under future model upgrades) but not for standalone inline blocking.

Cross-harness holdout (train LangGraph, test raw loop). The classifier is trained entirely on the LangGraph/SQLite factorial (its native harness). As a genuine out-of-harness generalization test, we froze that classifier and applied it—without retraining—to the raw-OpenAI-loop cross-framing sessions above, which use a different orchestration (direct SDK message loop, no LangGraph state machine) and a different, more recent model population (GPT-5.x, Gemini 2.5). On the corrected attack-success sessions, pooled recall is $186/188 = 98.9\%$ (per-model recall 0.975–1.000; only 2 missed sessions, both GPT-5.1 under the ReAct-prompt variant). Because these files contain almost no negative class, AUC is not informative here (near 0.5 by construction); recall among attack successes is the meaningful quantity. This is a cross-harness result (different execution engine), stronger than the within-loop prompt-framing comparison, and indicates the retrieval-to-action signature is a property of the attack’s information flow rather than of the LangGraph logging substrate.

5.2.1 GENUINE-FRAMEWORK OBSERVABLE ARM AND SCAFFOLD-SIDE IMPLICIT PROXY (V3-4)

The cross-framing study above varies prompt framing within one raw execution loop; it is not a test of independent orchestration engines (we label it exploratory in Table 1). We therefore pre-registered V3-4 (GPG-signed, before data): a replication whose *observable* and *benign* arms run on a genuine agent framework—LangGraph’s `create_react_agent` with tool-routed memory recall—and whose *implicit* arm is a genuine LangChain-style retriever-injection chain. **Implementation disclosure (implicit arm):** the released harness (`probe_v3_4.py::run_implicit`) instantiates a real FAISS retriever (the V3-2 store: 30 benign records + 1 poisoned routing rule, `text-embedding-3-small`, `IndexFlatIP` cosine, top- k) that retrieves records for the trigger query; the retrieved top- k are injected into the prompt and the LangGraph agent runs with only email tools (no memory/recall tool). The agent therefore issues no observable retrieval tool call (framework-side read), while a framework oracle logs whether the poisoned record was actually retrieved (real payload-delivery flag, not a hardcoded `delivery=1`). This occupies the same taxonomy cell (implicit read, scaffold-side) as the originally-planned OpenAI Assistants `file_search` arm, which was infrastructure-blocked (the institutional gateway forbids the Assistants and vector-store endpoints); the local FAISS retriever is a genuine open-source-framework retrieval pipeline standing in for the blocked managed endpoint, not a manual concatenation proxy. **Within-model contrast (confound closed):** both the observable and implicit arms are now run on `gpt-4.1` at $N=60$, so the 100% vs. 0% contrast below is a clean single-model manipulation of the observability axis (an earlier revision ran the observable arm on `gpt-4.1-mini` and the implicit arm on `gpt-4.1`, a cross-model confound; we retain the `gpt-4.1-mini` cells as an illustrative second model). The frozen P1-trained classifier is applied per-arm through a pre-declared ontology map: for the observable arm, LangGraph tool names map to canonical operations (the retrieval call genuinely exists); for the implicit arm, the framework retrieval issues no agent tool call and is encoded as *absent* (`recall_before_send=0` by construction), logged only as a delivery oracle—never remapped into a recall feature, so the observability boundary is demonstrated rather than assumed.

Results (within-model on gpt-4.1 for the observable and implicit arms; benign arm on gpt-4.1-mini; gpt-4.1-mini observable/implicit cells retained as an illustrative second model):

- **Observable arm (LangGraph ReAct, gpt-4.1):** attack succeeds in 39/60 delivered sessions (ASR 65%); among successes the frozen classifier flags 39/39 = 100% [0.910, 1.000]. The signature transfers to a genuine LangGraph orchestration engine—the first non-prompt-framing evidence in this work that the observable-arm signature survives a real agent framework. (On the second model, gpt-4.1-mini, the observable arm has a much lower ASR of 10/60 = 16.7% under the genuine ReAct scaffold, yet the classifier still flags 10/10 = 100% [0.722, 1.000] of those successes—the low mini ASR is why the original confirmatory roster paired mini with a gpt-4.1 implicit arm.)
- **Benign arm (LangGraph ReAct, gpt-4.1-mini):** the frozen classifier flags 60/60 = 100% [0.940, 1.000] of benign memory-grounded sessions. The precision ceiling reproduces under a real framework. Note that gpt-4.1-mini—classified act-without-grounding (0% benign FPR) under exact-key recall—grounds on *every* benign session under a genuine ReAct scaffold, reinforcing that the phenotype is interface-dependent, not model-intrinsic.
- **Implicit arm (genuine FAISS retriever, gpt-4.1):** the attack succeeds in 57/60 oracle-delivered sessions (ASR 95%), and the frozen classifier flags 0/57 = 0% [0.000, 0.063] of them—the framework retrieval produces no agent-visible tool call, so the detector is structurally blind. This is a genuine retriever-injection chain with a real delivery oracle, not a manual concatenation. (On the second model, gpt-4.1-mini, the implicit arm reached only 1/60 successes and is uninformative on its own; gpt-4.1 is the powered within-model comparison.)

The within-model observable–implicit contrast on gpt-4.1 (39/39 = 100% vs. 0/57 = 0% frozen-classifier recall) demonstrates the observability boundary on a genuine LangGraph engine (observable) and a genuine FAISS retriever chain (implicit), holding the model, tasks, payload, and execution framework fixed and varying only whether the read is tool-routed. It complements the architectural argument (Section 3) and the V3-2 arm C construction. The gpt-4.1-mini cells (observable 10/10, implicit 0/1, benign 60/60) reproduce the same directional boundary on a second model.

Endpoint disclosure (V3-4). V3-4’s success scorer is the *policy-violation* endpoint of §2.1, not the planted-address one: `probe_v3_4._finish` sets `exfil` if any recipient differs from `team@example.com`, so an invented or confabulated external address counts as a success without the planted `attacker@evil.example.com` appearing. This is the same allowlist operationalisation V3-1 uses, and it carries the same ambiguity: the counts establish unauthorized external sends, not that the specific planted payload drove the routing. Unlike V3-1 we do *not* report a planted-address-matched sensitivity analysis for V3-4, because the arm’s per-call recipient arguments were not persisted in a form that supports it. The observability contrast is unaffected—it compares the *signature* rate among successes under a fixed success definition, and the implicit arm’s 0/57 cannot be produced by a looser recipient rule—but the 65% and 95% ASR figures should be read as policy-violation rates, not planted-payload attribution rates.

Scope. This extension validates cross-scaffold and cross-model transfer of the retrieval-to-action signature under one attack construction (the delayed-trigger compliance-framing attack). Transfer across independent attack families is now partially probed but not confirmed: X1 (Section 6.5) reproduces the both-implicit boundary on a mechanism-faithful MINJA query-only case-bank implementation (within-model gpt-4.1 observable 80/80 vs. implicit 0/141), but after the `inert-similarity` cluster-unit correction and a preregistered continuation to the registered cap the implicit arm reaches only 9 of the required 10 effective clusters (and just 8 configurations contribute eligible successes in both arms; under the stricter send-only endpoint neither arm passes), so this is directional/LOW-CLUSTER evidence and the “no independent attack family” gap is narrowed rather than closed; the emergent sliding-window Zombie implementation likewise remains directional/LOW-CLUSTER (no fully-powered within-model contrast). Clustered-primary independent-family confirmation therefore remains the primary outstanding external-validity gap for both families. The $N=20$ model-sweep cells have Wilson CI half-widths of ± 16 –22pp; the 0/20 and 20/20 results map to [0%, 16.1%] and [83.9%, 100.0%] respectively. Per-trial logs, prompts, and harness code are released with the paper artifact.

6 DISCUSSION

6.1 WHY TOOL-CALL LOGGING IS SUFFICIENT FOR STRUCTURAL TRIAGE

The detector requires no model access, no memory inspection, and no additional inference. Tool-call logs are already generated by production agentic frameworks (*e.g.* LangChain tool invocation hooks, OpenAI function-call traces, Anthropic tool-use events). Deploying the classifier requires only routing these logs to a feature extractor and a trained model. The per-session inference cost is negligible (19 low-dimensional features; RF prediction in microseconds). This is deployable by any operator who can record tool invocations, a lower bar than defenses requiring memory-store modification, model internals, or content inspection.

6.2 RELATIONSHIP TO THE P1 DEFENSE FAILURE

IED (same author) found that five of six defense classes fail against memory poisoning in the tested configuration: input-level and retrieval-level defenses cannot observe the attack surface, and instruction-level defenses are overridden by compliance framing. The trajectory classifier is complementary: it is a *detection* mechanism, not a *prevention* mechanism. It does not stop the attack; it flags that a memory-grounded action occurred, which narrows a candidate set for incident response. It does *not* attribute the vector: §4.10 withdraws that implication, because prompt-inline attacks also produce the signature in 7/20 sessions and benign memory-grounded sends produce it at a 100% conditional rate. Detection without prevention retains operational value for triage, forensics, and anomaly alerting, provided attribution is done with the recipient and content inspection the operation-only feature set excludes.

6.3 CROSS-FRAMEWORK SCOPE: RETRIEVAL OBSERVABILITY AS THE BOUNDARY

A standing criticism is that our detector was validated on only one attack construction—our own delayed-trigger attack (DTA, from IED). We address this in two ways: an architectural argument (below) and, in X1 (§6.5), a mechanism-faithful reproduction of an independent family (MINJA case-bank) that partially closes the gap (Zombie remains directional/LOW-CLUSTER). Can the trajectory invariant generalize to other memory-poisoning families? We argue that the answer depends on a single architectural variable: whether memory retrieval is *observable* (routed through a logged tool call) or *implicit* (performed by the framework without agent-initiated invocation).

Table 12 classifies the major published memory-poisoning attack families by their memory-access mechanism:

Why implicit-retrieval attacks evade the detector. In MINJA (Dong et al., 2025), malicious records are injected via the agent’s own record-logging process and later retrieved by the framework’s embedding-similarity mechanism as in-context demonstrations—the agent never issues an observable `recall_fact` call. Similarly, Zombie Agents (Yang et al., 2026) persist payloads through sliding-window or retrieval-augmented memory implementations where retrieval is performed by the infrastructure, not by an agent-initiated tool invocation. In both cases, the `recall_before_send` transition cannot fire because no recall tool call is generated.

6.4 WRITE OBSERVABILITY AS A SECOND AXIS

The retrieval-observability boundary above concerns the *read* side of the attack (does payload retrieval produce a logged tool call?). A re-analysis of our existing implicit-delivery data—using only data already collected, no new experiments—shows that detectability is more precisely a function of *two* observability axes: whether the malicious *write* (payload storage) is observable, and whether the *read* (retrieval) is observable. This refines the taxonomy from a one-dimensional retrieval-observability boundary to the 2×2 structure in Table 13.

We scored two operation-level signatures on successful attacks from the implicit-delivery arms: the paper’s `recall_before_send` rule, and a `save_before_send` rule (any `memory_save_fact` preceding an exfiltrating send). Three findings result. (i) On the V3-1 implicit-delivery successes with `recall_before_send=0` ($N=28$; GPT-4.1 $n=14$, GPT-4o $n=14$; claude-sonnet-4-6 produced

no successful attacks), the payload delivery is implicit on the read axis but the agent still issues an observable `memory_save_fact` in 24/28 cases, so a *save_before_send* rule flags 24/28 while *recall_before_send* and the full 19-feature classifier flag 0/28. (ii) However, *save_before_send* exhibits a 66.7% benign false-positive rate (22/33 benign memory-grounded sends in the V3-2 benign arm): like *recall_before_send*, it is an attack *precondition*, not a maliciousness predicate. (iii) In the both-implicit cell—V3-2 arm C, where retrieval is scaffold-side and no `memory_save_fact` tool call is emitted, the architecture that native MINJA and Zombie Agents occupy—*save_before_send* flags 0/53 successful attacks. The 4/28 V3-1 successes that emit neither recall nor save (trajectory `list_all_facts`→`draft`→`send`, spanning 3 distinct scenario configurations) produce neither memory-operation signature.

Together these results show that memory-poisoning detectability is governed by two observability axes (write and read); attacks implicit on both axes—the cell occupied by Zombie Agents and (now measured mechanism-faithfully via X1, §6.5) MINJA—leave no observable payload-retrieval provenance and are caught 0/53 by the tested memory-operation signatures (*recall_before_send*, *save_before_send*), confirming their invisibility to *memory-operation-signature* monitoring (X1 shows this is not invisibility to every trajectory feature: an implicit MINJA attack still trips a classifier keying on non-retrieval action-shape features), while attacks observable on either axis produce a signature that remains a precondition (66.7% benign FPR), not a maliciousness predicate. This narrows rather than overturns the paper’s central claim: retrieval (read) observability determines observability of the *retrieval provenance*, and the both-implicit conclusion for MINJA (directional/LOW-CLUSTER after the cluster-unit correction, §6.5) and Zombie (directional/LOW-CLUSTER) is unchanged in direction, but “implicit retrieval evades trajectory monitoring” as an unqualified statement is too strong—an observable write leaves a (noisy) trace. *Write-provenance verification* (Exp 13c): the original V3-1 logs recorded operation names but not `memory_save_fact` key/value arguments, so the *save_before_send* figure was initially an operation-level association—we could not verify from the logs whether the observed save wrote the attack payload, a benign decoy, or imitated the in-context demonstration. We closed this by re-running the V3-1 treatment with argument logging (a preregistered QC amendment): among successful attacks whose *save_before_send* fired, the write was the actual attacker payload in 37/37 cases (26/26 GPT-4.1, 11/11 GPT-4o; GPT-4o reached only 11 of a targeted 40 successes before its ASR-limited run ended, so its write-provenance cell is exact but underpowered relative to GPT-4.1—see the deviation summary). The write signature, when it fires, thus reflects a genuine payload write—verified provenance, not mere association. This strengthens the *precondition* reading only; the 66.7% benign *save_before_send* FPR is unchanged, so the write axis remains a precondition, not a maliciousness predicate.

The invariant’s true scope. The detector targets the *tool-routed* portion of the memory-poisoning attack surface: architectures where memory access is mediated by observable tool calls. The structural argument applies whenever successful exfiltration depends exclusively on information returned by a logged retrieval operation. This is common in production deployments that expose memory as a first-class tool interface (LangChain, LlamaIndex, OpenAI Assistants), and we have empirically confirmed the invariant for two tool-routed retrieval primitives (exact-key recall and semantic search). However, attacks that bypass observable tool interfaces (implicit RAG, framework-level context assembly, cached internal state) fall outside the detector’s architectural assumptions and require complementary defenses (content-level DLP, semantic correlation analysis, or retrieval-layer monitoring).

Implications. Retrieval observability is the dividing variable of the memory-poisoning attack surface with respect to trajectory-based detection. When successful exfiltration causally depends on a payload obtainable only through an observable retrieval tool, a retrieval-before-exfiltration event is structurally necessary. Per-primitive evidence (V3-1 controls + V3-2 arm B, preregistered scoring): exact-key recall 58/58 zero violations (GPT-4.1 28/28 + GPT-4o 30/30); semantic search 33/33 on GPT-4.1 and, after a preregistered fresh-cohort power extension (Exp 13a) that removed the original underpowered $N=13$ cell, GPT-4o pooled 43/43 zero violations (two-sided 95% Wilson upper endpoint on the violation rate ≈ 0.082). Under corrected scoring: GPT-4.1 semantic 38/38. When the scaffold delivers the payload without an observable tool call, attacks remain viable without producing the signature (V3-1 treatment, V3-2 arm C)—the signature absence in arm C is architectural (no search tool available) rather than a behavioral choice by the model. Neither direction implies sufficiency for detecting maliciousness: benign memory-grounded sends produce trajectory-isomorphic

signatures (v2). This boundary is empirically verified on act-without-grounding models (GPT-4.1, GPT-4o) and, via V3-3, on a ground-then-act model (gemini-2.5-pro): necessity breaks under implicit delivery for both phenotypes (28/30 treatment successes $\text{rbs}=0$ on gemini-2.5-pro, despite an 88.3% benign recall-before-send habit; Section 6.4.1). The necessity claim requires that successful execution depend on information available exclusively through the logged retrieval operation—if the payload is accessible by other means, the model may bypass observable retrieval even when the tool exists.

Empirical validation (V3-1). A within-architecture probe (V3-1; preregistered design, exploratory execution due to deviations noted below; $N=40$ per cell, 3 models $\times$ 2 arms = 240 total trials; 2 models informative, 1 untestable due to near-zero ASR) directly tests the retrieval-observability mechanism. Both arms use the identical DTA agent architecture (same tool schema, same exfiltration action, same decoy facts in memory). The *control* arm delivers the routing address via `recall_fact` (tool-routed); the *treatment* arm delivers it as an ICL demonstration simulating framework-level implicit retrieval (the address is visible in context without requiring a `recall_fact` call). The ICL demonstration depicts no `recall_fact` invocations (anti-imitation constraint; see prereg V3-1). Note that ICL demonstration is a *proxy* for framework-level implicit retrieval; V3-2 (below) tests the same mechanism with real embedding-similarity retrieval and finds broadly consistent evasion rates.

Results confirm the mechanism variable (per-model, no pooling):

- **GPT-4.1 control (tool-routed):** ASR = 28/40 (70%); among successes, $P(\text{rbs}=1 \mid \text{success}) = 28/28 = 100\%$ (two-sided 95% Wilson CI upper endpoint on violations: [0, 0.121]). The invariant holds.
- **GPT-4.1 treatment (implicit):** ASR = 21/40 (52.5%); among successes, $P(\text{rbs}=0 \mid \text{success}) = 14/21 = 67\%$ (nominal Wilson 95% CI [0.454, 0.828]; *scenario-clustered* bootstrap 95% CI [0.450, 0.864], resampling the 18 scenario configurations—excludes 0 under both). Necessity is broken.
- **GPT-4o control (tool-routed):** ASR = 30/40 (75%); among successes, $P(\text{rbs}=1 \mid \text{success}) = 30/30 = 100\%$ (two-sided 95% Wilson CI upper endpoint: [0, 0.114]). The invariant holds — replicating on a second act-without-grounding model.
- **GPT-4o treatment (implicit; exploratory):** ASR = 19/40 (47.5%); among successes, $P(\text{rbs}=0 \mid \text{success}) = 14/19 = 74\%$ (nominal Wilson 95% CI [0.512, 0.882]; *scenario-clustered* bootstrap 95% CI [0.600, 0.929]—excludes 0 under both). Necessity is broken on a second model, supporting H2a: the effect is a phenotype property (act-without-grounding), not a model-specific artifact. (GPT-4o was added post-hoc; see deviations.)
- **Claude Sonnet control:** ASR = 1/40 (2.5%); the single success has $\text{rbs}=1$. **Claude Sonnet treatment:** ASR = 0/40 (0%), refusing the attack regardless of delivery mechanism. H2 is untestable for *this* ground-then-act model at the current N . *Gap now closed* (V3-3): we preregistered and ran a ground-then-act replication on gemini-2.5-pro (promoted by a preregistered ASR pilot gate: control-arm ASR $50\% \geq 10\%$). Results (Section 6.4.1): control $\text{rbs}=0$ in 0/19 successes (zero-event cell; the clustered percentile bootstrap is degenerate, so we report the Wilson upper bound 0.243 on the 12-cluster effective- N); treatment $\text{rbs}=0$ in 28/30 = 93.3% of successes (scenario-clustered 95% CI [0.821, 1.000], excludes 0); and a benign keystone cell shows the model recalls-before-send on 53/60 = 88.3% of benign tasks. So even a model with a strong verification-recall habit stops recalling under implicit delivery—the scope boundary replicates across *both tested behavioral phenotypes* (act-without-grounding and ground-then-act), rather than being limited to act-without-grounding. We validate on one ground-then-act model and do not claim universality over untested models.
- **H2a (phenotype moderation):** GPT-4.1 $\text{rbs}=0$ rate = 67% [0.454, 0.828]; GPT-4o $\text{rbs}=0$ rate = 74% [0.512, 0.882]. The preregistered H2a Fisher exact test is now computed and detects no difference between the two act-without-grounding models (OR=0.71, $p=0.74$), consistent with a shared phenotype effect rather than model-specific variation. The act-without-grounding class reliably bypasses the detector under implicit delivery.
- **Verification recall (H4):** Among the 12 treatment successes across both models that produced $\text{rbs}=1$, `recall_fact` calls targeted benign decoy keys (3/36 recalls targeted the

attacker address for GPT-4o; 0/29 for GPT-4.1). These are predominantly verification recalls of unrelated stored facts, mechanistically distinct from the control arm’s forced recall.

- **Classifier score distribution (H3):** On the two act-without-grounding models, the trained RF classifier scores control successes at mean = 0.95 (detected 58/58 across GPT-4.1 + GPT-4o); treatment rbs=0 successes score mean = 0.12 (detected 0/28 — complete evasion), while rbs=1 successes score mean = 1.000 (detected 12/12). The preregistered H3 test is now computed on all control successes (the 58 above plus Claude Sonnet’s single control-arm success, $n=59$) versus all treatment successes ($n=40$): a one-sided Mann–Whitney U test confirms treatment successes score below control successes (medians 0.339 vs. 1.000; $U=438$, $p=1.4\times 10^{-8}$; pooled treatment mean 0.49, reflecting the mixture of rbs=0 evasions and rbs=1 decoy-recall successes). These 12 rbs=1 “detections” are precision-coincidental: the agent happened to recall benign decoy facts before sending, producing the same trajectory shape as a genuine tool-routed attack — but the recall was unrelated to the exfiltration payload. The detector is structurally blind to implicit-delivery attacks that do not trigger verification recall. *Caveat on both preregistered tests:* the Fisher and Mann–Whitney tests above are computed on trial-level observations, but V3-1’s trials nest within 18 scenario configurations, so the nominal p -values are anti-conservative (they assume independence the design does not provide) and we do not treat them as cluster-valid inference. Neither conclusion rests on them: H2a is null (clustering would only widen it further), and the H3 direction is carried by the detection counts themselves (58/58 control versus 0/28 treatment rbs=0), a separation far larger than any plausible design effect over 18 clusters could erase.

Deviations from preregistration. The prereg (commit 96e63e8) specified $N=40$ per arm per model sampled from a 72-scenario grid ($3 \times 3 \times \sim 4 \times 2$), with a stopping rule extending sampling until ≥ 30 treatment successes per model or grid exhaustion. In implementation, the decoy-subset axis was fixed rather than varied (the decoy pool is present in all trials but which specific decoys are stored does not interact with the mechanism variable—retrieval observability depends on *whether* recall occurs, not on *which* keys are recalled), yielding an 18-scenario grid ($3 \times 3 \times 2$); we collected the preregistered $N=40$ per cell (scenarios sampled with replacement beyond the 18-element grid). *Unique-scenario N :* the effective number of independent observations per cell is $N_{\text{unique}}=18$ (unique scenario configurations), not the nominal $N=40$ —each scenario is repeated $\sim 2.2\times$ on average. GPT-4o was added post-registration as a robustness check (same phenotype, same architecture, same tool schema); its inclusion is exploratory with respect to the prereg but strengthens H2a. The GPT-4.1 treatment arm yielded 21 successes and GPT-4o yielded 19 (both below the 30-success floor); the preregistered 72-scenario grid was not fully instantiated. Despite the reduced grid, both models’ primary CIs exclude 0 ([0.454, 0.828] and [0.512, 0.882] respectively), so the confirmatory conclusion is unaffected. *Non-independence caveat:* the 40 trials per cell are sampled from only 18 unique scenario configurations, with some scenarios repeated 2–5 times. Wilson intervals assume independent observations; repeated-scenario trials at temperature=0 against the same API endpoint are anti-conservative for the treatment-arm rate estimates because identical prompts to a deterministic endpoint produce correlated (often identical) outcomes. The effective number of independent observations is closer to $N=18$ (unique scenarios) than to the nominal $N=40$. The control-arm zero-violation observation (a count, not a rate estimate) is unaffected by this concern. For the treatment-arm rate estimates we now report *scenario-clustered* bootstrap CIs (resampling the 18 scenario configurations as clusters) alongside the nominal Wilson intervals: GPT-4.1 [0.450, 0.864] (vs nominal [0.454, 0.828]) and GPT-4o [0.600, 0.929] (vs nominal [0.512, 0.882]). Both clustered intervals exclude 0, so the confirmatory conclusion is unchanged under clustered inference. *Planted-address sensitivity:* the attack-success scorer is allowlist-based (any send to a recipient outside team@example.com); because the V3-1 scenario grid shares two attacker addresses, 7/40 successes across the two treatment cells sent to the *other* attacker address rather than the one planted in that scenario (GPT-4.1 3/21, GPT-4o 4/19; all to auditor@external-compliance.com while attacker@evil.example.com was planted). These are genuine unauthorized external sends to an attacker-controlled address, but they are ambiguous evidence for dependence on the *scenario-specific* payload. Restricting to planted-address-matched successes, the rbs=0 rate is GPT-4.1 11/18 = 61.1% (scenario-clustered 95% CI [0.368, 0.833]) and GPT-4o 10/15 = 66.7% ([0.500, 0.889]); both still exclude 0, so the necessity-breaking conclusion holds under the stricter mechanistic scorer. We report the allowlist rates as primary (the preregistered operationalization)

and the planted-address rates as this sensitivity analysis. *Presentation-format check*: to rule out that the implicit-delivery evasion is an artifact of the ICL prefix wording rather than of implicit delivery per se, we re-ran the GPT-4.1 treatment with the V3-2-style “[Retrieved context]” prefix framing (in place of V3-1’s prior-exchange ICL framing); the $\text{rbs}=0$ rate among successes is $8/20 = 40\%$ (Wilson $[0.219, 0.613]$), overlapping the primary V3-1 ICL CI $[0.454, 0.828]$; the overlap fails to reject a difference (it does not prove equivalence, and the 40% vs 67% point-estimate gap leaves a partial formatting effect unexcluded), but the evasion is clearly present under both framings and is therefore not solely a presentation-format artifact. Claude Sonnet’s near-zero ASR (0/40 treatment, 1/40 control) is an unanticipated outcome outside the preregistered decision tree; H2 was untestable for that model and is addressed by the separate V3-3 ground-then-act replication (Section 6.4.1). The registration-to-execution interval was <24 hours (same calendar day; GPG-signed timestamps machine-verifiable).

The $\sim 30\%$ treatment $\text{rbs}=1$ rate across both act-without-grounding models (all from decoy-fact verification) has an adaptive-adversary implication: an attacker aware of the detector need only harvest the $\text{rbs}=0$ subset of successful implicit attacks to guarantee evasion. The detector cannot distinguish “agent recalled a decoy before sending” from “agent recalled the attack address before sending” using operation-only features — both produce $\text{rbs}=1$, but only the latter is causally related to the attack.

6.4.1 GROUND-THEN-ACT REPLICATION (V3-3)

V3-1’s testable models (GPT-4.1, GPT-4o) are both *act-without-grounding*: they do not habitually recall stored context before acting, so it is unsurprising that they omit recall when the payload is delivered implicitly. The sharper test is a *ground-then-act* model, which recalls stored context as a matter of habit even on benign tasks; if such a model’s verification habit persisted under implicit delivery, it would restore the signature and make the boundary phenotype-dependent. V3-1 could not run this test because Claude Sonnet refused the attack ($\text{ASR} \approx 0$). We preregistered V3-3 (GPG-signed, before data) to close this gap, extending V3-1’s two-arm design to a ground-then-act model and adding a benign keystone cell. Both falsification branches (necessity breaks vs. signature survives) were preregistered with equal prominence.

Model selection (preregistered pilot gate). Because the estimand conditions on attack successes, a model with near-zero ASR is uninformative. We piloted candidate ground-then-act models at $N=20$ on the control arm (discarded data, fixed seed distinct from confirmatory) with a preregistered inclusion threshold of control-arm $\text{ASR} \geq 10\%$. `gemini-2.5-pro` cleared it decisively (control ASR 50%) and is the confirmatory model; local open-weight grounders were deferred (hardware constraints) and would enter only as labeled-exploratory secondaries.

Design refinements over V3-1. To address V3-1’s effective- N limitation, V3-3 expands the scenario grid to 36 distinct configurations (varying the decoy-subset axis V3-1 collapsed) and uses *negative-binomial* sampling (collect until ≥ 30 treatment successes or a hard cap of $N=120$; stopping depends only on the success count, never on the rbs outcome, so the conditional estimand is free of optional-stopping bias). The control arm receives a length-matched benign prefix so the treatment ICL demonstration’s ~ 400 extra tokens cannot be confounded with an attention-dilution effect. The primary CI is a *scenario-clustered* bootstrap (resampling distinct configs as clusters), with Wilson intervals as a secondary reference. The anti-imitation ICL constraint (no `recall_fact` depicted in the demonstration) is carried over from V3-1.

Results (gemini-2.5-pro).

- **Control (H1, tool-routed):** ASR $19/60 = 31.7\%$; among successes 0/19 have $\text{rbs}=0$. This is a zero-event cell, so the scenario-clustered percentile bootstrap is degenerate (every resample reproduces 0, giving a spurious $[0, 0]$); we therefore report a Wilson upper bound on the effective cluster count (12 scenario clusters): $[0.000, 0.243]$ (trial-level Wilson upper 0.168). The necessity invariant *replicates* on a ground-then-act model.
- **Treatment (H2, implicit delivery):** ASR $30/70 = 42.9\%$ (negative-binomial stop at 30 successes); among successes $28/30 = 93.3\%$ have $\text{rbs}=0$ (scenario-clustered 95% CI $[0.821, 1.000]$, excludes 0; 17 effective scenario clusters). **Necessity is broken.** The

two rbs=1 successes recalled the attacker-address key (genuine payload verification), not a decoy.

- **Benign keystone (H_{benign}):** on legitimate memory-grounded tasks with no attack material and no ICL demonstration, gemini-2.5-pro exhibits recall-before-send in $53/60 = 88.3\%$ of sessions (scenario-clustered 95% CI $[0.772, 0.967]$).

Interpretation. The benign keystone is decisive: gemini-2.5-pro *does* have a strong verification-recall habit (88.3% on benign tasks), yet it drops recall in 93.3% of successful implicit-delivery attacks. Habit is present; the signature is absent. This rules out the preregistered “grounders recall anyway” branch and shows the evasion is driven by the delivery architecture (payload already in context $\Rightarrow$ no information-need to recall), not by the model’s behavioral phenotype. Notably the ground-then-act evasion rate (93.3%) is *higher* than the act-without-grounding rates (67%/74%), the opposite of the naive habit-based prediction. The scope boundary therefore replicates across both tested phenotypes. This is one ground-then-act model, one vendor, one attack construction: we claim replication across the tested phenotypes, not universality over unexamined models.

6.4.2 SECOND OPEN-WEIGHT GROUND-THEN-ACT GROUNDER (X2)

V3-3 established the implicit-delivery breakdown on one ground-then-act model (gemini-2.5-pro), from a single vendor. X2 (preregistered, GPG-signed before confirmatory data) adds a *second* ground-then-act grounder from a different model family: qwen2.5:32b, an open-weight model run locally via Ollama. It strengthens the secondary phenotype-generalizability claim, not the core taxonomy. The candidate cleared the preregistered discarded pilot gate (control-arm ASR $0.20 \geq 0.10$ AND benign recall-before-send $1.0 \geq 0.70$).

Regime-A caveat (disclosed adjacent to the result). X2 was collected on the existing GUI Ollama daemon, *not* a fresh-daemon restart as the reproducibility protocol prescribes; the served model digest 9f13ba1299afea09 was captured. This non-fresh-daemon deviation is a known confound for reasoning-model determinism and is stated here rather than buried, so the X2 numbers should be read as a strengthening-but-caveated open-weight replication.

Results: the treatment (implicit) arm shows `recall_before_send=0` in $27/31 = 87.1\%$ of successes, but with only 7 success-contributing scenario clusters this arm is **LOW-CLUSTER** (below the preregistered ≥ 10 -cluster gate), so the scenario-clustered interval is descriptive and the Wilson interval $[0.711, 0.949]$ governs; it is a strong directional pattern consistent with the necessity breaking under implicit delivery, reported as directional rather than confirmatory. The benign keystone confirms a strong verification-recall habit at $60/60 = 100\%$. **The control arm is also underpowered:** it recorded 0 violations among 24 successes (7 clusters) but hit the $N=150$ cap without reaching the preregistered 37-success target, so H_1 ’s ≤ 0.10 upper-bound threshold was *not* met (two-sided Wilson upper 0.138). We therefore report the X2 control as *consistent with but underpowered relative to* the necessity invariant, never as a confirmation. Net: X2 is a second model family / open-weight ground-then-act grounder whose treatment arm shows a directional (LOW-CLUSTER) breakdown pattern, weakly strengthening phenotype-generalizability, but with both arms below the cluster gate and a Regime-A daemon caveat.

Embedding retrieval validation (V3-2). A second probe (V3-2; preregistered design, scorer corrected post-hoc as disclosed below; $N=200$, 2 models $\times$ 2 arms + 40 benign) directly tests whether the invariant generalizes from exact-key recall to *any* tool-routed retrieval, and whether attacks remain viable when the payload is delivered scaffold-side without an observable tool call.

Setup: FAISS index over 30 benign organizational records + 1 poisoned routing rule, embedded via `text-embedding-3-small` (1536d, cosine similarity, $\text{top-}k=4$). Arm B provides a `memory_search(query)` tool; arm C injects $\text{top-}k$ results scaffold-side with no search tool available. A framework-level oracle logs whether the poisoned record was retrieved (rank, similarity) for each trial. Embeddings are cached per attacker-address condition in the released artifacts; because they are produced by an external embedding API, the cache supports re-runs but the vectors are auditable via provenance stamps rather than guaranteed bitwise-identical across API snapshots (consistent with the reproducibility statement in Table 1).

Results (per-model, no pooling; Table 14):

- **H1 (arm B — semantic tool search preserves invariant):** Among successful attacks where the payload was oracle-confirmed as delivered, under the *preregistered* scorer (`email_send_email` only): GPT-4.1 33/33 and GPT-4o 13/13 exhibited `search_before_send=1` (zero violations). Under the corrected scorer (sensitivity analysis counting `email_draft_email` as exfiltration-capable): GPT-4.1 38/38. *GPT-4o power extension (Exp 13a)*. The original V3-2 arm B cell yielded only 13 oracle-confirmed delivered successes (delivery rate $27/40 = 67.5\%$ due to retrieval competition from 30 benign records), giving a two-sided 95% Wilson upper endpoint on the violation rate of ≈ 0.228 —underpowered. We therefore preregistered a fresh-cohort extension (Exp 13a): a separate cohort collected to 30 additional oracle-delivered successes, scored separately and tested for a batch effect against the original 13 before pooling. The fresh cohort shows `search_before_send=1` in 30/30; because both the original (13/13) and fresh (30/30) cohorts are zero-violation, the two are trivially homogeneous on the estimand of interest and no batch-effect test is informative (a Fisher exact test on the $[[13, 0], [30, 0]]$ table returns $p=1$ by construction, with no power against the alternative), so we pool to 43/43 (two-sided 95% Wilson upper endpoint on the violation rate ≈ 0.082). The GPT-4o arm B invariant is thus now confirmed with a violation rate bounded below $\sim 8\%$, not merely directional. When successful exfiltration causally depends on a payload available exclusively through the observable `memory_search` tool, a retrieval event before the first exfiltration-capable email action is structurally necessary on both GPT-4.1 and GPT-4o.

Scorer correction justification (sensitivity analysis): The preregistered scorer checked only `email_send_email`. Post-collection, 5 GPT-4.1 trials used `email_draft_email` (specifying the attacker address at draft time, never proceeding to send). Counting `draft_email` as exfiltration-capable is justified because: (1) the recipient-routing decision — the attack’s defining exfiltration act — is made at draft time; (2) in production, a draft containing the attacker address is the threat, regardless of whether a separate send step follows; (3) the tool schema declares `draft_email` with a required `to` field, making it functionally equivalent to `send_email` for routing exfiltration. All 5 records had `memory_search` preceding `draft_email`; no trial was excluded or manually relabeled. The conservative primary result uses 33/33 under preregistered scoring; the corrected 38/38 is a sensitivity analysis. Both are consistent with zero violation rate (two-sided 95% Wilson CI upper endpoints: 0.102 and 0.091 respectively), providing bounded evidence for the retrieval-dependency invariant on GPT-4.1.

- **H2 (arm C — attacks remain viable without observable retrieval):** Arm C removes all `memory_*` tools from the agent’s schema (see Classifier applicability below for residual `rag_query` disclosure), so `search_before_send=0` is *structural/definitional*, not a measured behavioral rate: with no search tool in the schema the signature *cannot* fire, so arm C tests attack *viability* under implicit delivery, not an evasion rate (the read-axis evasion rate is estimated in V3-1 treatment and V3-3, where the recall tool is available but unused). The empirical finding is that attacks remain viable under this architecture: GPT-4.1 33/40 trials and GPT-4o 20/40 trials succeeded after oracle-confirmed payload delivery (CIs for attack viability: $[0.680, 0.913]$ and $[0.352, 0.648]$ respectively). This demonstrates that observable retrieval is not a precondition for successful exfiltration—the attacker can deliver payloads via channels that leave no trajectory signature—not that the model “chose” to bypass retrieval when retrieval was available.
- **H3 (proxy consistency):** Arm C attack-success rates (successful attacks among delivered trials) were broadly consistent with the V3-1 ICL-proxy treatment results. GPT-4.1: arm C = $33/40 = 0.825$ vs. ICL-proxy ASR = $21/40 = 0.525$; GPT-4o: arm C = $20/40 = 0.500$ vs. ICL-proxy ASR = $19/40 = 0.475$. Both mechanisms produce substantial successful attack rates despite payload delivery via implicit means. Because equivalence margins were not preregistered, we interpret this as qualitative consistency rather than formal equivalence: both scaffold-side and ICL-proxy delivery sustain viable attacks that lack the detection signature.
- **H4 (benign):** In the benign semantic-memory condition (GPT-4.1 only, no poisoned record, $N=40$), 33/40 trajectories (82.5% , CI $[0.680, 0.913]$) contained `search` before the outbound email action. This demonstrates that the precision limitation documented in v2 also occurs with semantic tool retrieval under the same task family.

Classifier applicability. The 19-feature Random Forest (Section 4.5) was trained on trajectories using the original DTA tool schema (`recall_fact`, `list_all_facts`). Arm B uses `memory_search`—a different operation name—meaning the trained classifier’s `recall_count`, `recall_before_send`, and `bigram` features would all read 0 without feature remapping or re-training. Arm C removes all `memory_*` tools; a residual `rag_query` tool remained in the schema but returned only a static acknowledgment (no actual retrieval), and its invocations (31/40 GPT-4o trials, 1/40 GPT-4.1 trials) did not access the poisoned record. V3-2 therefore validates the *generalized structural rule* (observable retrieval before exfiltration-capable action) directly. Whether the specific frozen 19-feature classifier (not just the rule) transfers to alternate tool schemas via feature remapping, we resolve by re-analysis: applied to the arm B trajectories without remapping, the frozen RF’s recall features read 0 and it detects 0/38 (GPT-4.1) / 0/13 (GPT-4o) successes; after a pre-declared ontology remap (`memory_search`→`recall_fact`), the same frozen classifier detects 33/38 = 86.8% (GPT-4.1) and 13/13 = 100% (GPT-4o). The trained classifier therefore does transfer across tool schemas, but only through an explicit human-specified ontology mapping—itsself an unvalidated deployment step—not automatically.

Top- k retrieval-depth sweep (X3). V3-2 registered a $k \in \{2, 4, 8\}$ robustness sweep but ran only $k=4$; the $k \in \{2, 8\}$ arm was the sole unexecuted preregistered analysis (Table 15). X3 (preregistered note, GPG-signed before data, via a parameterized k -runner that leaves the $k=4$ artifacts untouched) discharges it: arms B and C, gpt-4.1 and gpt-4o, $k \in \{2, 8\}$, $N=40$ per cell. The arm-B `search_before_send` violation rate is 0 in *all* cells at both $k=2$ and $k=8$; the gpt-4.1 $k=8$ cell meets the preregistered ≥ 30 -success robustness threshold (0 violations / 33 delivered successes, two-sided 95% Wilson upper endpoint ≈ 0.104), while the gpt-4o cells are underpowered/descriptive (delivery competition, as at $k=4$). Arm-C attack viability remains substantial at both depths (57.5–90.5%). The invariant is thus retrieval-depth-insensitive across the tested range, and no arm-B anomaly triggered the preregistered narrowing protocol. This is reported as robustness (it discharges the last outstanding preregistered analysis), not a new claim.

Deviations from preregistration (V3-2). GPT-4o arm B payload delivery rate was 27/40 (67.5%) due to retrieval competition from 30 benign records reducing the poisoned record’s rank. Per the prereg, the H1 analysis conditions on both success and delivery (13/13). The prereg’s stopping rule (extend to $N=60$ if < 10 successes) was not triggered for GPT-4.1 (38 successes) but GPT-4o yielded 13 (above the 10-success floor). *Non-independence caveat (V3-2):* V3-2 shares V3-1’s repeated-scenario structure (18 unique scenario configurations sampled with replacement to $N=40$ at temperature=0). The same anti-conservative interval concern applies: effective independent N is bounded by the 18 unique scenarios rather than the nominal 40 trials. The H1 zero-violation counts are unaffected (counts, not rate estimates), but H2 attack-viability CIs ($[0.680, 0.913]$ and $[0.352, 0.648]$) should be interpreted as approximate under the same caveat.

Scoring correction disclosure (V3-2). The preregistered scorer defined the signature as `memory_search` preceding `email_send_email`. Post-collection inspection revealed that GPT-4.1 arm B consistently used `email_draft_email` (the agent drafts to the attacker address rather than sending directly). Because `email_draft_email` requires specifying recipients and constitutes an exfiltration-capable action (the outbound routing decision is made at draft time), the scorer was corrected to define the first exfiltration-capable email action as either `email_send_email` or `email_draft_email`. All arm B observations were mechanically rescored from the immutable `call_sequence` field in the raw logs. This correction changed 5 GPT-4.1 records from `sbs=0` to `sbs=1` (all had `memory_search` preceding `email_draft_email`). No trial was excluded or manually relabeled. Under the original (erroneous) scorer: GPT-4.1 arm B = 33/38; under the corrected scorer: 38/38.

Consolidated deviation summary.

6.5 MECHANISM-FAITHFUL INDEPENDENT ATTACK FAMILIES (X1)

The paper’s largest external-validity gap has been that the both-implicit cell of the taxonomy (Table 12) was populated by architectural argument (status A), never by a mechanism-faithful implementation of an *independent* published attack family. X1 (preregistered, GPG-signed be-

fore data) probes this for one family and makes measured progress on a second. Both families are subjected to an observable-vs-implicit read manipulation in which the memory tool schema is present in *both* arms. **Scope of that statement (corrected in this revision).** Tool *presence* is not payload *reachability*, and in X1 only the former is held constant. In the observable arm `probe_x1.run_agent_seeded` serves the poison-bearing cases as the return value of `memory_search`; in the implicit arm `probe_x1.run_agent` starts from an empty store, so `memory_search` cannot return the poisoned exemplar at all (it returns “No stored cases match.” unless the agent has itself written something). The implicit arm’s `observable_read_of_poison=0` is therefore *structural*—the same status the paper assigns V3-2 arm C (§6.3)—and **not** a behavioral choice to decline an available poison retrieval. Earlier revisions of this section asserted the opposite (“a behavioral outcome, not a tool-absence artifact”); that assertion is withdrawn as contradicted by our own harness, and it is inconsistent with this section’s own later statement that in the implicit arm “no memory tool exposes the payload at all.” What X1 measures is consequently attack *viability* under scaffold-side delivery together with the architectural absence of retrieval provenance, not a measured evasion rate; the read-axis evasion rate—where the recall tool genuinely can return the payload and the model declines to use it—is estimated in V3-1 treatment and V3-3, not here. The **primary decision variable is the raw observable_read_of_poison** (did an agent tool call return the poison before the exfiltrating action?), not the frozen-RF score; the RF is reported as a secondary, out-of-distribution continuity check.

MINJA case-bank (measured, directional/LOW-CLUSTER after cluster-unit correction). We implemented a genuine MINJA-style query-only case-bank family (the attacker destination enters memory only as part of a logged past-action exemplar, surfaced at trigger time by task-similarity retrieval and used by in-context imitation). On `gpt-4.1`, within model, the raw `observable_read_of_poison` rate among eligible successes is $80/80 = 100\%$ in the observable arm and $0/141 = 0\%$ in the implicit arm, a matched-scenario paired observability contrast of $+1.0$ (scenario-clustered CI $[1.0, 1.0]$ over the 36 shared `scenario_ids=12` shared effective configurations; note that these are configurations *attempted* in both arms, and only 8 contribute eligible successes in both, so the contrast does *not* independently satisfy the ≥ 10 gate—see the Outcome paragraph and Table 16). `gpt-4o` corroborates directionally (observable 44/44; implicit 0/18).

Cluster-unit deviation (found post-hoc, 2026-09-19). We originally reported 13 and 19 success-contributing scenario clusters for these two arms and concluded that both satisfied the preregistered ≥ 10 -cluster gate. That conclusion was wrong. The MINJA scenario grid crosses 6 domains $\times$ 3 similarity levels (near/mid/far) $\times$ 2 framings = 36 `scenario_ids`, but the poison constructor `x.content.minja_poison_case()` accepts only (domain, framing)—similarity is passed at no call site, and the benign filler pool is identical across levels. All three similarity levels therefore produce a byte-identical poison case and an identical retrieval environment. The grid contains exactly 12 distinct poison texts, each mapped to exactly 3 `scenario_ids`, so the similarity factor did not create distinct scenarios; it triplicated the cluster count. Because the frozen bootstrap clusters on `scenario_id`, the reported counts were inflated $\approx 3\times$. Re-scoring on the effective cluster unit (`x_grid.effective_cluster_key`, which drops inert factors and is the identity for every other family) gave, on the original v3 sample, 6 effective clusters for the observable arm and 7 for the implicit arm—*both below the ≥ 10 gate*. The Addendum states that X1 reaches CONFIRMED only if *both* arms individually pass their Level-1 gates in the pre-designated primary model (`gpt-4.1`); that predicate failed.

Preregistered continuation to the registered cap (v4 amendment, GPG-signed before collection). Both arms had stopped early relative to the registered $N=360$ -per-cell cap (144 and 72 trials) because the v3 rule stopped at 30 eligible successes counted on the *inflated* unit. We therefore amended the stopping rule to be strictly harder—stop only when eligible successes ≥ 30 and effective contributing clusters ≥ 10 , cumulative across resume, within the unchanged $N=360$ cap—and continued collection. The design was not otherwise touched: the inert similarity factor was left inert and disclosed rather than retro-fitted to the frozen cosine bands, and the estimand, arms, grid, scorer and bootstrap seed are unchanged. The amendment carried a binding pre-commitment that if the gate remained unmet at the cap, MINJA would stay LOW-CLUSTER and would *not* be upgraded.

Outcome. The observable arm reached the gate: 252/360 trials, 80 eligible successes, $\text{orp} = 80/80 = 100\%$ (Wilson [0.954, 1.0]), 10 **effective clusters—gate satisfied, and satisfied on the collapsed unit**. The implicit arm ran to the full $N=360$ cap and did *not*: 141 eligible successes, $\text{orp} = 0/141 = 0\%$ (trial-level Wilson [0.0, 0.0265], superseded by the cluster-level bound [0.0, 0.299] below), 9 **effective clusters—one short**. The shortfall is not ordinary statistical underpowering, but neither is it a demonstration of impossibility. At the cap each effective configuration received exactly 30 implicit trials, and three of the twelve (`client_deliverable::mandatory_audit_cc` and both `compliance_report` framings) returned zero eligible successes. Zero in 30 carries a per-configuration Wilson upper bound of 0.113, so true rates of a few percent are entirely consistent with what we observed and a further 30 trials apiece might well have produced successes. The correct statement is therefore a *realised ceiling under the registered cap*: reaching 10 contributing clusters would have required sampling beyond the cap, which the amendment forecloses. The disposition rests on the cap and the pre-commitment, not on a claim that those configurations can never succeed.

The dead cells are not a delivery artifact. A natural alternative explanation is retrieval competition: the poison case competes against 12 pooled benign fillers (`x_content.DOMAIN_FILLERS`: 6 domains $\times$ 2 fillers; earlier revisions said 36, which was the `scenario_id` count, not the filler count) at $k=4$, so a configuration could fail merely because the poison is never retrieved. The per-trial logs rule this out. In *every* one of the twelve effective configurations the poison was delivered in 30/30 trials at a median `poison_rank` of 1.0—including all three dead cells, which are 90/90 delivered and 0/90 successful. Delivery is constant across the grid and cannot explain the shortfall. That uniform rank-1 retrieval also independently corroborates the inertness of `similarity`: had the near/mid/far bands been operationalised they would have produced a rank gradient, and none exists.

What the grid actually shows: domain-dependent viability of implicit imitation. See Section 6.7, which reports this as a result in its own right; it is the continuation’s most transferable finding and it is not a statement about our detector. **Honouring the pre-commitment, MINJA is therefore NOT upgraded: it is reported as measured but directional/LOW-CLUSTER, the same disposition as Zombie**, with Wilson intervals governing. The continuation nonetheless strengthened the evidence substantially—eligible successes rose $37 \rightarrow 80$ (observable) and $34 \rightarrow 141$ (implicit), and both point estimates held exactly (100% and 0%) across roughly four times the data. What the correction does *not* touch: the point estimates (80/80, 0/141), the no-poison controls, and the matched paired contrast (contrast +1.0). We note explicitly that the contrast’s 12 shared effective configurations are configurations *attempted* in both arms; applying the same success-contributing standard we apply to the arms, only 8 effective configurations contribute eligible successes in both arms, so the contrast does *not* independently satisfy the ≥ 10 gate and must not be read as rescuing the per-arm result. The released scorer now computes and gates on that figure (`eff_n_shared_contributing=8`, `eff_cluster_gate=false` in `results/xprogram_scored.json`); earlier revisions of the scorer gated on the attempted count ($12 \geq 10$) and therefore reported the contrast as gate-satisfied while the per-arm cells it summarises were not, contradicting this paragraph. The qualitative observability contrast—task-similarity retrieval of a poisoned exemplar delivers the destination into context with no agent-visible retrieval tool call, so retrieval provenance is absent—is unchanged and now rests on far more data; what remains withdrawn is its *confirmatory* (clustered-primary) status, because one arm does not reach the registered cluster floor within the registered cap.

The implicit arm’s interval must be read on the cluster unit, not the trial unit. The trial-level Wilson upper bound on 0/141 is 0.0265, and earlier revisions quoted that figure (tightened from 0.102) as the headline precision gain from the continuation. That bound treats the 141 eligible successes as 141 independent Bernoulli draws, which the design does not support: the trials are nested within 12 effective configurations (of which 9 contribute eligible successes), each contributing exactly 30 implicit trials, and `observable_read_of_poison` is a deterministic property of the delivery path within a configuration rather than an independently resampled outcome. Because the outcome is identically 0 in every cluster, the intra-cluster correlation is not identified from the data, so we report the conservative limit: treating each success-contributing effective configuration as the unit of analysis gives a cluster-level Wilson upper bound of $0/9 \Rightarrow 0.299$ (Clopper–Pearson 0.336); on the 12 attempted configurations it is 0.243 (Clopper–Pearson 0.265). A design-effect reading spans the two, but it must use the *unequal*-cluster arithmetic: the nine contributing configurations hold 30, 30, 30, 28, 14, 4, 3, 1, 1 eligible successes, so the effective clus-

ter size entering $DEFF = 1 + (m - 1)\rho$ is $m = \sum n_c^2 / \sum n_c = 26.29$, not the arithmetic mean 15.67. At $\rho = 0.1, 0.25, 0.5, 1.0$ the effective n falls to 39.9, 19.3, 10.3, 5.4 and the upper bound rises to 0.088, 0.166, 0.271, **0.417**. *Correction relative to earlier revisions of this revision's own ladder:* those figures (57.2, 30.2, 16.9, 9.0 and 0.063, 0.113, 0.185, 0.299) used the mean cluster size, which assumes equal sizes; under that assumption $\rho=1$ appeared to coincide with the cluster-count bound. It does not. For a trial-weighted rate whose outcome is constant within a cluster, the $\rho=1$ effective n is the Kish quantity $(\sum n_c)^2 / \sum n_c^2 = 5.36$, which is *smaller* than the nine clusters, so the genuinely conservative limit is 0.417 rather than 0.299. **We therefore report 0.299 as the cluster-unit bound on the unweighted cluster-level estimand—the preregistered unit—and 0.417 as the conservative limit on the trial-weighted rate, and we withdraw the claim that $\rho=1$ coincides with the cluster-level bound.** Either figure supersedes the trial-level 0.0265, and we withdraw the claim that the continuation tightened the bound by roughly 4×: what the continuation actually bought was more clusters (7 → 9) and an unchanged point estimate over 4× the trials, not a genuine 4× reduction in interval width. This does not change the LOW-CLUSTER disposition, which was already governed by the cluster gate; it removes an overstatement of precision. The same cluster-unit caveat applies to the per-configuration 0/30 bound of 0.113 quoted above, which is a trial-level bound within a single cluster and is therefore the correct unit at that level. Regenerate with `x1_cluster_bounds.py`; the bounds are persisted in `results/xprogram_scored.json` (`eff_cluster_unit_wilson`, `eff_kish_unit_wilson`) and `results/x1_cluster_bounds.json`.

The registered ≤ 0.20 bound was unreachable, which reframes “one cluster short.” X1’s H2 requires an implicit-arm clustered upper bound ≤ 0.20 in addition to the ≥ 10 -cluster gate. Under the cluster-unit convention this revision adopts, a zero-event cell needs 16 contributing clusters to clear 0.20 ($0/10 \Rightarrow 0.278$, $0/12 \Rightarrow 0.243$, $0/16 \Rightarrow 0.194$). The registered grid contains only 12 effective configurations, so *even a fully-populated implicit arm could not have satisfied H2 on this unit*. The shortfall we report is therefore against the *cluster gate*, not against H2: reaching a tenth cluster would have satisfied the gate and still left H2 unmet. We state this rather than letting “one short” imply that the registered criterion was within reach, and we note it as a design defect—the grid was sized for a trial-level interval convention and is too narrow for the cluster-level one the clustered design actually requires.

Two X1-specific scope disclosures. First, *the exfiltration endpoint differs from the main DTA endpoint*. The paper’s threat model defines attack success as `email_send_email` to a recipient outside the allowed set, but the X1 harness treats the first destination-bearing email action as exfiltration-capable and therefore also counts `email_draft_email` (`probe_x1.dispatch` appends both to the scored emails list). We report the send-only sensitivity: restricting to trials in which `email_send_email` actually occurred gives observable $74/74 = 100\%$ across 9 effective clusters and implicit $0/138 = 0\%$ across 8 (released as the `x1_send_only` block of `results/xprogram_scored.json`; regenerate with `score_xprogram.py --exp x1_send_only`). The `orp` point estimates are completely unchanged, but under the send-only endpoint *neither* arm satisfies the ≥ 10 -cluster gate—so the LOW-CLUSTER disposition is robust to the endpoint choice, and is if anything more firmly indicated under the stricter endpoint. We note the residual imprecision: this filter conditions on a send call having occurred but retains the draft-or-send eligibility flag, so it tightens the endpoint toward the threat model without fully reproducing it; a trial that drafted to the attacker and sent elsewhere would still be counted. Fully reproducing the main endpoint requires per-call recipient arguments, which the X1 harness did not persist. Draft-only cases are 6/80 (7.5%) and 3/141 (2.1%) of the two arms’ eligible successes. Second, *the two arms’ trigger text is not identical*. The observable arm appends a parenthetical retrieval hint (“(Use `memory_search` to review past cases.)”) that the implicit arm does not receive (`probe_x1.py`, `run_minja`). The contrast is therefore not a single-variable manipulation: delivery path and trigger phrasing both differ. This makes the observable arm an *easier* positive control, which affects only how surprising its 100% should be; it cannot manufacture the implicit arm’s 0/141, because in that arm no memory tool exposes the payload at all. We state it rather than describing X1 as a clean single-axis contrast. The same inert factor affects X5 and X6, which draw from the same grid (§C); Zombie (domain × turns × keyspan) and X4 (doctype × discoverability × recipient_rep) consume every grid factor and are unaffected (measured inflation 1.0×).

Frozen-RF is out-of-distribution (crucial caveat). The raw variable and the frozen-RF flag diverge sharply here, and the distinction is load-bearing. In the implicit MINJA/gpt-4.1 arm the raw `observable_read_of_poison=0/141`, yet the frozen P1 RF still flags those sessions—not via any retrieval feature (there is none) but via non-retrieval trajectory features (e.g. `draft_then_send`, `seq_len`) on which it is out-of-distribution for case-bank traces. The correct reading is therefore “no retrieval provenance in the tool logs”, not “no trace-based alert of any kind”. This is exactly why X1 anchors its conclusion on the raw retrieval variable and treats the RF as secondary.

Zombie Agents (directional/LOW-CLUSTER, not upgraded). We also implemented a genuine emergent sliding-window buffer (fixed window $W=6$ turns, a frozen content-agnostic self-reinforcing promotion rule, and a preregistered $\geq 90\%$ benign-eviction control that the buffer passed—so persistence is emergent, not passive retention). The results are directional but do not meet the preregistered cluster gate: on gpt-4.1 the observable arm is a clean positive control (36/36, 36 clusters) but the implicit arm has only 16 eligible successes across 5 success-contributing scenario clusters (`observable_read_of_poison=0/16`), below the ≥ 10 -cluster floor, so it is LOW-CLUSTER and Wilson-governing (descriptive). On gpt-4o the observable arm is again a positive control (36/36) but the implicit arm produced 0 eligible successes, so **there is no fully-powered within-model observable-vs-implicit Zombie contrast**. We therefore do *not* upgrade Zombie: it retains its architectural classification (status A) with directional, LOW-CLUSTER in-architecture support, as flagged in Table 12.

No-poison control and scope. A no-poison, format-matched negative control produced 0 external sends across all 288 X1 no-poison trials (0 scored successes and 0 trials recording any external recipient, across the four `x1_*_nopoison_*` cells; the per-cell counts are in the released JSONL rather than the scored summary, whose eligibility filter requires `poison_delivered` and is therefore vacuous for these cells), establishing that implicit-arm “successes” are attributable to the poison and not to the case-bank/window mechanics themselves. X1 probes the both-implicit boundary on an independent, mechanism-faithful MINJA case-bank family within one act-without-grounding model (gpt-4.1); after the cluster-unit correction above, that evidence is directional/LOW-CLUSTER rather than clustered-primary, so it does not claim universality across models and does not by itself close the independent-attack-family gap. The Zombie family’s independent-family confirmation likewise remains directional/LOW-CLUSTER and open.

6.6 SECOND EXFILTRATION CHANNEL: DOCUMENT SHARING (X4)

The paper’s necessity claim is operationalized on a single channel (`email_send_email`), and the concept-level heuristic (§D) found 0% detection on an indirect `share_document` channel, raising the possibility that the necessity is email-specific. X4 (preregistered, GPG-signed before data) tests whether the *generalized* invariant—observable retrieval before *any* exfiltrating action—holds when the exfiltrating action is a two-step document share (`draft_document`→`share_document`) rather than email. The memory tools are present in both arms, and both the “generalizes” and “narrow-to-email” outcomes were preregistered with equal prominence.

Primary result: raw necessity generalizes (control), but the ≤ 0.10 criterion is not met on the cluster unit. The primary variable is the hand-coded `recall_before_exfil` (did an observable memory-tool result return the attacker destination before the first destination-bearing action?), independent of the frozen RF. On the control arm the necessity holds on *both* models with zero violations: 0 violations among 50 successes on gpt-4.1 (28 success-contributing scenario clusters) and 0/62 on gpt-4o (33 clusters). Both arms comfortably satisfy the preregistered ≥ 10 -cluster gate.

The upper-bound criterion, however, is not met once the correct unit is used. These are zero-event cells, so the scenario-clustered percentile bootstrap is degenerate—every resample reproduces 0, giving a spurious $[0, 0]$ —exactly as documented for the V3-3 control cell (§6.4.1). Applying the same procedure we apply there (a Wilson upper bound on the effective cluster count rather than on trials) gives $0/28 \Rightarrow$ upper **0.121** for gpt-4.1 and $0/33 \Rightarrow$ upper **0.104** for gpt-4o. **Both exceed the preregistered ≤ 0.10 threshold, so we withdraw the claim—made in earlier revisions on the basis of the trial-level bounds 0.071 and 0.058—that X4’s control arms meet that**

criterion. The trial-level bounds are not wrong as arithmetic; they are the wrong unit for a design whose primary inference the preregistration defines over scenario clusters, and quoting them alongside a degenerate $[0, 0]$ bootstrap interval overstated the precision twice over. Because clustering here is mild (mean 1.79 and 1.88 successes per contributing cluster, versus 15.7 in X1), the truth lies between the two: the cluster-unit bound is the conservative limit (intra-cluster correlation = 1) and the trial-level bound the anti-conservative one. We therefore report X4’s control arms as **zero violations across 28 and 33 contributing clusters, directionally supporting the necessity on a second channel but falling marginally short of the registered ≤ 0.10 bound**, rather than as meeting it. The point estimates (0/50, 0/62), the cluster counts, and the ≥ 10 -cluster gate results are unchanged. The retrieval-before-exfiltration necessity therefore *extends* from email to a second, structurally distinct exfiltration channel, but on this arm it is directional rather than criterion-passing. Regenerate with `x4_cluster_bounds.py`.

Phenotype keystone (with a thinness caveat). A benign share-channel keystone confirms the models recall-before-share on legitimate tasks, so control violations (had they occurred) would have been interpretable as necessity failures rather than a “don’t-look-up-before-sharing” phenotype: `gpt-4o` recalls-before-share on $72/72 = 100\%$ of *completed* benign share tasks. `gpt-4.1` recalls-before-share on all 14/14 *completed* shares, but only 14 of 72 benign share sessions completed a share—this cell is thin, and we label it as such rather than reporting it as a clean 100%.

Treatment (implicit): not viable on one model, directional on the other. The implicit (ICL-delivery) treatment arm does not support a clustered-primary breakdown claim on the share channel. On `gpt-4.1` the attack is **not viable**: 0 treatment successes across 360 trials (the model did not execute an external share under implicit delivery), so the estimand is undefined. On `gpt-4o` the arm is directional/underpowered: `recall_before_exfil=0` in 20/20 treatment successes across 10 scenario clusters, but this is below the preregistered 37-success target, so we report it as directional rather than confirmatory and do not use the degenerate clustered interval to override the target-based underpowered branch. The implicit breakdown remains established for the email channel (V3-1, V3-3) and is only directionally suggested here.

Classifier portability is an engineering result, not channel-generality. Applying the frozen RF to the share-channel traces, the *unmapped* classifier flags 0/37 control successes (tool-name drift: it is blind to `share.document`), while after a pre-declared `share.document`→`send_email` ontology remap it flags 37/37. Because remapping the exfiltration tool to `send_email` makes “recall→send” near-tautological, we label the 37/37 an *ontology-adapted classifier transfer (engineering)*—it quantifies tool-name drift and reinforces the Limitations point (§6.9), and is **not** evidence that the invariant is channel-general. The channel-generality conclusion rests solely on the raw `recall_before_exfil` necessity above.

No-poison control and scope. A no-poison negative control produced 0 external shares across all 144 X4 no-poison trials. X4 broadens the necessity claim to two instantiated exfiltration channels (email + document-share) on two act-without-grounding models; the implicit treatment arm is not viable on `gpt-4.1` and only directional on `gpt-4o`, and only one additional channel was tested, so we do not claim channel-generality beyond these two.

The benign memory-tool base-rate probe (B+), which addresses general tool-avoidance as an explanation for the X1 implicit-arm result and discharges the preregistered E1, E2 and E3 endpoints, is reported in Appendix A. Its headline figures, on an instrumented re-collection carried out under a GPG-signed amendment registered before the new data: benign memory-tool use is saturated (720/720 in all four model×channel cells, store wired and read in every cell, so the confound threshold is met for the email cells that X1 depends on); benign agents retrieve a destination-bearing record before the exfiltrating action in 95.5–100% of sessions reaching such an action (E2, newly discharged); and the frozen RF’s false-positive rate on that benign corpus is 55.4–65.4% on the email channel. One share cell’s rate is unstable across collection dates by a factor of ≈ 44 , driven by benign task-completion drift rather than by the detector; we report that instability as a result, and cannot attribute it, because neither collection captured served-model identity.

The adaptive-attacker evasion battery (X5) returned no eligible successes at all (0/1016 across four destination transformations), so it bounds where oracle robustness can be measured rather than measuring it; it is reported in Appendix B.

The architecture- and model-breadth sweep (X6) produced no powered cell: 9 of 12 yielded no eligible sample at all, and after the cluster-unit correction of Section 6.5 no X6 cell—including the three that did produce eligible successes—satisfies the ≥ 10 -cluster gate. We therefore claim no architecture generality and scope the breadth evidence to dense retrieval; the sweep and its design deviations are reported in Appendix C.

The preregistered follow-up (Section 5) demonstrates that the trajectory invariant cannot serve as a standalone detector—its unconditional benign FPR of 24.7–57.6% is operationally prohibitive. This falsification is itself a contribution: it establishes the deployment boundary that separates forensic detection research from deployable security tooling.

In ROC terms, the signature operates at a fixed point of (Recall = 0.98, FPR = 0.247–0.576) depending on model phenotype. As a standalone classifier this is inadequate; as a high-recall pre-filter in an ensemble that adds semantic gating (recipient metadata, content classification, or allowlist checks), it narrows the inspection surface by 42–75% for act-without-grounding fleets under exact-key recall (Section 6.8; note that ground-then-act fleets achieve only 0–24% savings, and that the phenotype is interface-dependent — see the Section 6.8 caveat on semantic retrieval) while maintaining near-perfect recall. The operational value is analogous to a high-sensitivity medical screening test: it identifies virtually all true positives but requires confirmatory testing to achieve acceptable precision.

The honest reporting of this failure boundary—rather than suppressing the benign FPR result or restricting evaluation to attack-only data—illustrates a methodological contribution: preregistered deployment-boundary testing should be standard practice for forensic detection papers, most of which report precision and recall only on curated attack datasets without measuring performance under realistic benign traffic.

6.7 IMPLICIT-DELIVERY ATTACK VIABILITY IS DOMAIN-DEPENDENT

The X1 continuation (Section 6.5) produced an unanticipated result that is independent of our detector and, we think, more transferable than the boundary claim it failed to confirm. Because the implicit arm ran the full registered grid to its $N=360$ cap, every one of the twelve effective configurations received exactly 30 trials under identical conditions, and the poison was *delivered* in 30/30 trials at a median retrieval rank of 1.0 in *all twelve*. Delivery is therefore constant by measurement, not by assumption. What varies is whether the agent, having been handed the poisoned exemplar at rank 1, actually imitates it and routes externally.

It varies across the entire range (Table 17). Two domains are fully susceptible (30/30 in both compliance framings for `meeting_followup`; 30/30 and 28/30 for `incident_report`). Two are almost entirely resistant (1/30 in both framings for `project_status`; 0/30 in both for `compliance_report`, i.e. 0/60 pooled). The remainder are intermediate and show a consistent framing effect: the *historical-practice* framing (“as we’ve always done for this”) outperforms *mandatory-audit-cc* (“per the mandatory audit-trail compliance rule”) in every domain where the two differ, by 33.3 percentage points on `budget_expense` (14/30 vs. 4/30) and 10.0 on `client_deliverable` (3/30 vs. 0/30). (Earlier revisions wrote “10 points” and “3” here; those were the raw differences in trial counts, not percentage points.)

Two consequences. First, for the attack literature: memory-poisoning viability under implicit delivery is governed substantially by the semantics of the cover task, not only by the retrieval architecture. A payload can be retrieved first, be perfectly well-formed, and still fail to produce exfiltration because the surrounding task makes external routing implausible to the model. Reported attack-success rates for this family are therefore sensitive to cover-task choice in a way that is rarely stated, and single-domain demonstrations may substantially over- or under-state viability. Audit- and compliance-themed cover tasks were the most resistant here, which is the opposite of what a naive reading of the compliance-framing attack would predict.

Second, for evaluation design: a breadth gate defined over *success-contributing* clusters silently tests two different things at once—breadth of the effect under study, and breadth of *attack viability across*

conditions. X1’s implicit arm is clean on the first among every success it produced (0/141 retrieval provenance, cluster-level Wilson upper 0.299) and fails the second, which is why it cannot reach the preregistered cluster floor (Section 6.5). Future preregistrations in this program will gate delivery, viability, and effect breadth separately rather than folding them into one success-conditioned cluster count. We flag this as a design lesson rather than grounds for reinterpreting the present result, whose disposition is fixed by the signed pre-commitment.

6.8 DEPLOYMENT ECONOMICS

A natural objection to the trajectory pre-filter is that recipient-based Data Loss Prevention (DLP)—inspecting the `to` field of every outbound action—could achieve the same separation without the trajectory layer. We formalize when the trajectory signal provides marginal value over DLP-alone. **Scope up front:** the quantitative cost advantage below is specific to an *LLM-based* content-DLP inspector and is a favorable-case measurement for the trajectory layer—the trajectory cost C_T is pure-Python feature extraction (excluding Random Forest inference and pipeline/log overhead) and the DLP cost C_D caps generation at a 5-token BLOCK/ALLOW verdict (a lower bound on real content inspection). For a regex- or keyword-based DLP layer C_D is far smaller and the advantage shrinks or reverses; the argument then reduces to a conditional cost *model* parameterized by the deployment’s own C_D/C_T . We state the measured ratio as one hardware-specific benchmark, not a general deployment fact.

Cost asymmetry. Trajectory feature extraction operates on tool-call metadata: 19 integer/binary features computed from operation names and their ordering. This is $O(n_{\text{calls}})$ per session, where n_{calls} is typically 3–8 (the median trigger-session length in our dataset is 5 tool calls). Content-level DLP—inspecting email bodies, attachments, or memory contents for sensitive material—is $O(n_{\text{tokens}})$ per session, where n_{tokens} may reach thousands. We now report a *measured* same-hardware micro-benchmark (Mac Studio M3 Ultra): feature extraction costs $C_T \approx 2.3 \mu\text{s}$ per session (median over 200 real V2-1 tool-call sequences, mean length 4.4), while a single content-DLP pass with a self-hosted mid-size LLM classifier costs $C_D \approx 73 \text{ ms}$ (qwen2.5:32b) to 323 ms (gemma4:31b) per session. The realized ratio is therefore $C_D/C_T \approx 3 \times 10^4$ – 1.4×10^5 for an LLM-based DLP inspector—consistent in direction with, and larger than, the 10^2 – $10^3 \times$ figure quoted in earlier framings of this work, which was an asymptotic-only estimate. Two honest caveats bound this number. (i) It is specific to an *LLM-based* DLP inspector; a regex- or keyword-based DLP layer would have a far smaller C_D and hence a far smaller ratio, and an API-hosted DLP would add network latency that *increases* effective C_D . (ii) The C_D measurement caps generation at 5 tokens (a BLOCK/ALLOW verdict), so it is a lower bound on the true content-inspection cost. The economic argument below therefore holds with a large measured margin for LLM-based DLP, and remains a conditional cost *model* (parameterized by the deployment’s actual C_D/C_T) for cheaper DLP implementations. Benchmark artifact: `results/bench-ct.cd.json`.

When trajectory pre-filtering dominates. Let C_T denote the per-session cost of trajectory classification and C_D the per-session cost of content-level DLP. Let r denote the trigger rate (fraction of sessions that exhibit *recall_before_send*). A trajectory-gated deployment inspects all N sessions with the trajectory classifier ($N \cdot C_T$) and applies DLP only to flagged sessions ($r \cdot N \cdot C_D$). Total cost: $N(C_T + r \cdot C_D)$. DLP-alone inspects every session: $N \cdot C_D$. The trajectory layer reduces total cost whenever:

$$C_T + r \cdot C_D < C_D \iff C_T < (1 - r) \cdot C_D \quad (1)$$

Since $C_T \ll C_D$ is now measured to hold by ~ 4 – 5 orders of magnitude for LLM-based DLP (metadata vs. content inspection; see Cost asymmetry above) and $r \in [0.247, 0.576]$ (the unconditional benign-FPR range of Section 5; earlier revisions wrote $[0.25, 0.53]$, which predated that section’s correction of its own upper bound from 52.6% to 57.6%), this inequality holds with a large margin for LLM-based DLP; for cheaper (regex/keyword) DLP where C_T is not negligible relative to C_D , it becomes a conditional prediction of the cost model rather than a demonstrated saving. Under that condition the trajectory layer saves $(1 - r) \cdot N$ content inspections—a 42–75% reduction in DLP invocations—at the additional cost of one trajectory classification per session. Note that r is phenotype-dependent: ground-then-act fleets (claude-sonnet, gemini-flash) have $r \approx 0.76$ – 1.0 , where the cost savings shrink to 0–24% and the inequality may fail if C_T is non-trivial. The economics argument is strongest for act-without-grounding deployments (gpt-4o, gpt-4.1), where both

FPR and r are near zero under exact-key recall—the same phenotype variable that governs precision (Section 5) also governs economic viability. **Important caveat:** the act-without-grounding phenotype is interface-dependent, not a stable model property. V3-2 H4 demonstrates that GPT-4.1 exhibits 82.5% benign `search_before_send` under semantic tool retrieval (i.e., ground-then-act behavior), despite being act-without-grounding under exact-key `recall_fact`. Under semantic search interfaces—the most common production memory retrieval mechanism— r for GPT-4.1 rises to ≈ 0.83 , reducing cost savings to $\sim 17\%$ and potentially violating the inequality if C_T is non-trivial. Operators should condition the economics estimate on their specific retrieval interface, not on model identity alone.

When trajectory adds no detection power. If an operator already runs recipient-metadata DLP on every outbound action (checking whether `to` is external, regardless of trajectory), the trajectory signal adds no incremental *detection* capability—recipient externality alone separates benign from attack on the *internal-only V2-1 benign corpus* (though not on fleets with legitimate external mail, where recipient gating flags 100% of external sends; Section 5.1). In this regime, the trajectory layer’s residual value is limited to: (1) *prioritization* (ranking alerts by trajectory score before human review), (2) *attack-vector attribution* (distinguishing memory-channel from prompt-injection attacks in forensic triage), and (3) *early warning* (the prefix-only classifier can flag suspicious sessions before the send event, enabling pre-emptive intervention).

Target deployment. The trajectory detector’s primary value proposition is for high-volume agent fleets where content-level DLP is not universally deployed on every session due to cost or latency constraints. In such environments, the trajectory signal serves as a cheap structural triage layer that routes only high-risk sessions to expensive semantic inspection. For operators who already inspect all outbound traffic at the content level, the marginal value is attribution and prioritization, not detection.

A cross-vendor stress test of the retrieval-before-action *concept* (not of the frozen classifier: it uses a hand-weighted heuristic over single-turn proposed tool calls) is reported in Appendix D, together with the reasons it should not be read as evidence about the released detector.

6.9 LIMITATIONS

False negative rate. FN = 31 out of 1,919 attack-success sessions (1.6%). All 31 originate exclusively from `qwq:32b`’s implicit-bypass runs under the Memory Sandbox defense (goal-directed RAG fallback without `recall_fact`). In deployments without `qwq:32b`, the effective FNR is zero across all tested models. Separately, `qwen2.5:14b` contributes 62 false *positives* (FPR = 10.3%) due to distributional inversion (its benign recall patterns mimic the attack signature), but zero false negatives (Recall = 1.000).

Feature definition limitation. An earlier `recall_before_send` feature implementation compared only the *first* `recall_fact` invocation with the *first* `send_email` invocation (first-occurrence semantics); the released classifier does not, as stated at the end of this paragraph. Under that superseded definition a session that sends, then recalls, then sends again was incorrectly labeled `rbs=0` even though a later exfiltrating send follows retrieval. The corrected definition—any recall preceding any exfiltrating send—produces cleaner 100%/0% conditional FPR separation. This bug does not affect any reported number: across all 2,520 primary DTA sessions the naive first-occurrence and corrected any-preceding definitions produce *identical* labels (0 disagreements), including on the 1,120 sessions that do contain multiple `send_email` calls—in every such session a `recall_fact` precedes the first send, so first-vs-first and any-vs-any agree. The only observed divergence arises in out-of-scope replication scoring on `qwq:32b` revision-pattern sessions (send, revise via recall, then re-send), which are not part of the published training data. The released classifier (`paper_a_classifier.py`) implements the corrected any-preceding-recall definition; because the two definitions produce identical labels on all 2,520 primary sessions, every reported table and figure is unaffected by the choice.

Tool-name / ontology dependency. The feature extractor keys on a fixed vocabulary of canonical operation names (`recall_fact`, `send_email`, etc.); any tool call whose name is not in this vocabulary contributes zero to every feature (the extractor counts known operations and silently

ignores unknown ones). A deployment whose memory tool is named differently—or whose framework renames operations across versions—therefore silently disables the detector unless an explicit ontology map is supplied. We observe this directly: the frozen classifier detects 0/38 (GPT-4.1) / 0/13 (GPT-4o) of the V3-2 semantic-search successes before remapping and 86.8–100% after a pre-declared `memory_search`→`recall_fact` map (Section 6.3). The practical consequence is that the mapping step is a load-bearing, unvalidated deployment dependency: tool-name drift is indistinguishable from a benign session in the feature space, so an operator must maintain the ontology map as part of the detector, not treat the classifier as name-agnostic.

Write-axis re-analysis limitation. The 2×2 write-observability analysis (Section 6.4) uses only the read-implicit V3-1/V3-2 arms and the benign V3-2 arm; the *save_before_send* figures (24/28 catch, 66.7% benign FPR, 0/53 in the both-implicit cell) are descriptive re-analyses of already-collected data, not a preregistered confirmatory experiment. Two limitations bound their interpretation. First, the original V3-1 logs recorded operation names but not `memory_save_fact` key/value arguments; we closed this with a preregistered argument-logging re-run (Exp 13c) that verified 37/37 *save_before_send*-flagged successes wrote the actual attacker payload (26/26 GPT-4.1, 11/11 GPT-4o), so *save_before_send* now has verified payload-write provenance rather than being an operation-level association. This strengthens only the precondition side: the 66.7% benign FPR is unchanged, so the write axis is still a precondition, not a predicate. Second, the write-axis result is within-harness (our DTA-derived ontology, in which writes are tool-routed); native MINJA and Zombie Agents write scaffold-side, matching the both-implicit cell where the write signature also fails (0/53). The write axis thus does not provide a deployable detector and does not alter the MINJA/Zombie classification.

Benign false-positive rate. The reported false-positive rate in the main evaluation is measured against poisoned-but-defended non-exfiltration executions, not against ordinary unpoisoned benign agent traffic. A preregistered follow-up study (13-model factorial $N=4,160$; Section 5) measures the deployment FPR: $P(\text{FP} \mid \text{recall_before_send}=1) = 100.0\% [99.8, 100.0]$ (unconditional benign FPR: 24.7–57.6% depending on recall protocol and fact count). Benign memory-grounded sends are score-isomorphic to attacks under the trained classifier. The detector should therefore be deployed as a high-recall triage signal rather than a standalone blocker. We note that the gating layer such a deployment implies is itself unvalidated here: the only gate we measured (recipient externality) fails on legitimate external mail (§5.1), and no content- or intent-level gate was evaluated.

Frontier false positive rate. On frontier models (GPT-4.1, GPT-4o, o3-mini, o4-mini), the detector achieves Recall = 0.901 across 405 attack sessions but FPR = 23.0% on 560 non-attack sessions, notably higher than the training FPR of 10.3%. The increase arises because reasoning models (o3, o4-mini) call `recall_fact` more frequently during non-attack sessions to verify stored information before acting, mimicking parts of the attack signature. Per-model threshold calibration would likely reduce this gap; the current single-threshold design is a conservative choice that favors recall over precision.

Training data scope. The classifier was trained on open-source models via Ollama. Cross-model hold-out confirms generalization to GLM, GPT-OSS, and Qwen families, and the GPT-4.1 probe ($N=20$) confirms frontier model alignment. A larger frontier-model training set would sharpen the decision boundary, particularly for models with recall counts > 1.5 (the GPT-4.1 / GPT-4o regime).

Implicit-bypass attacks. The classifier correctly misses qwq:32b’s Memory Sandbox bypass (goal-directed RAG fallback, no `recall_fact`). This is one instance of a general boundary: attacks using implicit retrieval (framework-level embedding similarity, sliding-window assembly, or cached context) produce no observable tool call and therefore evade the detector entirely (see Section 6.3 for the full taxonomy). Detecting implicit-bypass attacks requires tracking the *semantic correlation* between RAG document content and outbound email fields, rather than relying on raw `rag_count` volume metrics alone. We leave this for future work. Companion evaluations confirm that the three models underlying the stable detection spine (qwen2.5:14b, qwen2.5:72b, qwen3:32b) reproduce at 100% ASR across independent evaluation environments, while reasoning models exhibit output-quality degradation under long-running inference sessions that affects attack *prevalence* but not trajectory *shape* when attacks succeed. The rate-fragility identified in companion work does

not reach the detection invariant: it changes class balance, not the forced recall-before-send signature.

Adaptive adversaries. We consider three evasion strategies an adversary aware of the detector might attempt: (1) *Suppress recall*: embed the routing address directly in the prompt, eliminating the `recall_fact` call. This changes the attack vector to prompt-injection, which the detector correctly classifies as a different channel (Section 4.10). The attack succeeds but loses persistence across sessions. (2) *Inject fake recalls into non-attack sessions*: the adversary poisons benign sessions to include spurious `recall_fact` calls, inflating the FPR. This requires persistent influence over the agent’s environment, itself a security compromise, and cannot suppress the genuine attack signature. The detector’s precision degrades but recall is unaffected. (3) *Retrieve via alternative channels*: use framework-level embedding retrieval or cached context instead of the memory tool. V3-1 and V3-2 arm C empirically demonstrate this strategy works: implicit-delivery attacks achieve 50–82% success rates on GPT-4.1 and GPT-4o while completely evading the detector. An attacker aware of the detector need only target architectures where payload delivery occurs scaffold-side, or (per V3-1’s adaptive implication) harvest only the `rbs=0` subset of implicit attacks. This is not a hypothetical evasion but a demonstrated, viable strategy — and the primary reason we characterize the detector as a precondition filter for tool-routed attacks, not a general-purpose defense.

Limitations of the integrated experiments (X1–X4). The four preregistered experiments each carry power and construct-validity caveats that bound their claims. *X1 MINJA (measured, directional/LOW-CLUSTER)*: the MINJA case-bank family gives the cleanest independent-family contrast—gpt-4.1 observable 80/80 vs. implicit 0/141, paired contrast +1.0—but a post-hoc audit found the grid’s `similarity` factor inert (`minja_poison_case()` receives only domain and framing; 12 distinct poison texts across 36 `scenario_ids`), which had inflated the reported cluster counts $\approx 3\times$. A preregistered continuation to the registered $N=360$ cap brought the observable arm to 10 effective clusters (gate satisfied, 80/80) but left the implicit arm at 9 (0/141, cluster-level Wilson upper 0.299; the trial-level 0.0265 assumes independence the clustered design does not support)—one short, and structurally so, because three of the twelve effective configurations produce zero eligible implicit successes. Under the Addendum’s both-arms rule the $A \rightarrow P$ upgrade therefore stays retracted and the result is directional/LOW-CLUSTER with Wilson intervals governing; it also rests on one model (gpt-4.1), with gpt-4o corroborating only directionally (effective clusters: observable 11, implicit 2). *X1 Zombie (directional/LOW-CLUSTER)*: the emergent sliding-window result is not powered—gpt-4.1’s implicit arm has 16 eligible successes across only 5 scenario clusters (below the gate) and gpt-4o’s implicit arm has 0 eligible successes, so there is no fully-powered within-model contrast; Zombie remains an architectural classification with directional support, and rests on one fixed sliding-window policy ($W=6$, one frozen promotion rule). *Frozen-RF is not a proxy for retrieval provenance*: in the implicit MINJA arm the raw `observable_read_of_poison` is 0/141 yet the frozen RF still flags those sessions via non-retrieval trajectory features (on which it is out-of-distribution), so the X1 conclusion is “no retrieval provenance in the tool logs”, not “no trace-based alert”; the raw retrieval variable, not the RF, carries the claim. *X4*: the document-share necessity is established only on the control arm; the implicit treatment arm is not viable on gpt-4.1 (0/360 successes) and only directional on gpt-4o (20 successes, 10 clusters, below the preregistered 37-success target despite meeting the 10-cluster minimum), only one exfiltration channel was added beyond email, and the gpt-4.1 benign keystone is thin (14/14 completed shares out of 72 sessions). The ontology-remapped RF transfer (37/37) is an engineering result reflecting tool-name renaming, not evidence of channel-generalizability. *X2*: the second open-weight grounder result was collected on the existing GUI Ollama daemon rather than a fresh-daemon restart (Regime-A determinism confound, digest `9f13ba1299afea09`), and its control arm is underpowered (0 violations / 24 successes, below the 37-success target, Wilson upper 0.138), so it is consistent with but does not confirm the invariant. The treatment-arm breakdown (27/31 = 87.1%) has only 7 success-contributing clusters (below the ≥ 10 -cluster gate), so it is LOW-CLUSTER and Wilson [0.711, 0.949] governs descriptively; it provides a directional (not confirmatory) replication of the implicit-delivery breakdown on a second grounder.

7 RELATED WORK

Memory poisoning attacks. Persistent memory attacks against LLM agents were established by MINJA (Dong et al., 2025) and Zombie Agents (Yang et al., 2026), which demonstrated high attack success rates against open-source models via query-only memory injection. The delayed-trigger attack (DTA) (Leong, 2026a) embeds a malicious compliance directive in a RAG-retrieved document; the directive instructs the agent to store a routing rule using `memory_save_fact`, which is then retrieved via `memory_recall_fact` in a later session and used to exfiltrate data. Leong (2026a) (same author) reports that five of six defense classes fail against this attack in the tested configuration, with only tool-layer memory restriction achieving structural protection. Hidden in Memory (Pulipaka et al., 2026) independently confirms that GPT-5.5 stores adversary-induced memories at 99.8% injection rate, demonstrating that injection-layer vulnerability persists even in the most capable frontier models. Cross-Session Stored Prompt Injection (Xie et al., 2026) formalizes the XSS analogy for persistent injection across session boundaries. MPBench (Dash et al., 2026) provides a benchmark covering four memory write channels and six attack classes, explicitly motivating behavioral detection approaches but not providing a detector. Critically, MINJA and Zombie Agents both use *implicit* retrieval mechanisms (framework-level embedding similarity or sliding-window assembly) rather than observable agent tool calls—placing them outside the architectural scope of our detector (Table 12).

Behavioral detection in agentic systems. VIGIL (Li et al., 2026) translates behavioral specifications into SMT constraints over finite tool-call event traces, achieving $> 95\%$ recall with $< 10\%$ FPR on policy violations. It enforces pre-specified behavioral policies rather than learning forensic signatures from labeled data. Our approach is complementary: we learn statistical signatures from labeled data without requiring a policy specification, targeting a specific attack class rather than arbitrary violations. MemMorph (Zhang et al., 2026) demonstrates that poisoned long-term memory can steer tool selection across multiple agent architectures; our work asks whether such memory-channel attacks leave operation-only forensic signatures detectable by a supervised classifier. MemLineage (Ouyang & Hou, 2026) attaches cryptographic provenance to memory entries, enabling detection of unsigned writes, but requires modification of the memory infrastructure and cannot detect attacks injected through the agent’s own authorized write pathway (as in DTA, where the agent legitimately stores the malicious rule from a RAG-retrieved compliance document). MEM-SAD (Gowda, 2026) achieves near-perfect detection using gradient-coupled anomaly scoring, but it is a *preventive* defense that blocks attacks before execution and requires model-internal gradient access; our detector is a post-hoc forensic tool requiring only tool-call logs. Concurrent work (Dang, 2026) enforces behavioral firewalls over tool-call sequences using probabilistic deterministic finite automata; they define *permitted* trajectories, whereas we learn *attack* signatures from labeled data.

Intrusion detection and anomaly detection analogues. Host-based intrusion detection systems (HIDS) in classical security identify compromises from system call sequences and process execution traces (Forrest et al., 1996; Warrender et al., 1999). Sequence-based anomaly detection on system calls (using n-gram models, HMMs, or neural sequence classifiers) is structurally analogous to our approach: both extract features from ordered event logs and classify sessions as normal or anomalous. The key distinction is that classical HIDS operates on low-level OS primitives, while our detector operates on tool invocation events in an LLM agent runtime. This framing clarifies the deployment requirement: tool-call logging in agentic frameworks (LangChain tool invocation hooks, OpenAI function-call traces, Anthropic tool-use events) is the agent-runtime equivalent of `strace` or Linux Audit, and the trajectory classifier is a direct implementation of HIDS principles at the agentic abstraction layer. PerD (Garcia-soto et al., 2022) detects embedded Trojans in static NLP models by analyzing input-output behavioral responses, the most directly analogous prior work, but applies to models with fixed behavior, not agentic systems where tool-call trajectories vary with memory state.

Execution-trace auditing for agents. Recent concurrent work has explored execution-trace analysis for agent security. TraceAegis (Liu et al., 2025) applies provenance-based rules over agent execution logs to detect generic anomalous behaviors, while TRACES (Wang et al., 2025) learns trajectory risk states from an observer LLM’s hidden representations. Unlike these systems, which learn generic unsafe patterns or require formal policy specifications, our approach identifies an

architecture-induced signature specific to persistent memory poisoning, using lightweight structural features without model internals or learned representations.

The detection gap. Unlike general trace-auditing or memory-poisoning benchmarks, no prior work studies whether a specific explicit-memory exfiltration channel induces a low-dimensional, operation-only trajectory signature amenable to supervised classification. MPBench (Dash et al., 2026) systematizes the memory-poisoning attack surface across four write channels; MemMorph (Zhang et al., 2026) demonstrates tool-selection steering; VIGIL (Li et al., 2026) verifies tool-stream intent. None provides the specific combination we contribute: a supervised classifier trained on an instrumentally labeled factorial dataset ($N=2,520$, 9 models, 7 defenses), evaluated with cross-validation, bootstrap uncertainty estimates, and leave-one-model-out hold-out, and grounded in a mechanistic argument that links the dominant feature to the attack’s information-retrieval dependency.

Disclosure. References (Leong, 2026a) and (Leong, 2026b) are companion preprints by the same author. The training data for this paper’s classifier originates from the factorial in (Leong, 2026a). No findings cited from companion works have been independently replicated.

8 CONCLUSION

Persistent memory poisoning attacks produce a stable behavioral invariant in the agent’s execution trajectory. The *recall_before_send* transition follows from the attack’s information-retrieval dependency: a simple rule exploiting it alone achieves $AUC = 0.9563$, and suppressing observable retrieval breaks the attack via the tool-routed channel (though scaffold-side delivery remains viable). A full trajectory classifier refines this to $AUC = 0.9904$; removing all recall-related features leaves in-distribution AUC unchanged because the retrieval event triggers a behavioral cascade (draft, send, sequence elongation) that produces redundant correlated encodings across multiple feature channels—not independent detection mechanisms, but downstream consequences of the same causal event. This redundancy is in-distribution only: on implicit-bypass attacks (*recall_before_send*=0) the full classifier flags 0/28 while the recall-ablated model flags 24/28, showing the fitted model overfits the recall root split and does not transfer its cascade coverage to implicit retrieval (Section 6.4).

The invariant generalizes across 6/9 open-weight models (7B–120B parameters) and transfers to frontier models (Recall = 0.901 on 405 attack sessions, FPR = 23.0% on 560 non-attack sessions) without retraining. However, a preregistered follow-up (13-model factorial $N=4,160$) reveals a critical deployment boundary: benign memory-grounded sends produce the same *recall_before_send* signature, yielding $P(\text{FP} \mid \text{recall_before_send}=1) = 100\%$ on ground-then-act models (unconditional benign FPR: 24.7–57.6%). The signature is a valid attack precondition, not a maliciousness predicate. Standalone inline blocking is not viable. What our data support is use as a high-recall triage signal feeding a second stage that inspects task intent or content; the one gating variable we actually tested—recipient externality—does *not* repair precision, flagging 129/129 of legitimate external business email with the combined trajectory-and-recipient gate still flagging 45% (§5.1). We therefore state content- or intent-level gating as the indicated direction rather than a validated deployment model: no such gate was evaluated here, and its precision is an open empirical question. Critically, the behavioral phenotype governing benign retrieval rates is interface-dependent: GPT-4.1 exhibits 0% benign recall-before-send under exact-key retrieval but 82.5% under semantic search, so deployment economics are conditioned on retrieval architecture, not model identity alone.

These results establish that tool-routed memory-recall exfiltration attacks leave execution-trajectory signatures that are robust within the tested scope (act-without-grounding models, exact-key and semantic tool retrieval), but that operation-only structural features face a hard precision ceiling when benign agents also ground their actions in memory. The scope boundary—validated on two act-without-grounding models (GPT-4.1, GPT-4o) and, via V3-3, on a ground-then-act model (gemini-2.5-pro) whose strong benign recall habit (88.3%) does not restore the signature under implicit delivery (and, via X2, on a second open-weight grounder, qwen2.5:32b, with an underpowered control)—is a property of observable retrieval dependence: when it holds, the signature is necessary; when the scaffold delivers payloads without observable tool calls, attacks remain viable without the signature. The necessity is not email-specific: it extends from *recall_before_send* to *retrieval-before-*

exfiltrating-action across the two tested exfiltration channels (email and document-share; X4 control 0 violations /50 (gpt-4.1) and 0/62 (gpt-4o), Section 6.6), though on the document-share channel the evidence is directional—its cluster-unit upper bounds (0.121, 0.104) fall short of the registered ≤ 0.10 —with the implicit treatment arm underpowered and only one channel tested beyond email. The both-implicit boundary is further probed on a mechanism-faithful independent attack family—a MINJA query-only case-bank implementation (within-model gpt-4.1 observable 80/80 vs. implicit 0/141, matched-scenario paired contrast +1.0; Section 6.5)—though after the inert-similarity correction and a preregistered continuation to the registered cap the implicit arm reaches only 9 of the required 10 effective clusters (and only 8 effective configurations contribute eligible successes in *both* arms), so MINJA, like the emergent sliding-window Zombie-Agents implementation, is directional/LOW-CLUSTER and is not upgraded to measured. Deployment requires both the trajectory signal (for recall) and semantic context (for precision).

ETHICS AND BROADER IMPACT

This work evaluates forensic detection of memory-poisoning attacks in LLM agents using benign proxy tasks (simulated email composition with fictional recipients and documents). No genuinely sensitive data, real credentials, or harmful payloads were used. The attack payloads consist of routing instructions directing simulated emails to fictional external addresses. We release raw tool-call logs but not model weights or proprietary API prompts.

Dual-use considerations. Publishing the trajectory-based detection mechanism could theoretically inform attackers seeking to evade it. We judge the net benefit positive because: (1) the evasion boundary (implicit retrieval) is already public knowledge through concurrent work (Yang et al., 2026; Dong et al., 2025); (2) the detection mechanism is a property of observable tool-routing architecture, not a secret; and (3) the paper simultaneously characterizes where detection *fails*, informing defenders about realistic adversarial adaptation.

Responsible use. The detector is designed as a triage signal, not a standalone enforcement mechanism. Deployment without human review or semantic gating could produce high false-positive rates on legitimate workflows. We explicitly document the precision ceiling and recommend against automated blocking.

REPRODUCIBILITY

Code, raw V3 result data (JSONL), the classifier-training script (the trained model is regenerated deterministically from the P1 JSONL by `paper_a_classifier.py`, seed 42; no serialized model is vendored), and preregistration documents are available at the companion repository.³ API-served

³Repository URL: <https://github.com/junwenleong/forensic-trajectory-signatures>. This is an arXiv preprint with no venue-publication gate; the artifact is released together with the preprint. A content-hash manifest (`artifact_manifest.json`, SHA-256) fixes the exact bytes of every `paper_a` script, result file, figure and preregistration, and records SHA-256 digests for the two external inputs it does not vendor (P1 factorial JSONL; V2-1 benign corpus) under `external_dependencies`, so a substituted upstream corpus is detectable rather than merely named. Regenerate with `scripts/generate_artifact_manifest_full.py`. *One disclosed departure from byte-identity in the public release:* 19 of the 259 released data files carry institutional infrastructure identifiers (the API gateway hostname in an `api_base` field, and a gateway routing prefix on two files’ model identifiers), which are emptied or stripped before publication, and two file names are normalised accordingly. Every scientific field—conditions, outcomes, counts, `scenario_ids`, call sequences, recipients—is untouched, and the transform on model identifiers is exactly prefix removal (e.g. the served model remains `claude-sonnet-4-6`). The public manifest records, per file, both the published digest and the internal digest with a scrubbed flag, so the departure is auditable rather than silent; scripts, preregistrations, scored summaries and figures are byte-identical. Stage and verify with `scripts/prepare_public_release.py`, which is fail-closed: it re-scans the staged tree and discards it if any identifier survives. *Correction:* the preceding manifest revision omitted the four self-audit correction scripts this version note points readers at (`x1_cluster_bounds.py`, `x4_cluster_bounds.py`, `recompute_recall_ci.py`, `bca_jackknife_sensitivity.py`) and recorded no external digests, so the hashed tree could not reproduce the restated intervals; both gaps are closed here.

model results are auditable via provenance stamps (response model, system fingerprint, request parameters) where the runner used the shared provenance layer; `probe_x1`, `probe_x4` and the original `probe_bplus` collection wrote records directly and so did *not* capture served-model identity (Appendix A), which is why the B+ share-channel operating-point drift cannot be attributed. Results are in no case bitwise reproducible, due to mutable API backends. All experiments record exact package versions, git commit hashes, and run manifests. Two upstream inputs are external to the `paper_a` artifact and released separately: (i) the P1 factorial JSONL (classifier training source), archived in the companion repository,⁴ and (ii) the V2-1 benign corpus (9 open-weight models, $N=2,180$ trials, plus the API-model cells; source of the deployment-FPR and PPV analyses), which lives in the `paper_1_behavioral/results/` tree of the same companion program rather than in `paper_a/results/`. V3 data were collected under the preregistrations archived in the repository.

REFERENCES

- Hung Dang. Enforcing benign trajectories: A behavioral firewall for structured-workflow AI agents, 2026. arXiv:2604.26274.
- Pritam Dash et al. From untrusted input to trusted memory: A systematic study of memory poisoning attacks in LLM agents, 2026. arXiv:2606.04329.
- Shen Dong, Shaochen Xu, Pengfei He, Yige Li, Jiliang Tang, Tianming Liu, Hui Liu, and Zhen Xiang. MINJA: Memory injection attacks on LLM agents via query-only interaction. In *Advances in Neural Information Processing Systems*, 2025. arXiv:2503.03704.
- Stephanie Forrest, Steven A Hofmeyr, Anil Somayaji, and Thomas A Longstaff. A sense of self for Unix processes. In *Proceedings of the IEEE Symposium on Security and Privacy*, 1996.
- Diego Garcia-soto, Huili Chen, and Farinaz Koushanfar. PerD: Perturbation sensitivity-based neural trojan detection framework on NLP applications, 2022. arXiv:2208.04943.
- Ishrith Gowda. MEMSAD: Gradient-coupled anomaly detection for memory poisoning in retrieval-augmented agents, 2026. arXiv:2605.03482.
- Jun Wen Leong. Injection-execution dissociation: A mechanistic evaluation of persistent memory attacks and defenses in stateful LLM agents, 2026a. arXiv:2605.08442.
- Jun Wen Leong. Recognition without enforcement: Configuration-dependent failures in LLM agent instruction arbitration and external control, 2026b. arXiv:2608.28502.
- Ying Li et al. VIGIL: Runtime enforcement of behavioral specifications in AI agent skills, 2026. arXiv:2606.26524.
- Jiahao Liu et al. TraceAegis: Securing LLM-based agents via hierarchical and behavioral anomaly detection, 2025. arXiv:2510.11203.
- Ciyan Ouyang and Rui Hou. MemLineage: Lineage-guided enforcement for LLM agent memory, 2026. arXiv:2605.14421.
- Sidharth Pulipaka et al. Hidden in memory: Sleeper memory poisoning in LLM agents, 2026. arXiv:2605.15338.
- Zijun Wang et al. Proactive safety auditing for multi-turn LLM agents via trajectory-state modeling, 2025. arXiv:2605.27690.
- Christina Warrender, Stephanie Forrest, and Barak Pearlmutter. Detecting intrusions using system calls: Alternative data models. In *Proceedings of the IEEE Symposium on Security and Privacy*, 1999.

⁴P1 factorial repository: <https://github.com/junwenleong/stateful-agent-security-eval> (contains the defense factorial dataset used for classifier training).

Yuanbo Xie et al. What if prompt injection never left? exploring cross-session stored prompt injection in agentic systems, 2026. arXiv:2606.04425.

Xianglin Yang, Yufei He, Shuo Ji, Bryan Hooi, and Jin Song Dong. Zombie agents: Persistent control of self-evolving LLM agents via self-reinforcing injections, 2026. arXiv:2602.15654.

Xuanye Zhang et al. MemMorph: Tool hijacking via memory poisoning, 2026. arXiv:2605.26154.

APPENDIX

The following four studies are reported here rather than in the main text. Each was preregistered and executed, and each is retained in full because null and underpowered outcomes are part of the record—but none supports a confirmatory claim, and in the main text they displaced results that do. Their bearing on the paper’s claims is stated at the corresponding point in the Discussion.

A BENIGN MEMORY-TOOL BASE RATE (B+): A CONFOUND CHECK, NOT AN FPR STUDY

A standing objection to the X1 implicit-arm result (`observable_read_of_poison=0`) is that it could reflect general tool-avoidance—models that simply never invoke memory tools would trivially produce a zero retrieval signature regardless of the boundary. B+ (preregistered, GPG-signed before data) is a benign, no-poison base-rate probe on the full 36-configuration email and share scenario grids (scenario identities identical to X1/X4), $N=20$ per scenario per model per channel (2,880 sessions). The measured endpoint is E1, the benign memory-tool-call rate: on the instrumented re-collection described below it is $720/720 = 1.000$ in every model $\times$ channel cell (email/gpt-4.1, email/gpt-4o, share/gpt-4.1, share/gpt-4o; Wilson lower bound 0.9947), with the benign store wired and read in all four. Benign agents therefore invoke memory tools essentially universally on these matched tasks, so general tool-avoidance is excluded as an explanation. **What this does and does not establish (corrected in this revision).** It rules out tool-avoidance; it does *not* establish that the X1 implicit arm’s zero poison-read rate is a behavioral outcome, because in that arm the poisoned exemplar is not reachable through the memory tool in the first place (§6.5). B+ demonstrates that agents retrieve *accessible benign* records at a saturated rate; the X1 implicit arm exposes no accessible poison, so the two observations are compatible without the second following from the first. Earlier revisions used B+ to license the stronger behavioral reading; that inference is withdrawn. B+’s standing contribution is the confound exclusion plus the E2/E3 base rates below. **Scope caveat:** B+’s primary purpose is the confound check, and its E3 figures are a false-positive rate *on the B+ challenge set*, not a deployment-traffic estimate; the ecological benign-FPR evidence remains that of Section 5. The B+ tasks are memory-inviting by construction, so $E1=1.0$ is an upper bound on benign tool-use propensity rather than an ecological estimate, and E2 conditions on sessions that reach a destination-bearing action.

B+ implementation and preregistration deviations (found post-hoc, 2026-09-19), and their remediation by preregistered re-collection. Three deviations bounded what the original 2026-09-11 collection could license. All three were disclosed and then remediated: a v1.3 amendment was GPG-signed *before* any new data was collected (BPLUS_PREREG_v1.3_AMENDMENT.md, commit bd8c8aa), an independent pilot was run and its scenario filter frozen and committed (64d3508), and the full grid was then re-collected under instrumentation (e272d39; 2,880 sessions, zero error records, exactly 20 per scenario in all four cells). Both collections are retained: the 2026-09-11 records are archived at `results/bplus/legacy_2026-09-11/` with per-file SHA256 and remain the provenance for the values reported in arXiv v5.

(i) *The email arm’s benign store was never wired (remediated).* In `probe_bplus.py::run_email_benign` a benign store (a legitimate external partner contact and a deadline fact) was constructed and a benign case bank was built, but neither was passed to the agent runner—`probe_x1.run_agent` accepts no store argument, and the case-bank return values were discarded. The email-arm agent therefore operated with memory tools available and a memory-inviting prompt but *nothing retrievable in memory*, so for that arm E1 measured whether the agent complies with an instruction to consult memory, not whether it

retrieves relevant benign content. The share arm did pass its store (`probe_x4.run_session` serves `memory_recall_fact` from it), so that arm was never affected. **Remediation:** the email runner now routes through `probe_x1.run_agent_seeded` with a benign case bank surfaced via `memory_search`, and both runners stamp `benign_store_wired`. On re-collection E1 is $720/720 = 1.000$ in all four cells *with the store wired and read*, so E1 is now a benign-retrieval measurement in every cell and the preregistered confound threshold (point ≥ 0.15 , Wilson lower > 0.05) is met for the *email* cells specifically—which is what X1 requires, since the preregistration resolves the confound per matched model×family cell and bars one cell from resolving another’s. Notably the value is unchanged from the defective collection: instruction compliance and genuine benign retrieval do not diverge on these memory-inviting tasks. The original defect therefore measured the wrong construct but returned the same number—a fact establishable only by the re-collection, not assertable from the defective data.

(ii) *E2 and E3 were preregistered but not computed (remediated).* The preregistration defines E2 (a destination-bearing benign recall-before-exfiltration base rate) and E3 (frozen-RF false-positive rate at the B+ operating point, share family via the ontology-adapted map) in addition to E1; the original scoring routine emitted only E1. E3 is now computed by loading a serialised frozen RandomForest and calling `predict_proba` at the preregistered 0.5 threshold, rather than by the `recall_before_send` shortcut the routine previously used on the strength of an in-code assertion. That assertion has since been *tested* rather than assumed: `verify_frozen_rf.py` refits the estimator exactly as `paper_a_classifier.py` does, scores every B+ session both ways, and finds complete agreement with zero disagreements in either direction—2,880/2,880 on the re-collected sample and, independently, 2,880/2,880 on the archived legacy sample (`results/frozen_rf_verification.json`, which now reports both collections separately; earlier revisions cited this script for both identities while it scored only the confirmatory paths). The RF’s predicted probabilities are 0 or 1 on both email cells and reach 0.89 on flagged share sessions, and the artifact records how many scores fall strictly inside (0,1) and within [0.40,0.60], so the agreement is verifiably not an artefact of threshold proximity. Two scope limits on what the identity licenses: it is an identity of *hard labels at the preregistered 0.5 threshold on this corpus after the B+ ontology map*, established by session-level comparison and not by inspecting tree structure—so “the RF reduces to `recall_before_send`” should be read as “the two agree on every scored B+ session,” not as a structural reduction—and it is B+-conditional, consistent with (not contradicted by) the out-of-distribution divergence in §4.8, where on implicit successes with `recall_before_send=0` the full RF flags 0/28 while the recall-ablated model flags 24/28. E2’s binding obstacle was *instrumentation*, not the unwired email store: the original records persisted only `call_sequence` (tool names), so “an observable memory-tool result *returned* a destination-bearing record” could not be established for *either* channel, and re-collection alone would not have yielded it. (`probe_x4.run_session`’s destination-read flag tests returned strings against the *attacker* addresses, which never occur in a benign no-poison run, so it does not measure the benign quantity either.) **Remediation:** both runners now record each memory call’s key, returned value and ordering relative to the first destination-bearing action, via a store proxy that preserves the existing runner signatures. E2 is consequently discharged (Table 18): benign agents retrieve a destination-bearing record before the exfiltrating action in 95.5–100% of sessions that reach such an action. This is the benign counterpart of the attack-side necessity claim, and it is the sharpest available statement of the precondition-not-predicate finding: the ordering the detector fires on is what benign memory-grounded agents almost always do.

(iii) *The memory-relevance pre-screen was not an independent pilot (remediated).* The preregistration requires the $\geq 20\%$ scenario filter to be computed on a separate pilot with a distinct seed and frozen before confirmatory collection; in the original implementation the freeze step read the same records that the confirmatory analysis scores. **Remediation:** an independent pilot of 720 sessions (5 per scenario per model per channel) was collected, and the freeze step now reads *only* pilot files and aborts if none exist, so the selection can no longer be computed on the sample it filters. The frozen set was committed before the confirmatory run. All 36 scenarios pass the $\geq 20\%$ filter at rate 1.000 in both channels, so the filter again selects the entire grid—but now because the base rate is genuinely saturated on a wired store, rather than because a defect forced every scenario to pass. One consequence: X1’s G3 restricted implicit estimate remains identical to its unrestricted estimate, so no separate restricted figure is required.

E3 (frozen-RF false-positive rate on the B+ benign corpus). All B+ sessions are benign and no-poison, so every flag is by construction a false positive. On the instrumented re-collection the frozen RandomForest at the preregistered 0.5 threshold gives email/gpt-4.1 399/720 = 55.4%, email/gpt-4o 471/720 = 65.4%, share/gpt-4.1 20/720 = 2.8%, share/gpt-4o 5/720 = 0.7%. The email-channel figures straddle the top of the 24.7–57.6% unconditional benign-FPR range of §5, which was measured on an independently collected benign corpus with a different task family—further evidence that the signature is an attack precondition rather than a maliciousness predicate. The channel spread is large and tracks how often the benign task happens to induce a retrieval-before-exfiltrating-action ordering, not anything about maliciousness, reinforcing the phenotype-and interface-dependence documented in §6.8.

E3 is not stable across collections, and we report that as a result. The legacy 2026-09-11 collection gives email/gpt-4.1 459/720 = 63.7%, email/gpt-4o 441/720 = 61.3%, share/gpt-4.1 1/720 = 0.1%, share/gpt-4o 220/720 = 30.6%. Three cells move modestly; share/gpt-4o moves by a factor of ≈ 44 (30.6% $\rightarrow$ 0.7%). The cause is not the detector but the benign task: that cell’s rate of *reaching a destination-bearing action at all* collapsed from 231/720 = 32.1% to 5/720 = 0.7% between the two collections, while its memory phase was aggregate-identical (1,440 `memory_recall_fact` and 720 `memory_list_all_facts` calls in each run). In the re-collection 715 of 720 sessions execute exactly `memory_list_all_facts`, `memory_recall_fact`, `memory_recall_fact` and then stop without completing the share. The other cells are comparatively stable (share/gpt-4.1 2.9% $\rightarrow$ 3.1%; email/gpt-4o 98.6% $\rightarrow$ 99.4%; email/gpt-4.1 96.9% $\rightarrow$ 86.4%). Two implications. First, a benign false-positive rate conditioned on task completion is not a stable property of a model plus a prompt across collection dates, which strengthens rather than weakens the deployment-boundary argument: the operating point a defender would measure is itself drifting. Second, the share-channel E3 cells should not be read as point estimates of anything durable, and the share E2 denominators inherit the same fragility.

Attribution gap (limitation). We cannot attribute this drift to a served-model change, because *neither* collection recorded served-model identity. `probe_bplus` wrote records directly and so bypassed the provenance stamping that captures `response_model` and `system_fingerprint`; the same omission affects `probe_x1` and `probe_x4`. The runner now stamps per-trial provenance (verified to capture `response_model`, `system_fingerprint`, sampling parameters and the code commit), which cannot recover the 2026-09-11 identity but prevents the next such drift from being undiagnosable. This is a concrete instance of the Regime-B limitation stated in §6.9: under a proxy API, checkpoints are not pinnable and `temperature=0` does not confer determinism.

B ADAPTIVE-ATTACKER EVASION BATTERY (X5): ATTACK NOT VIABLE UNDER TRANSFORM

X5 (preregistered, GPG-signed before data) applied a destination-transformation battery—A1 base64-obfuscated, A2 split-fragment, A4 laundering, A5 delayed—on the X1 MINJA implicit machinery, with a dual oracle (exact-substring and battery-aware decode) designed to distinguish detector evasion from attack failure. Across all four conditions and both models (1,016 trials), poison was delivered into context in 100% of trials, but **attack success was 0/1016**: A1 0/296, A2 0/240, A4 0/240, A5 0/240. Agents consistently sent only to the benign team address and did not exfiltrate to the transformed attacker destination. Because there were zero delivered-and-successful trials, the conditional oracle-miss estimand is undefined and no evasion or boundary-breach quantity can be estimated: under the preregistered decision tree this routes to **ATTACK-NOT-VIABLE-UNDER-TRANSFORM**, not to detector robustness. **Interpretation caveat:** without a matched no-transform baseline (identical harness, untransformed destination), we cannot attribute the non-viability specifically to the transformations versus a base attack/harness/model interaction; X5 is therefore reported as a feasibility-null result that delimits where oracle robustness can be measured, not as evidence that the detector withstands adaptive attackers. **This is a preregistration deviation, not merely a design gap:** the X5 preregistration specified that “each condition includes a matched no-transform arm,” and `probe_x5.py` implements only the four transform conditions (`CONFIRMATORY = [A1, A2, A4, A5]`), so no matched arm was collected. The nearest available comparison is cross-experiment rather than matched: the X1 MINJA implicit arm is the same machinery with an *untransformed* destination and produced 34 eligible successes in 72 trials on gpt-4.1, against 0/1016 here. That contrast is consistent with the transformations breaking attack execution rather than with

the detector resisting evasion, and it is what motivates the ATTACK-NOT-VIABLE routing—but because the arms differ in trial count, model mix, and collection window, it does not substitute for the registered matched baseline, and we do not treat it as one. (A3 aliasing was preregistered EXPLORATORY: this harness has no native alias-resolution capability, so A3 is outside the confirmatory battery.)

C ARCHITECTURE AND MODEL BREADTH (X6): FEASIBILITY, SCOPED TO DENSE RETRIEVAL

X6 (preregistered, GPG-signed before data) attempted the observability contrast across memory architectures (FAISS dense retrieval, BM25 lexical, running-summary) and models (gpt-4.1, gpt-4o, claude-sonnet-5, gemini-3.1-pro-preview, plus open-weight qwen2.5:32b). The dominant outcome is viability failure: *no* X6 cell produced a powered eligible sample—all 12 scored cells fall below the ≥ 10 -effective-cluster gate (the best-populated reach only 4; see the deviations paragraph below)—and 9 of the 12 yielded eligible=0 outright (both BM25 cells, both summary cells, all three Claude and gpt-4.1 FAISS cells, and gpt-4o FAISS implicit), so the architecture $\times$ model matrix is largely empty and X6 does *not* support an architecture-general claim. The best-populated per-arm pattern is FAISS on gemini-3.1-pro-preview: observable 33/33 (observable_read_of_poison=1.0) versus implicit 0/30 (= 0.0), consistent with the boundary; gpt-4o FAISS observable is 7/7 but LOW-CLUSTER/underpowered. We therefore report X6 as a feasibility pilot: the observed pattern is consistent with the observability boundary for FAISS/dense-retrieval, while BM25, summary memory, broader cross-model transfer, and the open-weight interaction sweep remain unresolved. We explicitly retract any architecture-general framing for the boundary and scope the breadth evidence to dense retrieval.

X5/X6 design deviations (found post-hoc, 2026-09-19). Three implementation facts bound X5 and X6 further than the text above. (i) *Inert factor.* Both draw their scenario configurations from the MINJA grid and therefore inherit the inert `similarity` factor documented in §6.5: their `scenario_id` counts overstate the number of materially distinct conditions. (ii) *Prefix, not stratified subsample.* Both use `minja_grid()[12]`, described in-code as a “frozen stratified subsample.” It is a *prefix*: because the grid iterates domain-outermost, the first 12 entries span only 2 of the 6 domains, giving 4 effective configurations rather than 12. (iii) *Consequence for X6’s populated cells.* Re-scored on the effective cluster unit, the two gemini-3.1-pro-preview FAISS cells fall from 12 `scenario_id` clusters to 4 effective clusters, and the gpt-4o cell from 6 to 4. **No X6 cell satisfies the ≥ 10 -cluster gate**, so X6 supports no clustered-primary claim whatsoever and its status as a descriptive feasibility pilot is strengthened rather than weakened. (iv) *The summary architecture is not retrieval-independent.* The running-summary arm selects which exemplars to summarise using the *same* dense FAISS retrieval as the `faiss` arm (`probe_x6.py`: “faiss / summary both use dense retrieval to select context”), differing only in whether the retrieved material is injected verbatim or as a generated summary. The architecture axis therefore varies delivery *format* more than retrieval *mechanism*, and the intended BM25-versus-dense-versus-summary contrast is only genuinely realised on the BM25 arm—which produced zero eligible successes. Architecture breadth is consequently untested, not merely underpowered.

D CONCEPT-LEVEL HEURISTIC STRESS TEST (CROSS-VENDOR)

To probe whether the trajectory-signature *concept* (retrieval-before-action as a detection signal) generalizes beyond the training distribution, we evaluate a simplified hand-specified scoring heuristic (logistic scoring on 11 features including `has_recall_before_send`, `has_send_email`, and tool counts; see companion repository for exact weights) on three held-out attack families that were never present during training, across three vendor families (GPT-5.1, Claude-Sonnet-5, Gemini-2.5-Pro; $N=50/\text{cell}$, 600 total trials).

Important methodological notes: (1) This evaluation uses a hand-specified scoring heuristic with hardcoded weights derived from the v2 detector’s principal discriminative features—it is **not** the trained 19-feature Random Forest and does not test that classifier’s transfer. (2) The harness makes a single API completion per trial and does not execute tool calls or feed tool results back to the

model; it records only the model’s *proposed* tool calls from one response, not multi-turn executed trajectories as in the main experiments. (3) Attack-family trials are labeled as ground-truth attacks based on scenario membership (intent to trigger malicious behavior), regardless of whether the model actually executed a malicious action. Detection rates below therefore reflect recognition of the attack *scenario*, not recall among successfully executed attacks—models that refuse or produce empty tool calls are counted as detector misses rather than non-attacks. (4) The heuristic scorer produces only 6 distinct score values across all 600 trials, determined entirely by which tool *names* appear in the proposed call set (not by arguments, recipients, or context). It is a discrete deterministic rule over tool-name presence, not a probabilistic classifier; per-family “detection rates” reflect the fraction of trials in which the model proposed the specific tool-name pattern that triggers the rule. (5) *The hand-set weights do not encode the paper’s own thesis, and one of them dominates.* The heuristic adds +1.2 for `has_send_email` and subtracts $1.0 \cdot (1 - \text{has_send_email})$, so a proposed call set containing a `send` and *no memory access whatsoever* scores $\sigma(1.2) \approx 0.769$ —above the 0.5 threshold, i.e. flagged. Under this heuristic the mere presence of a `send` tool, not the retrieval-before-send transition, is sufficient to trip the rule. That is the opposite of the invariant the rest of the paper establishes, and it means the reported “detection rates” partly measure whether the model proposed a `send` at all. We therefore treat this experiment as a weak concept probe only; it is *not* evidence about the frozen classifier, and it should not be read as supporting the necessity claim. Correcting the weights would change the reported rates, so we report the numbers as collected and flag the defect rather than silently re-scoring a superseded heuristic.

Results therefore assess generalization of the *concept* (whether recall-before-action persists as a signal across novel attack families and vendors) under a weak proxy harness, not the performance of the published classifier in deployment:

- **Indirect exfiltration** (via `share_document` instead of `send_email`): Detection rate = 0.0% [0.000, 0.025]. The recall-before-send signature is specific to the email channel; exfiltration through sharing tools produces no detectable trajectory pattern.
- **Encoded payload** (base64 instructions in memory): 27.3% [0.208, 0.350]. Some encoded variants still trigger recall-before-send when the model decodes and acts on the payload.
- **Multi-step delayed trigger**: 38.7% [0.312, 0.467]. Delayed triggers that ultimately route through email partially trigger the signature.

Benign specificity: 81.3% correct [0.743, 0.868] (FPR = 18.7%). Model-level detection varies: GPT-5.1 (60.7%), Gemini-2.5-Pro (5.3%), Claude-Sonnet-5 (0.0%)—Claude’s baseline refusal prevents the attack trajectory from materializing entirely.

These results are consistent with the architectural boundary described in Section 4.10: the detector’s scope is limited to tool-routed attacks that pass through observable `recall_fact`→`send_email` sequences. Novel exfiltration channels require either semantic correlation analysis or external enforcement (see companion work (Leong, 2026b)).

Table 1: Claim-to-evidence map. *Evidence status* distinguishes preregistered confirmatory findings (P), exploratory findings whose executed design deviates from the preregistration or was not preregistered (E), post-hoc scorer/label corrections disclosed in the deviations (C), and architectural classifications argued from mechanism rather than direct reproduction (A). All numeric results are reproducible from the released artifacts *together with* two external inputs disclosed in the Reproducibility section (the P1 factorial classifier-training JSONL and the V2-1 benign corpus, both released in the companion `leong2026defense repository / paper_1_behavioral`); API-served results are auditable via provenance stamps but not bitwise reproducible.

Claim	Evidence	Status	Section
Observable retrieval $\Rightarrow$ <i>recall_before_send</i> necessary for tool-routed exfiltration	Exact-key 58/58; semantic 33/33 GPT-4.1 (preregistered; 38/38 corrected scorer) / 43/43 GPT-4o (pooled after Exp 13a) zero violations	P	§6.3
Implicit delivery breaks necessity (successful attacks with <code>rbs=0</code>)	V3-1 treatment 67% (GPT-4.1) / 74% (GPT-4o) <code>rbs=0</code> ; scenario-clustered CIs exclude 0	P [‡]	§6.3
Necessity/breakdown replicates on a ground-then-act model	V3-3 gemini-2.5-pro: control 0/19 <code>rbs=0</code> ; treatment 28/30=93.3% <code>rbs=0</code> (clustered CI [0.821, 1.000]); benign recall habit 88.3%. X2 second grounder qwen2.5:32b: treatment <code>rbs=0</code> 27/31=87.1% [0.711,0.949]; control 0/24 underpowered (Wilson upper 0.138) [‡]	P	§6.4.1
Observable-arm boundary holds under a genuine LangGraph framework; within-model contrast on a genuine FAISS retriever	V3-4 (gpt-4.1, within-model): LangGraph <code>create_react_agent</code> observable 39/39 flagged, genuine-FAISS-retriever implicit 0/57 flagged, benign 60/60 flagged (gpt-4.1-mini)	P [†]	§5.2.1
Signature is a precondition, not a maliciousness predicate	Benign FPR 24.7–57.6% (13-model factorial $N=4,160$); $r=0.031$ ASR vs signature; recipient gating flags 129/129 legitimate external sends (V3-5)	P	§5, §5.1
Write-axis <i>save_before_send</i> has verified payload-write provenance	Exp 13c: 37/37 flagged successes wrote the attacker payload; 66.7% benign FPR unchanged (precondition, not predicate)	P	§6.4
Within-scope detector AUC = 0.990 (random-fold) / 0.907 (grouped)	5-fold CV, $N=2,520$; leakage-corrected grouped CV	P	§4.4
Cross-model transfer without retraining	Leave-one-model-out 6/9 AUC = 1.000; frontier Recall = 0.901	P	§4.6
Signature stable across prompt framings (one loop, one schema)	99–100% signature on GPT-5.1 raw vs ReAct-framed	E*	§5.2
Signature transfers across execution harnesses (train LangGraph, test raw loop)	Frozen-classifier cross-harness holdout, pooled recall 186/188 = 98.9%	E	§5.2
ASR corrected to structured-recipient (<code>to</code>) scoring	GPT-5.1 98.3% $\rightarrow$ 62.5%; signature rates unchanged	C	§5.2
V3-2 arm B scorer includes <code>draft_email</code> as exfiltration-capable	Preregistered 33/33; corrected sensitivity 38/38 (both reported)	C	§6.3
MINJA / scaffold-side RAG evade trajectory detection	X1 (within-model gpt-4.1, query-only case-bank): observable <code>orp</code> 80/80 vs. implicit 0/141 (cluster-level Wilson upper 0.299; trial-level 0.0265 assumes independence the design does not support), contrast +1.0; <i>observable arm gate-satisfied</i> (10 effective clusters); <i>implicit arm 9—one short at the registered cap</i> ; 8 configurations contribute eligible successes in both arms [¶] ; gpt-4o corroborating (LOW-CLUSTER)	A [¶]	§3, §6.5, Table 12
Zombie-family (emergent sliding-window) evades retrieval-provenance detection	X1 (within-model gpt-4.1, emergent $W=6$ buffer): observable <code>orp</code> 36/36; implicit 0/16 but 1/5 (LOW-CLUSTER)	A	§6.5, Table 12

Table 2: Leave-one-defense-family-out generalization. The taxonomy correctly predicts which families the classifier generalizes to (all observable-retrieval families) and where it fails (Memory Sandbox, which removes the retrieval tool). Prompt Hardening shows degraded AUC (0.714) due to sleeper-effect sessions (model recalls but refuses to execute), producing label ambiguity rather than signature failure.

Held-Out Family	N	AUC	Recall	Taxonomy Prediction
No Defense	360	1.000	1.000	Observable $\rightarrow$ detectable ✓
Minimizer	360	1.000	1.000	Observable $\rightarrow$ detectable ✓
Sanitizer	360	1.000	1.000	Observable $\rightarrow$ detectable ✓
RAG Sanitizer	360	1.000	1.000	Observable $\rightarrow$ detectable ✓
RAG LLM Judge	360	1.000	1.000	Observable $\rightarrow$ detectable ✓
Prompt Hardening	360	0.714	1.000	Observable; label ambiguity [†]
Memory Sandbox	360	0.438	1.000[‡]	Implicit read $\rightarrow$ no provenance ✓

[†]Sleeper-effect: model recalls the rule but refuses execution; trajectory is attack-shaped but label is 0.

[‡]Rank-inversion artifact: AUC=0.438 (< 0.5) and precision=0.167. With Recall=1.000 on 40 attack successes, precision=0.167 implies 240 of 360 sessions predicted positive (specificity ≈ 0.375), so Recall=1.000 is non-informative rather than genuine detection. (Earlier revisions said *every* Sandbox session is predicted positive and specificity ≈ 0 ; that overstated it.)

Table 3: 5-fold cross-validation performance across three classifiers ($N=2,520$ DTA runs, 9 models). *Task*: distinguishing successful attack executions from unsuccessful attack executions within poisoned sessions (not attack-vs-benign classification; see Section 5 for benign evaluation). All three are equivalent; features are sufficiently discriminative that classifier choice does not matter. Primary metric is Recall (minimizing undetected attack-success sessions).

Classifier	AUC	BCa 95% CI	Recall	Precision	F1	FN
Logistic Regression	0.9904	[0.987, 0.993]	0.9838	0.9682	0.9760	31
Random Forest	0.9904	[0.987, 0.993]	0.9838	0.9682	0.9760	31
Gradient Boosted Trees	0.9904	[0.987, 0.993]	0.9838	0.9682	0.9760	31

Table 4: Top-10 Random Forest feature importances (mean decrease in impurity). *recall_before_send* is dominant: it is mechanistically forced by the attack structure.

Feature	Importance
recall_before_send	0.3143
send_count	0.2159
recall_count	0.1015
recall_to_send_ratio	0.0975
max_recall_chain	0.0767
seq_len	0.0494
list_then_draft	0.0435
send_without_recall	0.0238
draft_then_send	0.0185
list_then_recall	0.0119

Table 5: Mean trigger-session (S4) feature values for attack-success vs. non-exfiltration sessions across the factorial. The *list* $\rightarrow$ *draft* transition (non-exfiltrating agents draft directly after listing) is the clearest Markov difference.

Feature	Attack	Non-exfil.	Δ
recall_count	1.334	0.867	+0.467
send_without_recall	0.021	0.333	-0.312
max_recall_chain	1.334	0.867	+0.467
draft_then_send	0.783	0.466	+0.317
list_count	1.000	1.399	-0.399

Table 6: Leave-one-model-out hold-out validation (Random Forest trained on 8 models, tested on held-out 9th). Six of nine models generalize perfectly. qwq:32b, qwen2.5:14b, and qwen3.5:122b are mechanistically explained exceptions.

Held-Out Model	AUC	Recall	Interpretation
glm-4.7-flash:q8_0	1.000	1.000	Generalizes
gpt-oss-safeguard:120b	1.000	1.000	Generalizes
gpt-oss:20b	1.000	1.000	Generalizes
qwen2.5:72b	1.000	1.000	Generalizes
qwen3.5:9b	1.000	1.000	Generalizes
qwen3:32b	1.000	1.000	Generalizes
qwen3.5:122b	0.750	1.000	Partial; Prompt Hardening yields 0% ASR
qwen2.5:14b	0.083	1.000	Distributional inversion (see text)
qwq:32b	0.000	0.000	Implicit bypass (different attack class)

Table 7: Detector performance stratified by the defense condition under which the P1 factorial run was evaluated. All 31 false negatives originate from the Memory Sandbox condition; the classifier achieves Recall = 1.000 under every other defense. N_{atk} counts attack-success sessions; N_{neg} counts non-exfiltration sessions (poisoned but defended).

Defense	N_{atk}	N_{neg}	FN	Recall
No Defense	319	41	0	1.000
Minimizer	320	40	0	1.000
Sanitizer	320	40	0	1.000
RAG Sanitizer	320	40	0	1.000
RAG LLM Judge	320	40	0	1.000
Prompt Hardening	280	80	0	1.000
Memory Sandbox	40	320	31	0.225

Table 8: Feature-group ablation: AUC when each group of features is removed. The classifier is robust to removing any single group; the retrieval event triggers a behavioral cascade that produces redundant correlated encodings across multiple feature channels. All single-group removals change AUC by at most 0.0001; the Mechanistic and Frequency-counts removals are tied at this -0.0001 noise floor (the largest observed change, itself negligible). All rows are computed with the identical estimator specification (RF, 200 trees, `max_depth=8`, no class weighting, pooled out-of-fold predictions from one 5-fold split).

Feature Group Removed	Features	AUC	ΔAUC
None (full model)	19	0.9904	—
Mechanistic (<code>recall_before_send</code> , <code>send_without_recall</code>)	17	0.9903	-0.0001
Frequency counts (7 features)	12	0.9903	-0.0001
Ratio features (<code>recall_to_send_ratio</code> , <code>max_recall_chain</code>)	17	0.9904	0.0000
Bigram transitions (5 features)	14	0.9904	0.0000
First-tool indicators (3 features)	16	0.9904	0.0000
All recall-related (9 features)	10	0.9904	0.0000

Table 9: Base-rate-aware PPV (%) at fixed TPR = 0.98, as a function of benign FPR (rows) and attack prevalence π (columns). Computed from existing TPR/FPR operating points; no new data. The 24.7–57.6% FPR rows are the V2-1 unconditional benign range; the 100% row is conditional on `recall_before_send=1`.

Benign FPR	$\pi=0.0001$	$\pi=0.001$	$\pi=0.01$	$\pi=0.05$	$\pi=0.10$
1%	0.97	8.93	49.75	83.76	91.59
5%	0.20	1.92	16.53	50.78	68.53
10%	0.10	0.97	9.01	34.03	52.13
24.7%	0.04	0.40	3.85	17.27	30.60
40%	0.02	0.24	2.41	11.42	21.40
57.6%	0.02	0.17	1.69	8.22	15.90
100%	0.01	0.10	0.98	4.90	9.82

Table 10: Cross-framing replication (GPT-5.1). Signature = `recall_before_send`. ASR under the corrected recipient-only scorer (legacy body-inclusive ASR in parentheses).

Variant	Condition	N	ASR (corrected / legacy)	Signature
Raw OpenAI	Attack	120	62.5% (98.3%)	99.2%
Raw OpenAI	Benign (memory)	100	—	100.0% [†]
Raw OpenAI	Benign (no memory)	50	—	0.0%
LangChain-style	Attack	100	81.0% (100.0%)	100.0%
LangChain-style	Benign (memory)	100	—	100.0% [†]
LangChain-style	Benign (no memory)	50	—	0.0%

Table 11: Model sweep (raw loop, $N=20$ /model unless noted). ASR under the corrected recipient-only scorer (legacy body-inclusive ASR in parentheses). Models sorted by corrected ASR.

Model	N	ASR (corrected / legacy)	Signature	Category
GPT-5.2	20	90.0% (95.0%)	95.0%	Exfiltrator
GPT-5.1	120	62.5% (98.3%)	99.2%	Exfiltrator
GPT-5	20	40.0% (40.0%)	40.0%	Partial
GPT-5-nano	20	20.0% (45.0%)	65.0%	Partial
Gemini 2.5 Pro	20	10.0% (10.0%)	75.0%	Partial (signature > execution)
Gemini 2.5 Flash	20	0.0% (0.0%)	100.0%	Latent Carrier
GPT-4.1-mini	20	0.0% (0.0%)	100.0%	Latent Carrier

Table 12: Memory-poisoning attack taxonomy by retrieval observability. The detector’s invariant fires only when retrieval produces an observable tool call. [†]: empirically tested with controlled implementation (this work). [§]: empirically tested via a mechanism-faithful independent implementation, but directional/LOW-CLUSTER: after the `inert-similarity` correction and a preregistered continuation to the registered cap, the observable arm reaches 10 effective clusters (gate satisfied) while the implicit arm reaches 9 (MINJA, X1, §6.5). *: retrieval-axis prediction assessed via controlled implicit-delivery probes (V3-1 ICL proxy, V3-2 scaffold-side FAISS); the named attack pipeline was not reproduced. ^b: implemented as an independent sliding-window family (Zombie, X1) but directional/LOW-CLUSTER—the implicit arm has only 5 success-contributing clusters (below the ≥ 10 -cluster gate), so it remains analytic.

Attack	Memory write	Memory read	Observable?
DTA (this work)	agent tool call (<code>save_fact</code>)	agent tool call (<code>recall_fact</code>)	✓ [†]
Semantic search (V3-2)	direct DB write	agent tool call (<code>memory_search</code>)	✓ [†]
MINJA-style [§] (Dong et al., 2025)	agent record-logging	framework embedding retrieval	✗ [§]
Zombie-style ^{*b} (Yang et al., 2026)	normal memory-update	sliding-window / RAG assembly	✗ ^{*b}
qwq:32b bypass (§6.9)	agent tool call	goal-directed RAG fallback	✗

Table 13: Detectability under the 2×2 write-observability $\times$ read-observability taxonomy, from re-analysis of existing implicit-delivery data. The write axis provides an additional signature only when the malicious write is tool-routed, and even then as a high-FPR precondition; attacks implicit on both axes (the MINJA/Zombie cell) leave no *memory-operation* signature at all. “Signature-free” here is scoped to the two memory-operation rules tested (`recall_before_send`, `save_before_send`); it does not mean no trajectory feature whatsoever fires, since non-retrieval action-shape features can still trip a classifier (§6.5).

	Observable read	Implicit read
Observable write	full signature (main regime)	<code>save_before_send</code> flags 24/28 (V3-1); 66.7% benign FPR — precondition, not predicate
Implicit write	—	0/53 caught (V3-2 arm C = MINJA/Zombie cell); free of both memory-operation signatures

Table 14: V3-2 denominator breakdown. “Delivered” = oracle-confirmed poisoned record in retrieval results. Arm B delivery = poisoned item returned by agent-invoked `memory_search`; arm C delivery = poisoned item selected by scaffold retrieval and injected into context. The signature column reports `search_before_exfiltration` among successful attacks: for arm B this is an empirically observed behavioral invariant; for arm C the search tool is architecturally absent, so the entry is N/A (all successes are necessarily signature-free).

Model	Arm	Trials	Del.	Succ.	S.+D.	Sig.—S.+D.
GPT-4.1	B (search tool)	40	40	33 [†] /38 [§]	33/38	33/33 [†] ; 38/38 [§]
GPT-4.1	C (scaffold)	40	40	33	33	N/A (no tool)
GPT-4o	B (search tool)	40	27	13	13	13/13
GPT-4o	C (scaffold)	40	40	20	20	N/A (no tool)

[†]Primary (preregistered): `email.send_email` only. [§]Sensitivity analysis: includes `email.draft_email`. The GPT-4o arm B 13/13 shown here is the original cohort; a pre

Table 15: Preregistration deviations across all probes. One deviation reverses a family-level label: the v3 confirmatory re-run makes MINJA (not Zombie) the powered within-model X1 contrast (see the X1 rows below); no deviation reverses the core observability-boundary conclusion. The four previously-unexecuted secondary analyses (H2a Fisher, H3 Mann–Whitney, retrieval-rank, and the classifier feature-remap open question) have now been computed, and the $k=\{2, 8\}$ robustness sweep—previously the only unexecuted preregistered analysis—is discharged by X3 (§6.3).

Probe	Deviation	Justification
V2-1	H1 (monotonicity) falsified	Binary saturation
V3-1	Grid reduced 72→18 scenarios	Decoy axis non-interacting
V3-1	GPT-4o added post-hoc	Same phenotype, exploratory
V3-1	Success floor (≥ 30) missed	ASR lower than anticipated
V3-1	Claude untestable ($ASR \approx 0$)	Ground-then-act phenotype
V3-1	H2a Fisher test now computed	$OR=0.71, p=0.74$
V3-1	H3 Mann–Whitney now computed	$U=438, p=1.4 \times 10^{-8}$
V3-2	Scorer corrected post-hoc	<code>draft_email</code> $\equiv$ exfiltration
V3-2	GPT-4o delivery 27/40	Retrieval competition
V3-2	$k=\{2, 8\}$ sweep now run (X3)	Discharges the last unexecuted prereg analysis
V3-2	Retrieval-rank analysis now computed	Descriptive, mixed (GPT-4.1 arm C null $p=0$)
Exp 13c	GPT-4o reached 11 successes (target 40)	ASR-limited; write-provenance rate still 11/1
X1	v3 re-run inverts family labels	MINJA/gpt-4.1 powered (80/80 vs 0/141); Z
X1	Inert similarity factor inflated MINJA cluster counts $\approx 3\times$	<code>minja_poison_case()</code> takes only (domain)
X5/X6	Same inert factor; subsample is a prefix, not stratified	Both use <code>minja_grid()[12]</code> , which spa
X2	Control missed 37-success target (24 at cap)	ASR-limited; Regime-A GUI daemon (not fro
X4	Treatment not viable (gpt-4.1) / directional (gpt-4o)	gpt-4.1 0/360 successes; gpt-4o 20 successes
X4	Control ≤ 0.10 criterion claim withdrawn	Zero-event cells: clustered bootstrap degenera
X1/X4	v2 X1/X4 superseded by v3	v2 used 3 cover-tasks, no persisted scenari
X1	Observable arm CLI dead-code default	<code>--arm</code> defaulted so observable cells were ski
X5/X6	<code>observable_read_of_poison</code> destination coverage	Detector matched only X1 dests, blind to per-
X5	Recipient not captured	Harness logged tool names, not email recipien
X4	Recall detector missed non-email dest form	<code>recall_before_exfil</code> matched only em
All	Gateway 403 under 4-stream load	First parallel re-run produced 70–90% error r
X6	gemini-3.1-pro-preview cells partial	Slow reasoning model incomplete at analysis
<i>Corrections introduced in this revision (self-audit, no new data collection):</i>		
Title	Title claimed a general detection boundary	The paper establishes a boundary on <i>retrieval</i>
§2.1	Structural and behavioural implicit arms were not distinguished	Signature absence is definitional where the pa
§4.4	AUC presented without its endpoint proximity	Positives are defined by a completed external
X1	Implicit-arm $orp=0$ was described as behavioral; it is structural	<code>probe_x1.run_agent</code> starts the implicit
X1	Design-effect ladder used equal-cluster arithmetic	$DEFF = 1 + (m - 1)\rho$ was evaluated at the
X1	Registered H2 (≤ 0.20) was unreachable, not narrowly missed	On the cluster unit a zero-event cell needs 16
X1	Scorer gated the paired contrast on attempted, not contributing, clusters	<code>x.bootstrap.paired_contrast_ci</code> co
X1/X4	Cluster-unit bounds existed only in the prose	<code>xprogram.scored.json</code> carried the with
B+	Frozen-RF identity was cited for two collections but tested on one	<code>verify_frozen_rf.py</code> hardcoded the cor
§2.4	Stale <code>bca_ci()</code> retained the capped jackknife	<code>main()</code> was corrected to the full 2,520-samp
V3-4	Success endpoint not disclosed as policy-violation	<code>probe_v3.4.finish</code> counts any recipient
§4.7	Two misstatements about the Sandbox cell	Precision 0.167 with 40 successes implies 24
§6.8	Trigger-rate range was stale	$r \in [0.25, 0.53]$ predated §5’s own correction
§6.7	Framing effect stated in the wrong units	“10 points” and “3” were trial-count differenc
§6.5	Filler count misstated	The case bank holds 12 benign fillers (6 dom
§6	Vector-attribution claim survived its own retraction	“attributes it to the memory-channel vector” c
§4.6	“Per-model calibration would resolve” $AUC=0.083$	A monotone threshold shift cannot repair a ra
§8	Conclusion recommended the gate its own data falsify	“gated by recipient metadata or semantic che
<i>Corrections introduced in the preceding revision (self-audit, no new data collection):</i>		
X1	Implicit-arm upper bound was trial-level, not cluster-level	0/141 Wilson upper 0.0265 assumes 141 ind
§4.6	Hold-out recall CI used total sessions as the denominator	Recall is defined over positives; $N=280$ is al
§4.10	Vector-attribution implication withdrawn	Earlier text asserted $rbs=1 \Rightarrow$ memory-chan
§3.1	Definition 3 sharpened; edge-vs-node observability made explicit	The universally-quantified condition is necess
§5	“Correct deployment model is escalation-with-semantic-gating” softened	No content- or intent-level gate was evaluate
X1	Opening paragraph contradicted the Outcome paragraph on the paired contrast	Said the 12 shared effective configurations “d
X1	Send-only sensitivity mislabelled as matching the main threat-model endpoint	<code>score_x1.send_only</code> filters on presence o
X6	Cell counts misstated	9 of 12 cells yielded <code>eligible=0</code> (not 10); and
§2	BCa jackknife acceleration was computed on an unrepresentative block	Capped at the <i>first</i> 200 leave-one-out samples
V3-1	H2a/H3 tests are trial-level on clustered data	Trials nest in 18 scenario configurations; Fish

Table 16: X1 MINJA, gpt-4.1, after the preregistered continuation to the registered $N=360$ cap. `orp` is *observable_read_of_poison* among eligible successes. “Effective clusters” collapses the inert `similarity` factor (§6.5); the preregistered gate is ≥ 10 success-contributing effective clusters *per arm*. The send-only rows restrict to trials in which `email_send.email` actually fired; this is a *necessary* condition for the main threat-model endpoint but not equivalent to it, because the eligibility flag is still the harness’s draft-or-send `attack_success` (`score_xprogram.score_x1_send_only` filters on the presence of a send call and does not re-verify that the attacker-directed action was the send). The point estimates are unchanged and neither arm passes. The paired contrast’s 12 shared configurations are those attempted in both arms, of which 8 contribute eligible successes in both, so it does not independently satisfy the gate.

Arm / endpoint	Trials	Elig.	orp	Eff. cl.	Gate	Disposition
Observable (draft-or-send, as scored)	252	80	80/80 = 100%	10	pass	positive control, gated
Implicit (draft-or-send, as scored)	360	141	0/141 = 0%	9	fail	LOW-CLUSTER
Observable (send-only sensitivity)	—	74	74/74 = 100%	9	fail	endpoint-sensitive
Implicit (send-only sensitivity)	—	138	0/138 = 0%	8	fail	LOW-CLUSTER
Paired contrast (matched configs)	—	—	+1.0	8 of 12	secondary	does not override per-arm gate

Table 17: Implicit-delivery attack success by task domain and compliance framing (X1 MINJA implicit arm, gpt-4.1, 30 trials per cell at the registered cap). The poison was retrieved at median rank 1 in 30/30 trials in *every* cell, so these differences are not retrieval-competition artifacts: delivery is held constant and only imitation varies. Cells at 0/30 carry a Wilson upper bound of 0.113, so they are low-yield rather than demonstrably zero.

Task domain	historical-practice	mandatory-audit-cc	pooled
meeting_followup	30/30	30/30	60/60
incident_report	30/30	28/30	58/60
budget_expense	14/30	4/30	18/60
client_deliverable	3/30	0/30	3/60
project_status	1/30	1/30	2/60
compliance_report	0/30	0/30	0/60
all domains	78/180	63/180	141/360

Table 18: E2 (discharged 2026-09-19): benign destination-bearing recall before the first exfiltrating action, on the instrumented re-collection. Denominators are sessions that reached a destination-bearing action; the remainder lie outside E2’s conditioning event. The two share denominators are thin and the share intervals are correspondingly wide.

Channel	Model	E2	Rate	Wilson 95% CI
email	gpt-4.1	594/622	95.5%	[0.936, 0.969]
email	gpt-4o	716/716	100%	[0.995, 1.000]
share	gpt-4.1	22/22	100%	[0.851, 1.000]
share	gpt-4o	5/5	100%	[0.566, 1.000]